



TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701

Student Notes

A single consolidated study companion covering the combined course: network foundation (sessions 1 to 3) followed by the CompTIA Security+ SY0-701 core (sessions 4 to 12). Key terms, core concepts, book reference deep dives, cautions, self-check and exam tips for all twelve sessions in one document.

Course: Network Fundamentals + CompTIA Security+ SY0-701

12 sessions of 3 hours - combined network foundation and Security+ core

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Companion to: session objectives, slides, instructor notes, instructor script, quizzes

Network Fundamentals + CompTIA Security+ SY0-701	CONTENTS
---	-----------------

Contents

This single student notes document brings together the key terms, core concepts, cautions, self-check questions and exam tips from all twelve sessions of the combined course.

Ch.	Chapter
1	Network Models & IP Addressing
2	Switching, Routing & Network Architecture
3	Network Services, Operations & Troubleshooting
4	Security Controls, Concepts & Zero Trust
5	Threat Actors, Attack Surfaces & Vectors
6	Cryptography, PKI & Identity
7	Security Architecture & Data Protection
8	Network Security Controls & Segmentation
9	Network Troubleshooting & Resilience
10	Vulnerability Management & Asset Protection
11	Security Operations, Monitoring & Forensics
12	Governance, Risk, Compliance & Awareness



TRAINING @ FORREST.ONE

CHAPTER 01

Network Models & IP Addressing

The language of networks: the seven OSI layers and encapsulation, the physical, data link, network and transport layers, the media and topologies they run over, then the IPv4 addressing and subnetting that security controls such as firewalls, ACLs and segmentation rely on.

Student Notes, Network Models & IP Addressing

Your revision guide for Session 1, the first of three network-foundation sessions in the combined course. Read alongside the slides, work the calculations by hand, then use the self-check questions and the session quiz to confirm you are ready for the security content ahead. The session runs in six chapters: the language of networks, the OSI model, physical and data link, network and transport, media and topologies, and IPv4 addressing and subnetting.

Key terms

Term	Definition
OSI model	Seven layers organising network communication, from physical to application
TCP/IP stack	Four-layer model: application, transport, internet, network access
Encapsulation	Each layer adds its header as data travels down the stack
PDU	Protocol data unit: segment or datagram (layer 4), packet (layer 3), frame (layer 2), bits (layer 1)
Port	Transport-layer address, such as 443 for HTTPS and 53 for DNS
MAC address	48-bit hardware address written in hex, used at layer 2, and changeable in software
Logical Link Control	Upper data link sublayer; identifies the layer 3 protocol, error checking
Media Access Control	Lower data link sublayer; shares the medium, delivers by hardware address
Cyclic Redundancy Check	Checksum appended to a frame to detect corruption in transit
Time to Live	Counter in an IP packet that drops by one per router and stops loops
Twisted pair	Cheapest common copper cable; categories rate its capability
Fibre optic	Carries data as light, immune to interference, longest distance
Transceiver	Converts between signal types so a copper port can feed a fibre link
Registered Jack 45	The standard copper connector
Small Form factor Pluggable	Hot-swappable module for changing media type on a switch port
Star topology	Every device connects to a central point: easy to troubleshoot, single point of failure

Term	Definition
Full mesh	Every node links to every other node: maximum resilience, maximum cost
Subnet mask	32 bits, ones then zeros, marking the network/host boundary
CIDR	Classless notation: the slash count of network bits
Private range	10.0.0.0/8, 172.16.0.0/12 and 192.168.0.0/16: reusable internally, not internet routable
Loopback	127.0.0.1, always the local machine
169.254 range	Self-assigned when no address server answered: a fault symptom
Network address	First address of a range: identifies the subnet, never assigned
Broadcast address	Last address of a range: reaches all hosts, never assigned
VLSM	Variable subnet masks within one network, allocated largest first

Core concepts

Chapter 1, The language of networks

Layering exists so that faults are findable. Without it, a connectivity problem is an unfindable mixture of cable, switch, route and server. With seven layers, each with one job, you test in turn and eliminate as you go. Remember that the model is a map, not a product: nobody sells a layer five, but thinking in layers is how real troubleshooting is done.

Chapter 2, The OSI model

The seven layers are application (7), presentation (6), session (5), transport (4), network (3), data link (2) and physical (1). The TCP/IP stack condenses these to four: application (OSI 5 to 7), transport (4), internet (3), network access (1 to 2). A message travels down the stack: the application produces the data, transport adds ports and produces a segment or datagram, network adds IP addresses and produces a packet, data link adds hardware addresses and produces a frame, and the physical layer transmits bits. The receiver reverses the process. Encapsulation is simply that wrapping, and the vocabulary matters because exam questions use these exact words.

Chapter 3, Physical and data link

Layer 1 carries the raw bitstream with no understanding of meaning. Its three signal types are electrical (copper), light (fibre) and radio (wireless), and it defines the cabling, connectors and signalling standards. Cost, distance and interference decide which medium you use. A completely dead link is almost always a layer 1 fault, so check the cable, the port indicator and the link state before anything else. Layer 2 handles node to node delivery on one local network using 48-bit Media Access Control addresses written in hexadecimal, and its unit of data is the frame. It appends a Cyclic Redundancy Check to detect corruption. It has two sublayers: Logical Link Control, which faces up to the network layer and identifies the layer 3 protocol, and Media Access Control, which faces down to the physical layer, shares the medium and delivers

by hardware address. Hardware addresses are assigned by manufacturers but changeable in software, so they are not a trustworthy identity.

Chapter 4, Network, transport and above

Layer 3 provides logical addressing and routing: a hardware address identifies a device on a local segment, an IP address identifies a device across networks. Routers work at layer 3, Time to Live drops by one per router and discards the packet at zero, which prevents endless circulation, and the layer adapts routes when links fail. Layer 4 delivers between applications using port numbers. Transmission Control Protocol is connection oriented, sequence numbered, guarantees delivery and retransmits losses. User Datagram Protocol is connectionless, unordered and best effort, which makes it faster and lower latency and preferable for voice, video and lookups. Layer 5 manages conversations and checkpoints; layer 6 handles format translation, compression and encryption; layer 7 is where HTTP and DNS live, and it is the protocol layer, not the program.

Chapter 5, Media and topologies

Wireless uses radio waves and buys mobility, but it is a shared medium: lower frequencies travel further and carry less, higher frequencies carry more over shorter distances, and every device on the channel competes for airtime. Wired media: twisted pair is cheapest and most common (Category 5e and Category 6 are the ones you will meet), shielding reduces interference, coaxial suits legacy networks and broadband, and fibre carries light, so it is immune to interference and spans the longest distances. Transceivers convert between signal types, RJ45 is the standard copper connector, SC and LC are the fibre connectors to recognise, and Small Form factor Pluggable modules are hot swappable. Topology is a trade between cost and resilience: star is simple with a single point of failure, full mesh has no single point of failure but is costly and complex, hybrid does both where it matters, and spine and leaf gives predictable latency in the data centre.

Chapter 6, IPv4 addressing and subnetting

An IPv4 address is 32 bits in four octets, written in dotted decimal, each octet 0 to 255, giving about 4.29 billion addresses. Recognise these on sight: 10.0.0.0/8, 172.16.0.0/12 and 192.168.0.0/16 are private and not internet routable; 127.0.0.1 is loopback; a 169.254 address is self-assigned when no address server answered and is a symptom, not a configuration. A subnet mask is 32 bits of ones then zeros: the ones mark the network, the zeros the host. Two addresses are always reserved, the network address and the broadcast, so a /24 mask gives 254 usable hosts, not 256. Classless addressing replaced the classes: the slash states the network bits, a larger slash means a smaller network, and /30 gives just two addresses. VLSM lets each subnet be a different size and is allocated largest first, because small-first allocation fragments the space. Worked example: 192.168.1.50 with mask 255.255.255.0 gives network 192.168.1.0, usable hosts 192.168.1.1 to 192.168.1.254, and broadcast 192.168.1.255.

Prefix and mask reference

Prefix	Subnet mask	Usable hosts	Typical use
/24	255.255.255.0	254	Office network
/25	255.255.255.128	126	Half a /24, a large department

Prefix	Subnet mask	Usable hosts	Typical use
/26	255.255.255.192	62	A department or a small server segment
/27	255.255.255.224	30	A small team or a DMZ segment
/28	255.255.255.240	14	A very small segment
/29	255.255.255.248	6	A tiny segment or a management zone
/30	255.255.255.252	2	A point-to-point link between two routers

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: the OSI model and Layer 1

The Open Systems Interconnection (OSI) model divides network communication into seven abstraction layers. Each layer has a defined duty, so faults can be isolated and vendors can build interoperable products against shared standards. Layer 1, the Physical layer, moves raw bits as electrical signals on copper, light pulses on fibre or radio waves.

Layer	Name	Unit
7	Application	Data
6	Presentation	Data
5	Session	Data
4	Transport	Segment
3	Network	Packet
2	Data Link	Frame
1	Physical	Bit

Reference deep dive: the data link layer

Layer 2, the Data Link layer, moves data between adjacent nodes on one segment. It identifies each interface by a 48 bit Media Access Control (MAC) address, written in hexadecimal as 00:1A:2B:3C:4D:5E, and builds frames carrying source and destination addresses plus an error check. Sublayers split the work.

- Cyclic Redundancy Check (CRC) appends a checksum per frame
- The receiver recalculates it and discards failures
- Logical Link Control encapsulates network layer protocols

- Media Access Control governs the shared medium
- Switches learn MAC addresses into a table
- Frames are forwarded only towards the destination port

Reference deep dive: the network layer

Layer 3, the Network layer, provides logical addressing and routing. Its protocol data unit is the packet, whose header carries source and destination IP addresses. Routers read those addresses, consult a routing table and forward the packet to the next hop. Open Shortest Path First (OSPF) and Border Gateway Protocol (BGP) recalculate routes dynamically.

- IPv4 addresses are 32 bit values in dotted decimal
- IPv6 addresses are 128 bit values in hexadecimal
- OSPF uses a link state algorithm to map topology
- BGP exchanges routes between autonomous systems
- Each hop decrements the Time to Live (TTL) value

Reference deep dive: the transport layer

Layer 4, the Transport layer, manages end to end delivery and balances reliability against speed. The Transmission Control Protocol (TCP) is connection oriented: it opens a session with a three way handshake, numbers segments, acknowledges receipt and retransmits losses. The User Datagram Protocol (UDP) is connectionless and suits streaming, gaming and voice over IP.

- Port 80 carries HTTP and port 443 carries HTTPS
- Port 25 carries SMTP, port 110 POP3 and port 143 IMAP
- Port numbers act as endpoints for applications
- TCP segments carry sequence and acknowledgement numbers
- UDP datagrams carry ports and a length field only
- Windowing stops a receiver being overwhelmed

Reference deep dive: the upper layers

The upper three layers serve the applications users work with. Layer 5, the Session layer, establishes, manages and terminates the dialog between systems and keeps checkpoints for recovery; Remote Procedure Call (RPC) and Session Initiation Protocol (SIP) work here. Layer 6 handles formatting, encryption and compression. Layer 7 supplies services such as SMTP, FTP and HTTP.

- Presentation layer standards include SSL/TLS, JPEG and PNG
- Checkpoints let a transfer resume after a break
- HTTP formats data as well as carrying web traffic
- HTTPS folds encryption into the Application layer
- The model is a conceptual map, not a strict hierarchy

Reference deep dive: wireless transmission media

Wireless media trade the certainty of cable for mobility, and the IEEE 802.11 family defines how a wireless local area network (WLAN) works. Standards climbed from 802.11b at 11 Mbps in the 2.4 GHz band to 802.11n at 600 Mbps using multiple input multiple output (MIMO), then 802.11ax beyond 10 Gbps.

- 802.11a and 802.11g both reach 54 Mbps
- The 2.4 GHz band has 11 channels, with 1, 6 and 11 clear
- The 5 GHz band gives up to 23 non overlapping channels
- Microwaves and Bluetooth interfere at 2.4 GHz
- 4G LTE reaches 100 Mbps and 5G up to 10 Gbps
- Satellite links add 500 milliseconds or more of latency

Range against interference

The 2.4 GHz band penetrates walls better but shares space with microwaves and Bluetooth. The 5 GHz band offers far more non overlapping channels at a shorter range.

Reference deep dive: wired media and cabling hardware

Wired media differ in cost, reach and performance. Single mode fibre has a core near 8 to 10 micrometres, carries one light path and reaches beyond 100 kilometres. Multimode fibre, at 50 to 62.5 micrometres, carries several paths but suffers modal dispersion and is rated near 550 metres at 10 Gbps. Coaxial cable suits moderate distances.

Medium	Reach	Notes
Single mode fibre	Over 100 km	Core about 8 to 10 micrometres
Multimode fibre	550 m at 10 Gbps	Core 50 to 62.5 micrometres
Coaxial cable	A few kilometres	Shielded, limited bandwidth
Direct Attach Copper	Up to 10 m	Up to 10 Gbps, in rack use

- SC uses a square push pull body and a 2.5 mm ferrule
- LC halves that size with a 1.25 mm ferrule
- ST locks with a bayonet twist on multimode fibre
- MPO carries up to 24 fibres in one connector
- RJ11 has four or six pins and RJ45 has eight
- SFP+ reaches 10 Gbps while QSFP carries four channels

Reference deep dive: star, mesh and hybrid topologies

Topology describes how nodes and links are arranged. In a star, every node links to a central hub or switch, so devices are easy to add or remove, but that central device is a single point of failure. A full mesh connects every node to every other node, and a partial mesh connects some pairs only.

- Star offers simple management and one failure point
- Full mesh tolerates the loss of any single link
- Full mesh cost climbs sharply as nodes are added
- Partial mesh balances redundancy against cost
- Hybrid joins star and mesh for different departments

Reference deep dive: data centre architectures

Data centres use structured hierarchies rather than one flat design. The three tier model separates a core layer that transports traffic quickly, a distribution layer that applies routing and Quality of Service (QoS) policy, and an access layer that connects users and devices. The collapsed core merges the first two tiers.

- Core: high speed transport with minimal latency
- Distribution: routing, filtering and QoS policy
- Access: connects computers, printers and access points
- Collapsed core: two tiers for smaller sites
- Spine and leaf: one hop reaches any other leaf
- Point to point links carry wide area connections

Reference deep dive: IPv4 addressing fundamentals

An IPv4 address is a 32 bit label written in dotted decimal as four octets, each from 0 to 255, so the space holds 4,294,967,296 addresses. The binary form 11000000.10101000.00000001.00000001 converts to 192.168.1.1. Classful addressing split the space by first octet but wasted addresses, so Classless Inter-Domain Routing (CIDR) replaced it.

Class	First octet	Purpose
A	1 to 126	Very large networks
B	128 to 191	Medium networks
C	192 to 223	Small networks
D	224 to 239	Multicast groups
E	240 to 255	Experimental use

Private ranges and APIPA

RFC1918 private blocks are 10.0.0.0 to 10.255.255.255, 172.16.0.0 to 172.31.255.255 and 192.168.0.0 to 192.168.255.255, and they need Network Address Translation (NAT) to reach the

internet. Automatic Private IP Addressing (APIPA) supplies 169.254.0.1 to 169.254.255.254 when no DHCP server answers.

Reference deep dive: subnetting and CIDR

A subnet mask is a 32 bit number of consecutive 1s followed by 0s: the 1s mark the network portion and the 0s the host portion. CIDR writes that prefix length after a slash, so 192.168.1.0/24 equals the mask 255.255.255.0. Variable Length Subnet Masking (VLSM) allows subnets of different sizes from one block.

CIDR	Subnet mask	Usable hosts
/24	255.255.255.0	254
/25	255.255.255.128	126
/26	255.255.255.192	62
/27	255.255.255.224	30
/28	255.255.255.240	14

Never count the two reserved addresses

Creating 4 subnets from 192.168.1.0/24 needs 2 borrowed bits, giving 192.168.1.0/26, 192.168.1.64/26, 192.168.1.128/26 and 192.168.1.192/26. Each block holds 64 addresses but only 62 usable hosts.

Practical cautions

- Do not assign the network or broadcast address to a host.
- Do not assume a /24 means 254 usable hosts in every context: it is 254 only when the whole block is one subnet.
- Do not treat a MAC address as an identity: it can be changed in software.
- Do not start troubleshooting a dead link at layer 3: check the cable, the port light and the link state first.
- Do not confuse Logical Link Control, which looks up to layer 3, with Media Access Control, which looks down to layer 1.
- Do not say the application layer is the application: it is the protocol layer, where HTTP and DNS live.
- Do not choose a cable on price alone: distance, bandwidth and interference decide.
- Do not read a 169.254 address as a valid configuration: it means no address server answered.
- Do not allocate VLSM smallest-first: it fragments the address space.
- Do not confuse a larger prefix with a larger network: /30 is two addresses, /24 is 254 usable hosts.

Self-check questions

1. Why does layering make a fault findable?

2. Name the seven OSI layers and one protocol, device or job for each.
3. What is the unit of data at layers 4, 3, 2 and 1?
4. Which two data link sublayers exist, and which layer does each face?
5. What are the three signal types, and which medium carries each?
6. A user has no connectivity at all. What do you check first, and why?
7. Give two differences between Transmission Control Protocol and User Datagram Protocol.
8. Which three factors decide which cable you install?
9. What is the weakness of a star topology, and how does a mesh answer it?
10. What is the network address, usable host range and broadcast for 192.168.1.50 with mask 255.255.255.0?
11. Which three IPv4 ranges are private, and which address is loopback?
12. Convert mask 255.255.255.240 to prefix notation and give its usable host count.

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 1

- CompTIA references OSI layer numbers, so know both models and the mapping between them.
- Exam questions use the unit-of-data vocabulary precisely: segment, datagram, packet, frame, bits.
- The subnet formula pattern is the fastest mark on the paper: every extra prefix bit halves the count, and two addresses are always reserved.
- Remember the common connectors: RJ45 on copper, SC and LC on fibre, SFP modules hot swappable.
- Media questions are decided by distance, bandwidth and interference, in that order of frequency.
- A 169.254 address is a fault symptom, and questions use it as a distractor.
- Segmentation is a scored security topic: link subnets to zones, the attack surface and lateral movement.

Further reading

- RFC 791, Internet Protocol (IPv4).
- RFC 4632, CIDR: An Address Assignment and Aggregation Strategy.
- IEEE 802.3, Ethernet, for the data link and physical layer detail.
- IEEE 802.11, Wireless LAN, for the wireless medium.
- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture).
- CompTIA Security+ SY0-701 Exam Objectives, Domain 4 (Security Operations) for network attack mitigation.



TRAINING @ FORREST.ONE

CHAPTER 02

Switching, Routing & Network Architecture

The device, the route and the segment: switches and routers, security appliances, load balancing, cloud networking and service models, static and dynamic routing, administrative distance, address translation and first hop redundancy, VLANs, trunks and spanning tree, wireless deployment, and the physical installation that carries it all.

Student Notes, Switching, Routing & Network Architecture

Your revision guide for Session 2, the second of three network-foundation sessions. Read alongside the slides, trace the frame walkthrough and the route selection order by hand, then use the self-check questions and the session quiz to confirm you are ready for the services session and the Security+ core. The running theme is that every device and every segment is a boundary, and that segmentation is an architectural control rather than tidiness.

Key terms

Term	Definition
Frame	Layer 2 PDU, Ethernet headers plus payload
Packet	Layer 3 PDU, forwarded by a router using IP addresses
MAC address	48-bit hardware address, six hex pairs; the first three octets are the OUI
Forwarding table	The switch's learned map of MAC addresses to ports
Unknown unicast flooding	Frame sent to every port except the source when the destination is unknown
MAC flooding	Overflowing the forwarding table so the switch degrades to hub mode
Firewall	Filters traffic on rules built from addresses, ports, protocols and content
IDS	Intrusion detection system: monitors passively and alerts, never blocks
IPS	Intrusion prevention system: sits inline and can drop, block or reset
Load balancer	Spreads requests across a server pool; round robin or least connections
Forward proxy	Hides the client and filters outbound requests
Reverse proxy	Fronts the servers, caches content and terminates TLS
NAS	Network attached storage: file level sharing over the network, NFS and SMB
SAN	Storage area network: block level storage, usually over Fibre Channel
NFV	Network functions virtualisation: appliances become software on ordinary servers
VPC	Virtual private cloud: a logically isolated network inside a public cloud
Security group	Stateful firewall attached to a cloud resource; replies are allowed automatically

Term	Definition
Network ACL	Stateless filter at the subnet boundary of a cloud network
Static route	A route typed by hand; administrative distance 1; it never adapts
Distance vector	A protocol where each router advertises its whole table: routing by rumour
Link state	A protocol where every router holds the same map and calculates its own paths
Path vector	A protocol that selects on attributes and policy; BGP is the internet example
Administrative distance	A ranking of how trustworthy a route source is; the lowest value wins
Longest match rule	The most specific route wins, before distance or metric is considered
NAT	Network address translation: rewrites addresses in the packet header
PAT	Port address translation: many private addresses onto one public address by port
First hop redundancy	HSRP, VRRP and GLBP: a shared virtual gateway address that survives failure
Subinterface	A logical interface on one physical router port, serving one VLAN
VLAN	A logical broadcast domain built inside the switching hardware
Trunk port	Carries many tagged VLANs between switches
Access port	Carries a single untagged VLAN to one endpoint
802.1Q tag	Four byte header carrying the 12-bit VLAN identifier
Native VLAN	The untagged VLAN on a trunk; VLAN 1 by default and a known risk
VLAN hopping	Crossing VLAN boundaries by switch spoofing or double tagging
Port security	Limits the MAC addresses allowed on a port; violations can shut it down
PortFast	Skips the listening states on a port that leads to one endpoint
BPDU Guard	Shuts a port that receives a bridge protocol data unit
Root Guard	Prevents a port from becoming a root port
STP	IEEE 802.1D, blocking redundant ports to keep one loop free path
RSTP	IEEE 802.1w, converging in seconds with alternate and backup roles
Root bridge	The switch with the lowest bridge identifier: priority plus MAC address
MTU	Maximum transmission unit; 1500 bytes on standard Ethernet
Jumbo frame	An Ethernet frame up to about 9000 bytes; every device must agree
SSID	Service set identifier, the wireless network name clients see
BSSID and ESSID	Single access point identifier, and the shared name that allows roaming

Term	Definition
WPA2 and WPA3	Wireless encryption with AES; WPA3 adds simultaneous authentication of equals
802.1X	Authenticates a device before it joins the network, using a central server
DMZ	Segment hosting public facing services, isolated from the internal network
Blast radius	How far a compromise can reach; segmentation reduces it

Core concepts

Chapter 1: Infrastructure devices

A switch forwards frames at layer 2 by MAC address, building its table from source addresses and flooding unknown destinations to every port except the source. A router forwards packets at layer 3 by IP address between networks. Firewalls filter on rules, intrusion detection monitors and reports, and intrusion prevention sits inline and blocks. Load balancers spread requests across a pool; a forward proxy hides clients and a reverse proxy fronts servers and terminates TLS. NAS serves files with NFS and SMB; a SAN serves blocks over Fibre Channel. Access points bridge wireless clients to the wired network, controllers manage them centrally, and wireless bridges join two segments with no cable.

Chapter 2: Cloud networking and routing foundations

Network functions virtualisation turns firewalls, routers and balancers into software, which lowers cost but moves the attack surface to the management plane and the hypervisor. A virtual private cloud is a logically isolated cloud network, with security groups as stateful per-resource firewalls and network ACLs filtering at the subnet boundary. Deployment models are public, private and hybrid; service models are software, infrastructure and platform as a service, and each one shifts, but never removes, responsibility. Routing starts with static routes, which never adapt, then extends to distance vector protocols such as RIP, where fifteen hops is the maximum and sixteen means unreachable, and link state protocols such as OSPF, where every router holds the same map of the network.

Chapter 3: Route selection and translation

A router chooses in a strict order: the longest match first, then administrative distance to pick the source it trusts, then the metric to pick between paths from that source. Connected routes score 0, static 1, EIGRP 90, OSPF 110 and RIP 120. EIGRP is advanced distance vector with a pre-calculated backup path; BGP is the path vector protocol of the internet and selects on policy. NAT rewrites addresses as traffic crosses a boundary, with static NAT for published servers and dynamic NAT from a pool; PAT multiplexes many addresses onto one by port number, which is why inbound services need port forwarding. First hop redundancy gives routers a shared virtual gateway address, so clients never notice a failure. Router on a stick gives each VLAN a subinterface and a gateway over one shared trunk, which is simple but can become the bottleneck.

Chapter 4: VLANs, switching and spanning tree

A VLAN is a logical broadcast domain, giving containment: fewer broadcasts, a smaller blast radius and no easy lateral movement. Trunks carry many VLANs between switches with an 802.1Q tag, and the native VLAN crosses untagged, so a mismatch can leak traffic between VLANs. Switch spoofing and double tagging are the two VLAN hopping attacks. Port configuration matters too: speed and duplex agree, port security limits addresses per port, PortFast skips the listening states on an endpoint port and BPDU Guard shuts a port that receives a BPDU. Redundant links create loops, so STP elects a root bridge on the lowest bridge identifier and blocks the redundant ports. Rapid spanning tree converges in seconds, multiple spanning tree maps VLAN groups to instances, and Root Guard, BPDU Guard and port security are the defences. Finally, the MTU is 1500 bytes, jumbo frames reach about 9000, and every device in the path must agree or packets vanish.

Chapter 5: Wireless and physical deployment

In the 2.4 GHz band only channels 1, 6 and 11 do not overlap; 5 GHz offers up to twenty three non overlapping channels and 6 GHz far more again. The SSID is the network name, the BSSID names one access point and the ESSID lets clients roam. Hiding the name is not a control. Encryption runs from WEP, which is broken, through WPA and WPA2 with AES, to WPA3 with simultaneous authentication of equals. Enterprise mode uses 802.1X with a central authentication server, Protected EAP inside a TLS tunnel and EAP TLS with certificates. A guest network gets its own name, its own VLAN and a bandwidth limit. Access points are placed by survey, not by eye, and the room itself matters: a 19 inch rack, 1.75 inch rack units, labelled cable, a documented patch panel, locked racks, hot and cold aisles and a UPS.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: routers, switches and their layer scope

Switches forward frames at Layer 2, the Data Link Layer, by destination MAC address. Routers forward packets at Layer 3, the Network Layer, by destination IP address, consulting a routing table of networks and next hops. Switching is local; routing is internetwork.

- Switches forward frames by MAC address at Layer 2.
- Routers forward packets by IP address at Layer 3.
- A switch learns source addresses to fill its table.
- Routing carries packets between separate networks.

Reference deep dive: security appliances, load balancers and proxies

Firewalls filter traffic against rules matching addresses, ports and protocols, and they sit at the perimeter as the first line of defence. An Intrusion Detection System monitors passively and alerts without blocking; an

Intrusion Prevention System sits inline and drops what it detects. Load balancers spread requests across a server pool.

- Firewall: allow or block traffic by rule.
- IDS: passive detection and alerting only.
- IPS: inline enforcement that drops attacks.
- Round robin and least connections balance server load.
- Forward proxies hide clients; reverse proxies protect servers.

Reference deep dive: storage and wireless infrastructure devices

Network Attached Storage is file level storage that clients reach across the LAN using NFS or SMB, which suits shared files. A Storage Area Network is block level storage reached over Fibre Channel or iSCSI, so servers see remote disks as local disks, which suits databases. Bridges extend coverage without cabling.

- NAS: file level, using NFS or SMB.
- SAN: block level, using Fibre Channel or iSCSI.
- Access point: joins wireless clients to the wired network.
- Wireless controller: centralised management of access points.
- Wireless bridge: joins two segments without cabling.

Reference deep dive: cloud networking and service models

Network Functions Virtualization replaces hardware appliances with software, so firewalls, routers and load balancers run as virtual machines at lower cost. A Virtual Private Cloud is an isolated part of a public cloud with its own address ranges, subnets and route tables, guarded by stateful security groups.

- Public cloud: shared infrastructure, pay as you go.
- Private cloud: dedicated to one organisation.
- Hybrid cloud: sensitive work private, the rest public.
- SaaS: the provider runs the application, as with Microsoft 365.
- IaaS: the customer rents virtual machines and storage.
- PaaS: the customer builds on a managed runtime.

Reference deep dive: static routing

A static route is entered by hand and changes only when an administrator edits it. Static routing suits small networks, stub networks with one path in and out, and default routes that catch unlisted traffic. Its administrative distance of 1 places it ahead of dynamic routes, but it cannot react to failure.

- Stub network: one route in and out.
- Default route: catches unlisted traffic.
- Static routes carry an administrative distance of 1.
- Limitations: weak scalability, no reaction to failure.

Reference deep dive: distance vector routing and convergence

Distance vector protocols share the whole routing table with immediate neighbours, a process the book calls routing by rumour. The Routing Information Protocol uses hop count, with 15 hops as the maximum distance. Convergence, the time for all routers to agree on the topology, is slow, risking loops and black holes.

- RIP metric: hop count, maximum 15, and 16 means unreachable.
- Split horizon: never advertise a route back the way it arrived.
- Route poisoning: mark a failed route unreachable at maximum hops.
- Hold down timers: suppress updates while the network settles.

Exam note

Distance vector protocols suffer the count to infinity problem, as routers raise the hop count of a lost route until it passes 15. Split horizon, route poisoning and hold down timers stop that loop.

Reference deep dive: dynamic routing with OSPF, EIGRP and BGP

Open Shortest Path First is an open standard link state protocol for one autonomous system. Routers flood Link State Advertisements to build a Link State Database, then run Dijkstra's algorithm with themselves as the root, costing paths by bandwidth. EIGRP is Cisco's hybrid protocol, and BGP is the path vector protocol of the internet.

- OSPF: link state and open standard, with Area 0 as the backbone.
- OSPF states: down, init, two way, exstart, exchange, loading, full.
- EIGRP: Cisco hybrid, using bandwidth, delay, load and reliability.
- BGP: path vector, choosing by AS path, origin and next hop.

Reference deep dive: administrative distance and route selection

Administrative distance ranks how trustworthy a routing source is, and the lower the value the more the router trusts it. When two sources offer a route to the same destination, the router installs the lower value, so a static route beats one learned by OSPF. The longest match rule then picks the most specific entry, such as 192.168.1.192/26 for a host at 192.168.1.200.

Route source	Administrative distance
Connected network	0
Static route	1
External BGP	20
EIGRP	90
OSPF	110
RIP	120

Reference deep dive: network address translation and PAT

Network Address Translation rewrites IP addresses in packet headers as traffic crosses a router or firewall. It slows IPv4 exhaustion, since the 32 bit scheme offers about 4.3 billion addresses. Static NAT maps 192.168.1.10 to 203.0.113.10 one to one, dynamic NAT draws on a pool, and PAT shares one address by port.

- Static NAT: one to one, for servers needing public access.
- Dynamic NAT: many to many, from a pool of addresses.
- PAT, also called NAT overload: many devices to one address by port.
- Port forwarding sends unsolicited inbound traffic to one device.

Reference deep dive: first hop redundancy and router on a stick

First hop redundancy protocols protect the default gateway by letting routers share one virtual IP address, so a router failure does not break connectivity. HSRP is Cisco proprietary and elects an active router with a standby. VRRP is the open standard equivalent, and GLBP also balances load.

Protocol	Ownership	Roles
HSRP	Cisco proprietary	Active and standby
VRRP	Open standard	Master and backup
GLBP	Cisco proprietary	Active virtual gateway and forwarders
Virtual IP	Shared by the group	One gateway address for clients

Reference deep dive: virtual LANs, trunking and tagging

A Virtual Local Area Network creates separate broadcast domains on one physical switch, which limits broadcast traffic and separates groups such as guests from internal users. Port based assignment is the most common method. VLAN 1 is usually the default and native VLAN, and a separate management VLAN keeps administrative access apart.

- Port based VLAN: each switch port belongs to one VLAN.
- Default VLAN: VLAN 1 on most switches.
- Native VLAN: carries untagged traffic, and both ends must match.
- Management VLAN: dedicated to device administration.
- Access port: one VLAN, untagged frames.
- Trunk port: many VLANs, 802.1Q tagged frames.

Exam note

The 802.1Q tag adds 4 bytes to the Ethernet frame and carries the VLAN identifier. A native VLAN mismatch at the two ends of a trunk link misroutes or drops untagged traffic, so set the same native VLAN on both switches.

Reference deep dive: switch interface configuration and frame size

Switch ports run at a set speed, usually 10 Mbps, 100 Mbps, 1 Gbps or higher, and in one duplex mode. Half duplex cannot send and receive at once and invites collisions; full duplex can. A duplex mismatch causes collisions and latency. Port security limits the MAC addresses on a port.

- Violation modes: protect, restrict and shutdown.
- Speed and duplex must match at both ends.
- PortFast and BPDU guard protect access ports.
- Standard Ethernet MTU is 1500 bytes; jumbo frames reach 9000.

Reference deep dive: wireless channels and frequencies

Wireless LANs use licence free radio bands. The 2.4 GHz band carries 11 to 14 channels depending on region, of which only 1, 6 and 11 avoid each other in the United States. The 5 GHz band offers up to 23 non overlapping channels at shorter range, and Wi Fi 6E adds the 6 GHz band.

Band	Channels	Character
2.4 GHz	11 to 14, with 1, 6 and 11 in the United States	Longer range, more interference
5 GHz	Up to 23 non overlapping	Shorter range, less congestion
6 GHz	Added for Wi Fi 6E	Built for dense device populations

Reference deep dive: wireless configuration, security and authentication

The Service Set Identifier is the network name clients see, while the BSSID is the access point MAC address and the ESSID spans several access points. Encryption has passed through WEP, which is broken, WPA with the Temporal Key Integrity Protocol, WPA2 with AES, and WPA3 with the Simultaneous Authentication of Equals handshake.

- WEP is broken and must never be used.
- WPA2 with AES is the current baseline.
- Infrastructure mode uses an access point; ad hoc links clients directly.
- Enterprise mode uses 802.1X with a RADIUS server.
- EAP types: PEAP, EAP-TLS and EAP-TTLS.
- Guest access belongs on its own SSID and VLAN.

Reference deep dive: access points, antennas and site surveys

Access points are either autonomous, configured one at a time, or controller based, managed centrally by a wireless LAN controller that handles policy and roaming. Antennas shape coverage: omnidirectional antennas radiate in all directions, while directional types such as Yagi and parabolic focus energy into a narrow beam.

- Autonomous: standalone, configured individually.
- Controller based access point: lightweight, managed centrally.
- Directional antenna: Yagi for medium range, parabolic for long range.

- More antenna gain means more range and a narrower beam.
- Site surveys and heat maps expose coverage gaps.

Reference deep dive: physical installation, power and environment

Network hardware is mounted in 19 inch racks, where height is measured in rack units and one rack unit is 1.75 inches. Clear labelling and documentation keep cabling orderly, and patch panels allow repatching without disturbing equipment. Power protection comes from an Uninterruptible Power Supply and Power Distribution Units.

- Rack: 19 inches wide, and one rack unit is 1.75 inches high.
- Patch panel: a central patching point that reduces port wear.
- Standby UPS switches to battery; an online UPS converts continuously.
- Temperature: keep equipment between 18 and 27 degrees Celsius.
- Humidity: hold relative humidity between 40% and 60%.

Reference deep dive: spanning tree protocol and its enhancements

Spanning Tree Protocol prevents Layer 2 loops, which cause broadcast storms, unstable MAC address tables and duplicate frames. Switches elect a root bridge, the one with the lowest bridge ID of priority and MAC address, then each switch finds the cheapest path to it. Classic STP needs up to 50 seconds.

- Blocking: listens for bridge protocol data units, forwards nothing.
- Listening: checks for loops, not forwarding and not learning.
- Learning: builds the MAC address table but does not forward.
- Forwarding: normal operation, frames pass and addresses are learned.
- Disabled: administratively shut down, taking no part in STP.
- RSTP roles: root, designated, alternate and backup ports.

Exam note

Classic STP is IEEE 802.1D and can take up to 50 seconds to converge. RSTP is IEEE 802.1w and converges in seconds, MSTP is IEEE 802.1s and maps VLAN groups to instances.

Practical cautions

- Do not confuse switches (layer 2, frames) with routers (layer 3, packets).
- Do not assume an IDS stops anything: it alerts, and only an inline IPS blocks.
- Do not mix up the proxies: forward hides clients, reverse fronts servers and terminates TLS.
- Do not treat NAS and SAN as interchangeable; the protocols and the level of access differ.
- Do not assume the cloud provider secures your data; service models shift responsibility rather than remove it.
- Do not leave the native VLAN at VLAN 1, and do not leave a trunk with an implied allow-all list.
- Do not confuse administrative distance (which source) with the metric (which path).

- Do not confuse NAT with PAT: PAT is the port-based form that hides many hosts behind one address.
- Do not confuse BPDU Guard (shuts the port) with Root Guard (stops root takeover).
- Do not assume jumbo frames help everywhere; a mismatch in the path silently drops large packets.
- Do not count a hidden SSID or a long WEP key as wireless security.
- Do not neglect physical access: it defeats every logical control you have.

Self-check questions

1. What three operations does a switch perform on a received frame, and what happens when the destination is unknown?
2. What does a firewall do that an intrusion detection system does not, and what does an intrusion prevention system add?
3. How does a forward proxy differ from a reverse proxy?
4. Compare network attached storage with a storage area network, including the protocol each uses.
5. What are security groups and network ACLs in a cloud network, and how do they differ?
6. Where does responsibility stop on infrastructure as a service compared with software as a service?
7. What is the difference between a static route and a route learned dynamically, and what is a stub network?
8. How does a link state protocol such as OSPF differ from a distance vector protocol such as RIP?
9. In what order does a router decide: longest match, administrative distance, metric?
10. Why does port address translation need port forwarding for an inbound service?
11. What problem do first hop redundancy protocols solve, and name two of them.
12. What is a subinterface, and what is the drawback of router on a stick?
13. What is a VLAN, and how does it limit lateral movement?
14. Describe the two VLAN hopping methods and the mitigation for each.
15. How does STP elect a root bridge, and what do the port states mean?
16. How does rapid spanning tree improve on classic STP?
17. Which feature stops a rogue root bridge, and which stops a rogue switch on an access port?
18. What is the standard Ethernet MTU, and why do jumbo frames fail silently when they are mismatched?
19. Which wireless channels do not overlap in 2.4 GHz, and why does 5 GHz suit a busy office?
20. Describe the wireless encryption history from WEP to WPA3, and explain enterprise mode.
21. How should a guest wireless network be designed?
22. Why does physical access defeat logical controls, and what installation practice reduces the risk?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz. The twenty quiz questions are tagged by topic area, so any weak area is easy to find and revise.

Exam tips for Session 2

- Learn, look up, forward, flood: the switch behaviour sequence is a classic question.
- Know the appliance split cold: the firewall refuses by rule, detection reports, prevention blocks inline.
- Link each device to its protocol: NAS with NFS and SMB, SAN with Fibre Channel, access points with 802.11.
- For any cloud question, ask where the responsibility boundary sits before answering.
- Memorise the administrative distance table, and remember the longest match rule is applied before it.
- Remember PAT tells sessions apart by port number, and that inbound services need a forwarding rule.
- The native VLAN rule is examinable: move it, prune unused VLANs, restrict the trunk allowed list.
- Distinguish switch spoofing from double tagging whenever VLAN hopping appears.
- STP port states, RSTP convergence and the guard features appear in scenario questions; know which guard does what.
- Segmentation as a control answers most 'contain the breach' and lateral movement questions.
- Wireless answers default to WPA2 or WPA3 with AES, enterprise mode with 802.1X, and a separate guest VLAN.

Further reading

- IEEE 802.1Q, VLAN tagging and trunking.
- IEEE 802.1D, Spanning Tree Protocol; IEEE 802.1w, Rapid Spanning Tree; IEEE 802.1s, Multiple Spanning Tree.
- IEEE 802.1X, port based network access control, with the EAP methods that carry it.
- RFC 826, Address Resolution Protocol, and its security implications.
- RFC 4271, Border Gateway Protocol version 4, and route hijacking as a security concern.
- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture) and Domain 4 (Operations).



TRAINING @ FORREST.ONE

CHAPTER 03

Network Services, Operations & Troubleshooting

The operations that keep a network running and the services an attacker can reach: well-known ports, documentation and change control, monitoring and recovery, then DHCP, DNS, time and remote access, with the Kali commands that verify them.

Student Notes, Network Services, Operations & Troubleshooting

Your revision guide for Session 3, the final session of the network-foundation strand. It follows the six chapters of the session: ports and traffic types, documentation and agreements, life cycle and change, configuration and monitoring, baselines, logs and resilience, and the core services with remote access. Read alongside the slides, run the commands on any Linux box you can reach, then use the self-check questions and the session quiz to confirm you are ready for the Security+ core.

Key terms

Term	Definition
Port	A numbered endpoint for a service; every firewall rule and troubleshooting step starts with one
FTP / SFTP	File transfer in plaintext on 21 and 20; Secure File Transfer inside SSH on 22
Telnet / SSH	Plaintext remote shell on 23; encrypted remote shell on 22
SMTP	Mail relay between servers on 25; client submission on 587
HTTP / HTTPS	Web on 80; web inside TLS on 443
SNMP	Device management: 161 for requests, 162 for traps
LDAP / LDAPS	Directory queries on 389; encrypted directory queries on 636
SIP	Call signalling on 5060; encrypted signalling on 5061
Unicast	One sender to one receiver
Broadcast	One sender to every device on the segment; stays inside one subnet
Multicast	One sender to the devices that joined the group
Anycast	One sender to the nearest of many servers sharing one address
Physical diagram	Devices, ports in use and cable runs: where the cable goes
Logical diagram	Addressing, VLAN segments and traffic flow: how traffic moves
Rack unit	1.75 inches of vertical space in a cabinet
IPAM	IP address management: tracks static and dynamic allocation and finds conflicts
SLA	Service level agreement: uptime, response time and resolution time

Term	Definition
The nines	Each additional nine cuts permitted downtime roughly tenfold
End of Life	The vendor stops selling the product
End of Support	No further patches; every flaw found afterwards stays open
Configuration drift	Slow divergence of a running device from its approved baseline
SNMP trap	An unsolicited alert sent from a device to the manager on port 162
Community string	A plaintext password in older SNMP versions; version 3 adds authentication and encryption
Flow record	A summary of a conversation: addresses, ports, protocol, bytes, times
NetFlow / sFlow / IPFIX	Flow collection as traffic crosses an interface, packet sampling, and the standard export format
Full packet capture	Every byte of every packet; highest detail, highest storage cost
Baseline	What normal looks like, recorded: bandwidth, latency, error rate and load
Syslog severity	Zero is emergency, seven is debug
SIEM	Correlates logs across sources to surface a pattern no single device shows
RPO	Recovery Point Objective: how much data you may lose; drives backup frequency
RTO	Recovery Time Objective: how long you may be down; drives failover
MTTR / MTBF	Mean Time To Repair and Mean Time Between Failures
Cold, warm, hot site	Space only; some equipment; a live mirror, from cheapest and slowest to costliest and fastest
Active-active	Every node serves traffic and shares the load
Active-passive	A standby takes over when a heartbeat stops
DORA	Discover, Offer, Request, Ack: the DHCP lease exchange
Relay agent	Carries DHCP conversation to a server on another subnet
Reservation	Pins one address to one hardware address
SLAAC	Stateless Address Autoconfiguration: the host builds its address from a router advertisement
DHCPv6	Stateful assigns and records addresses; stateless supplies settings only
Privacy extensions	The host rotates temporary IPv6 addresses, resisting long-term tracking
TTL	Time to live: how long a resolver may cache a DNS answer
Split horizon DNS	Answers internal and external clients differently
DNSSEC	Cryptographic signing of DNS records, so a forged answer fails validation
Stratum	Distance from the authoritative time source: zero is the reference clock

Term	Definition
VPN	Site to site joins two offices; remote access serves one user
IPsec transport / tunnel mode	Encrypts the payload only, or the whole packet
Split tunnelling	Sends only corporate traffic through the tunnel
Console cable	Out-of-band serial management when no network path answers
Attack surface	The sum of entry points an attacker can use to enter or extract data
Threat vector	The path or method an attacker uses to reach the attack surface

Core concepts

Chapter 1: Ports, protocols and traffic types

Learn the ports in pairs, plaintext against encrypted: 21/20 against 22, 23 against 22, 80 against 443, 389 against 636, 5060 against 5061. The protected form always moves to a different port. Rule of thumb: if the name has no S, assume plaintext. Troubleshooting rule: names resolve first, so check port 53 early. Traffic is unicast (one to one), broadcast (one to all on the segment, contained within one subnet), multicast (one to the group that joined) or anycast (one to the nearest of many sharing one address, which is how global name servers and content networks scale).

Chapter 2: Documentation, agreements and surveys

The physical diagram answers where the cable goes; the logical diagram answers how the traffic moves. Both must be current. Rack diagrams fix unit positions and power feeds, cable maps trace paths and termination points, wiring schematics document structured cabling and patch panels, and floor plans mark equipment rooms, cable trays and access points. The asset inventory carries serial number, location, configuration and owner; software entries carry version, licence key and location; warranties carry end dates. Address management tracks every allocation, detects conflicts and feeds changes into the name system. An SLA defines uptime, response time and resolution time, and each additional nine cuts permitted downtime roughly tenfold, which is a design instruction disguised as a contract term. Wireless surveys are predictive before installation and validation afterwards, and the lower band offers only three non-overlapping channels: 1, 6 and 11.

Chapter 3: Life cycle and controlled change

End of Life is a sales decision; End of Support is a security decision, because no further patches arrive and every flaw found afterwards stays open. Update as a process: download, verify the source, stage, test, deploy, with a tested rollback plan in a maintenance window. Decommissioning is a security event: sanitise the configuration, remove certificates and stored credentials, then destroy, degauss or overwrite the media, recycle it under electronic waste rules, and update the inventory, diagrams and monitoring. Change control counters self-inflicted outage: the Change Advisory Board reviews disruptive work, standard changes are pre-approved, normal changes are planned and tested, emergency changes go in first and are reviewed

afterwards, and every request carries justification, risk, impact, rollback and result. Every change touches four records: the diagram, the inventory, the configuration baseline and the monitoring.

Chapter 4: Configuration and monitoring tools

The production configuration is what a device runs now; the baseline configuration is the approved template. Drift is the slow gap between them, found by compliance checking and closed by restoring the baseline. Back up locally, in version control and off site, and test a restore. SNMP has a manager, an agent and a management information base; object identifiers name each value, GET reads and SET changes, and a trap is an unsolicited alarm sent to port 162. A community string is a plaintext password, so use version 3. Flow data summarises conversations: NetFlow collects as traffic crosses an interface, sFlow samples packets, IPFIX standardises the export. Flows are cheap and retain for months; full capture reads what was said, costs storage, and needs authority because packets hold personal data.

Chapter 5: Baselines, logs and resilience

A baseline records bandwidth, latency, error rate and device load under normal conditions, so that a number later means something. Threshold alerting fires on fixed limits; anomaly detection watches the shape of the data; trending forecasts capacity, and a baseline is only valid until the network changes. Log aggregation gives one searchable repository, syslog carries source, timestamp and severity from zero to seven, and a SIEM correlates across sources: one device shows an event, correlation shows the campaign. RPO says how much data you may lose and drives backup frequency; RTO says how long you may be down and drives failover; MTTR and MTBF measure repair speed and component life. Cold, warm and hot sites trade cost against recovery speed. Active-active shares load, active-passive waits on a heartbeat, load balancing steers around dead nodes, and a plan that has never been tested is unproven: use tabletop, simulation, parallel test and full failover, at least once a year.

Chapter 6: Core services and remote access

DHCP lease negotiation is DORA: Discover, Offer, Request, Ack, from no address at all to the broadcast address. A relay agent carries the conversation to another subnet, a reservation pins an address to a hardware address, scope options deliver gateway, name servers and domain, and two servers in failover share the pool. The security catch: a client accepts the first offer it receives, so an unauthorised server on the LAN wins the race and becomes your gateway. IPv6 changes who configures addresses: stateless autoconfiguration lets the host build its own address from a router advertisement, stateful DHCPv6 assigns and records, stateless DHCPv6 supplies options alone, and privacy extensions rotate temporary addresses. DNS runs on root servers, top-level domains and authoritative servers, with resolvers asking on your behalf; records are A, AAAA, CNAME, MX, PTR and TXT, each with a time to live that decides cache lifetime; split horizon answers internal and external clients differently, and DNSSEC signs records so forgery fails. Time is organised in strata from the reference clock downward, needs several sources for cross checking, and must be authenticated; drift breaks tickets, logs and timelines. VPNs are site to site or remote access, IPsec transport mode protects the payload and tunnel mode the whole packet, and split tunnelling sends only corporate traffic. Device management paths are the console cable, Secure Shell, the web interface and the programmatic interface, and every one of them is an attack surface.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: network traffic types

Traffic is classified by how many endpoints receive a transmission. Unicast carries one to one communication, as browsing and email do. Broadcast sends one packet to every device in a subnet, which is how address resolution works. Multicast delivers one stream to subscribed members. Anycast publishes one address from several locations, so the nearest instance answers.

- Unicast: one sender, one receiver
- Broadcast: one packet reaches all hosts in the subnet
- Multicast: one stream reaches subscribed members only
- Anycast: shared address, nearest instance responds

Reference deep dive: network documentation diagrams

Documentation records how infrastructure is built and how it behaves. A physical diagram shows hardware, ports and cable runs, which shortens fault finding. A logical diagram shows IP addressing, VLANs and traffic flow, which supports performance analysis. ISO/IEC 11801 governs cabling and TIA/EIA-606 governs labelling, while specialised drawings answer narrow questions and inventory records what exists.

- Physical: devices, ports and cable runs
- Logical: IP addressing, VLANs and traffic flow
- ISO/IEC 11801: cabling; TIA/EIA-606: administration
- Rack diagram: position by rack unit of 1.75 inches
- Cable map: paths, labels and termination points
- Inventory and IPAM: assets and address allocation

Reference deep dive: service level agreements

A Service Level Agreement is a contract stating the quality a provider must deliver. The usual metrics are uptime percentage, response time and resolution time. An uptime of 99.9% permits about 8.76 hours of downtime a year, while 99.99% permits roughly 52.56 minutes, so the target drives spending on redundancy.

- 99.9% uptime allows 8.76 hours down each year
- 99.99% uptime allows 52.56 minutes down each year
- Response time: how quickly a request is answered
- Resolution time: how quickly the fault is cleared
- Monitoring and reporting prove compliance

Reference deep dive: wireless site surveys

A wireless site survey proves that coverage and capacity match the design. A predictive survey happens before installation, using floor plans and modelling software to simulate signal propagation and choose access point positions. A validation survey happens afterwards, measuring signal strength, signal to noise ratio and throughput. Heat maps show signal, noise and channel utilisation so engineers can adjust placement.

1. Obtain floor plans showing walls and obstructions
2. Model signal propagation to place access points
3. Install the access points and measure real coverage
4. Record signal strength, signal to noise ratio and throughput
5. Adjust placement or channels where gaps appear

Reference deep dive: life cycle, firmware and asset retirement

Life cycle management covers equipment from purchase to retirement. End of Life marks the point when a vendor stops selling a product, so the device still runs but gets less attention. End of Support is worse, because patches and support stop, leaving known vulnerabilities unpatched. Refresh planning uses inventory assessment, vendor roadmaps, budgeting and risk assessment.

- End of Life: the vendor stops selling the product
- End of Support: patches and support cease
- Firmware updates: download, stage, test, deploy
- Deploy in a maintenance window with a rollback plan
- Sanitise: clear configurations, certificates, credentials
- Destroy, degauss or overwrite the storage media
- Recycle through certified waste partners

Reference deep dive: change management and the change request

Change management controls every modification to the network, because uncontrolled change is a leading cause of downtime. Work passes through a Change Advisory Board, which reviews impact and approves or rejects the request. ITIL places change management in service transition. The category sets the route: standard changes are pre approved, normal changes need review, and emergency changes proceed at once.

- Uncontrolled change causes outages
- Change Advisory Board reviews impact and approves
- Standard change: routine and pre approved
- Normal change: planned, tested and approved in advance
- Emergency change: urgent action, reviewed afterwards
- Life cycle: submission, justification, risk assessment

Reference deep dive: configuration management and recovery

Configuration management keeps device settings known, consistent and recoverable. The production configuration is the running state of a device; the baseline configuration is the approved template for that device type. Devices drift from the baseline over time, so teams monitor for drift and run compliance checks. Comparison tools show what changed between versions.

- Production configuration: the settings a device runs now
- Baseline configuration: the approved template
- Configuration drift: devices slowly leave the baseline
- Compliance checking compares live settings with policy
- Backups: manual exports, scheduled jobs, triggered events
- Restore the backup, then verify the device behaves correctly

Reference deep dive: network monitoring with SNMP

SNMP is the standard framework for monitoring network devices. A manager on a central server queries agents on routers and switches, reading values identified by Object Identifiers in the Management Information Base, such as 1.3.6.1.2.1.1.5. Agents also raise traps when a significant event occurs. Version 1 and version 2c use community strings; version 3 adds authentication and encryption.

Protocol	Port	Purpose
SNMP	UDP 161 and 162	Device queries and traps
LDAP	389	Directory queries and authentication
LDAPS	636	Directory queries over SSL/TLS
SIP	5060 and 5061	Voice signalling; 5061 uses TLS
Syslog	UDP 514	Centralised event logging
NTP	UDP 123	Clock synchronisation

Community strings are passwords

Version 1 and version 2c send the community string in plaintext, so anyone capturing traffic can read it. Version 3 adds authentication and encryption. Remember the ports: UDP 161 receives queries at the agent, and UDP 162 receives traps at the manager.

Reference deep dive: flow data, packet capture and baselines

Flow data summarises traffic patterns rather than recording every byte. NetFlow describes each conversation entering or leaving an interface, sFlow samples packets on high speed links, and IPFIX, based on NetFlow version 9, exports flexible records. Packet capture records whole frames using Wireshark, tcpdump, a SPAN port or a TAP. Baselines record normal behaviour so deviations stand out.

- NetFlow: flow records for bandwidth analysis

- sFlow: samples packets on high speed links
- IPFIX: exports flows, based on NetFlow version 9
- Capture: Wireshark, tcpdump, a SPAN port or a TAP
- Metrics: bandwidth, latency, error rate, device load
- Threshold alerting fires at a limit; anomaly detection uses models

Reference deep dive: syslog severity levels

The syslog protocol lets network devices send event messages to a central logging server. Each message carries a source, a timestamp and the event content, and each is graded by severity from 0 to 7. Lower numbers are more urgent, so severity 0 needs immediate attention while severity 7 exists only for debugging.

Syslog level	Meaning
0 Emergency	System is unusable
1 Alert	Immediate action required
2 Critical	Critical conditions
3 Error	Error conditions
4 Warning	Warning conditions
5 Notice	Normal but significant
6 Informational	Routine status messages
7 Debug	Debugging detail

Reference deep dive: disaster recovery metrics

Recovery objectives turn business tolerance into numbers. Recovery Point Objective sets the maximum acceptable data loss in time, so a four hour objective requires backups at least every four hours. Recovery Time Objective sets the maximum acceptable downtime before services return. Mean Time To Repair measures average repair time and Mean Time Between Failures measures reliability.

Metric	Measures	Question
RPO	Acceptable data loss, in time	How much can we lose?
RTO	Acceptable downtime	How quickly must we recover?
MTTR	Average time to repair	How fast do we repair?
MTBF	Average time between failures	How reliable is it?

Recovery point is not recovery time

RPO measures data loss in time, so a four hour RPO permits up to four hours of lost transactions. RTO measures downtime, so a two hour RTO requires service back within two hours. Swapping the two definitions is the most common examination error in this topic.

Reference deep dive: recovery sites, availability and testing

Recovery sites trade cost against recovery speed. A cold site offers space and power only, a warm site adds some equipment, and a hot site runs at once. High availability keeps services running meanwhile: active active clusters share the load, active passive clusters hold standby nodes, and stretched clusters span locations.

- Cold site: space and power, slowest, cheapest
- Warm site: partial equipment, moderate cost
- Hot site: ready to run, fastest, dearest
- Active active: all nodes serve traffic
- Active passive: standby nodes take over
- Heartbeat monitoring triggers failover
- Tabletop exercise: discussion based, low impact
- Full failover test: complete switch, most disruption

An untested plan is not a plan

Test disaster recovery at least annually, and more often for high risk or regulated organisations. A tabletop exercise only talks through the plan, a parallel test runs recovery systems beside production, and a full failover test switches everything and carries the greatest risk. Document each test and close the gaps it exposes.

Reference deep dive: DHCP services and IPv6 address assignment

DHCP automates address assignment on UDP ports 67 and 68, issuing a lease with the subnet mask, default gateway and DNS server. The exchange follows DORA: Discover, Offer, Request, Acknowledge. Relay agents carry messages between subnets. IPv6 adds Stateless Address Autoconfiguration, where a host builds its own address from a router advertisement.

- Discover: client broadcasts from 0.0.0.0 to 255.255.255.255
- Offer: server proposes an address and reserves it
- Request: client accepts one offer
- Acknowledge: server confirms the lease
- Reservation: fixed address bound to one MAC address
- SLAAC: host builds an address from a router advertisement
- EUI 64 builds the identifier from the MAC address

Reference deep dive: name resolution and time synchronisation

DNS resolves names to addresses through root servers, top level domains, authoritative servers and resolvers. Record types matter: A for IPv4, AAAA for IPv6, CNAME for aliases, MX for mail and PTR for reverse lookups. DNSSEC signs records against cache poisoning. NTP distributes time from stratum 0 reference clocks, so logs and authentication line up.

- Root servers: 13 sets, labelled A to M
- A maps a name to IPv4 and AAAA to IPv6
- CNAME aliases, MX routes mail, PTR reverses lookups
- Split horizon DNS answers internal and external clients differently
- DNSSEC uses digital signatures to prove integrity
- NTP uses UDP port 123 from a stratum 0 reference clock
- NTS authenticates time sources

Reference deep dive: remote access VPNs and device management

A site to site VPN joins whole networks through a tunnel over public infrastructure, while a remote access VPN serves individual users through client software. IPsec encrypts each packet and works in transport or tunnel mode, SSL/TLS VPNs run in a browser, and WireGuard is newer and fast.

- Site to site VPN: an appliance joins two networks
- Remote access VPN: client software for individual users
- IPsec transport mode encrypts the payload only
- IPsec tunnel mode encrypts the whole packet
- Full tunnelling: all traffic passes through the tunnel
- Split tunnelling: selected traffic only, less overhead
- Console access: 9600 baud, 8 data bits, no parity, 1 stop
- Use SSH, HTTPS or APIs to manage devices, never Telnet

Reference deep dive: common ports and protocols

Port numbers decide which traffic a firewall permits, so they must be recalled exactly. FTP uses 21 for control and 20 for data, and it and Telnet on 23 send credentials in plaintext, which SFTP and SSH on 22 replace. SMTP uses 25 and 587, DNS uses 53, DHCP uses 67 and 68, HTTP uses 80 and HTTPS uses 443.

Protocol	Port
FTP	20 and 21
SFTP	22
SSH	22
Telnet	23
RDP	3389

Protocol	Port
SMTP	25 and 587
DNS	53
DHCP	67 and 68
HTTP	80
HTTPS	443

Practical cautions

- Do not leave a plaintext service running where an encrypted replacement exists. Telnet on 23 and FTP on 21 are the usual offenders.
- Do not run SNMP with a community string on a reachable interface. Use version 3, and filter port 161 to management hosts.
- Do not trust a diagram or inventory you did not update at the last change. A wrong drawing is worse than no drawing.
- Do not let equipment run past End of Support without a compensating control and a replacement date.
- Do not retire a device with its configuration, certificates or credentials still on it.
- Do not make a change without a rollback plan or outside a maintenance window.
- Do not assume a device matches its baseline. Check for drift, and back the configuration up off the device.
- Do not capture packets without authority: they contain personal data.
- Do not buy failover before you have agreed the RPO and RTO with the business.
- Do not assume a hot site removes the need to test. An untested plan is still unproven.
- Do not leave DHCP unguarded: a client accepts the first offer it receives.
- Do not trust a forensic timeline from a system whose clock was never verified against an authenticated source.
- Do not leave an unexpected listener running. Explain every entry in `ss -tuln`, or treat it as a finding.

Self-check questions

1. Which port does Telnet use, and which port replaces it?
2. What is the difference between a physical and a logical network diagram?
3. What is the difference between End of Life and End of Support?
4. What is configuration drift, and how do you detect it?
5. What is the difference between flow records and full packet capture?
6. What does the Recovery Point Objective drive, and what does the Recovery Time Objective drive?
7. Why is a hot site not a substitute for disaster recovery testing?
8. What does the D in DORA stand for, and why does the exchange start from no address at all?

9. Why does the client accepting the first offer it receives create a security risk?
10. Which IPv6 addressing method leaves no central record of addresses, and which one does?
11. What does the time to live on a DNS record control?
12. Why is clock drift a forensic problem as well as an operational one?
13. What is the difference between IPsec transport mode and tunnel mode?
14. Which command shows all listening TCP and UDP services on Linux?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 3

- The port table is core knowledge: 20/21 FTP, 22 SSH and SFTP, 23 Telnet, 25/587 SMTP, 53 DNS, 67/68 DHCP, 80/443 web, 161/162 SNMP, 389/636 LDAP, 3389 RDP, 5060/5061 SIP.
- Encrypted services usually move to a different port. If a question gives you an unfamiliar port, ask which service moved there.
- Traffic types are examinable: a broadcast stays within one subnet, a multicast reaches only group members, and anycast reaches the nearest of many.
- End of Support is the security cliff. A question about unsupported equipment is a question about unpatched vulnerabilities.
- RPO is about data loss and backup frequency; RTO is about downtime and failover. Do not swap them.
- Match the control to the attack: documentation and baselines against drift, change control against self-inflicted outage, DNSSEC against DNS forgery, DHCP snooping against rogue servers.
- Flows tell you what happened, packets tell you what was said. A question about retention or storage cost is a flow question.
- A plan that has never been tested is unproven: tabletop, simulation, parallel, then full failover, in increasing order of proof.
- Every management path is attack surface: console, command line, browser and programmatic interface.
- Reducing the attack surface is a stated security principle, and closing unused services is the example.

Further reading

- Internet Assigned Numbers Authority service name and port number registry.
- RFC 2131 and RFC 8415: DHCP and DHCPv6.
- RFC 1034 and RFC 1035: DNS concepts and implementation. RFC 4033: DNSSEC introduction.
- RFC 5905: NTP version 4. RFC 8915: Network Time Security.
- RFC 4251: SSH protocol architecture.
- ITIL 4 change enablement guidance, for the change control vocabulary.
- UK National Cyber Security Centre: network security and logging guidance.



TRAINING @ FORREST.ONE

CHAPTER 04

Security Controls, Concepts & Zero Trust

The foundational principles of information security: the CIA triad and non-repudiation, the AAA framework, security control categories and functional types, the NIST Cybersecurity Framework, gap analysis, and the roles and responsibilities that make security governance work.

Student Notes, Security Controls, Concepts & Zero Trust

Your revision guide for Session 4 (Lesson 1 · Domain 1, 12% of the exam). Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. This session follows six chapters: why controls exist, classifying controls by category, what each control type does, proving identity, accounting and zero trust, and deception and change control.

Key terms

Term	Definition
Security control	A safeguard or countermeasure that manages risk to an asset
Defence in depth	Layered controls, so no single point of failure; layers fail independently
Technical control	Implemented in hardware or software, firewalls, encryption, ACLs, IDS
Physical control	Protects premises, hardware and people, locks, fences, cameras, mantraps
Managerial control	Policy and procedure, risk assessment, security policy, training
Operational control	Day-to-day work by people, guard patrols, incident response, backups
Preventive / detective / corrective	Operates before / during / after an incident
Compensating control	Substitutes when the proper control is not feasible
Deterrent control	Discourages an attempt psychologically, banners, visible cameras
Directive control	Guides your own people, acceptable use policy, procedures
Confidentiality	Information is disclosed only to those with the right permission
Integrity	Data is accurate, complete and unaltered without authorisation
Availability	Authorised users can reach systems and data when they need them
Non-repudiation	Persons cannot deny creating or modifying data, proof of origin and action
Authentication factors	Something you know, something you have, something you are
Accounting	Recording user activity and resource use, producing the audit trail
Audit trail	A chronological record that traces an action back to a specific user
Zero trust	Never trust, always verify, no user or device trusted by default

Term	Definition
Microsegmentation	Isolated network zones that block lateral movement
Honeypot / honeynet / honeytoken	Decoy system / decoy network / single piece of fake data
Change management	Request, impact assessment, approval, scheduled implementation and rollback
Gap analysis	Comparing current posture against a target framework to find gaps
Least privilege	Users receive only the access their role requires
Separation of duties	No one person controls a critical process alone

Core concepts

Chapter 1, Why controls exist

A control is any safeguard or countermeasure that manages risk. Threats are external (a ransomware crew) and internal (a trusted employee copying files). Controls prevent access, detect activity, or respond to incidents, and they span technology, policy, procedure and physical barriers. One control is never enough, which is the layered view: a firewall at the edge, an intrusion detection system behind it, and logs holding the evidence. Layers fail independently, and that independence is the point: backups survive ransomware even when prevention does not.

Chapter 2, Control categories (how a control is delivered)

Technical: built into hardware or software, enforced with no person in the loop (firewall, encryption, ACLs, IDS). Physical: protects premises, hardware and people (locks, fences, cameras, mantrap, biometric door access). Managerial, also called administrative: risk assessment, security policy and training, which set direction for technology to enforce. Operational: the day-to-day work carried out by people (guard patrols, incident response, backup routines, copies held on site and off site). Managerial writes the policy, operational carries it out.

Chapter 3, Control types (what a control does)

Preventive acts before, and is never perfect, so pair it with detection: firewall, encryption, training, segmentation. Detective finds what prevention missed: log monitoring, intrusion detection using signatures and anomalies, security audits. Corrective repairs damage: patch, restore from backup, and revise the procedures that failed (the step organisations skip). Compensating substitutes when the proper control is not feasible, for example a secure gateway for a legacy system that cannot encrypt, enhanced logging where there is no budget, cameras where production cannot stop; it is temporary by intent and must be documented and replaced. Deterrent discourages psychologically: warning banners, visible cameras, security personnel, and it fails against an attacker who does not care. Directive guides your own people: acceptable use policy and procedures, where non-compliance is a management issue.

Chapter 4, Proving identity and keeping records

The CIA triad: confidentiality (only authorised parties read the data), integrity (data is accurate, complete and unaltered), availability (systems and data are reachable when needed). Threats and answers: confidentiality falls to data breaches and eavesdropping, answered by encryption and strong authentication; integrity falls to tampering and man in the middle, answered by hashes, signatures and version control; availability falls to denial of service and hardware failure, answered by redundancy, failover and tested backups. Non-repudiation gives proof of origin: a digital signature is a hash encrypted with the sender's private key, verifiable with the matching public key, with audit logs and timestamps completing the proof. Authentication rests on three factors (know, have, are), and multifactor means two or more different factors: two passwords are not MFA. Protocols to know: Kerberos, LDAP, SAML and SSO.

Chapter 5, Accounting and zero trust

Accounting records who did what and when, producing the audit trail. It creates accountability, supports investigation after an incident, demonstrates compliance and reveals policy violations. Log management centralises logs for correlation, sets a retention period that satisfies regulation, and analyses them with automated alerting; a SIEM collects and correlates events, because a log nobody reads is evidence you will not have. Zero trust removes implicit trust: threats exist inside the network too, so no user and no device is trusted by default and every request is verified. Microsegmentation blocks lateral movement, continuous verification re-checks behaviour and context with adaptive authentication, and least privilege grants only what the role requires. Zero trust is a design principle, not a product.

Chapter 6, Deception and change control

A honeypot is a decoy system that mimics a real one, a honeynet is a network of decoys, and a honeytokens is fake data or a fake account. Contact with a decoy is suspicious by definition, because no legitimate user should ever reach one. Deception buys early warning, threat intelligence and wasted attacker effort. Change management has four steps: request, impact assessment (security, functionality, performance), approval by the system owner and security officer, and scheduled implementation with a rollback plan, all documented. Skipping it produces back doors nobody recorded and configuration drift away from the approved baseline. Four technical implications: allow list, firewall rules, security baseline and system dependencies. Test in a non-production environment and evaluate security impact before approving.

Memory aids

- Controls on two axes: category says how (technical, physical, managerial, operational); type says what (preventive, detective, corrective, compensating, deterrent, directive).
- When does it act? Preventive before, detective during, corrective after.
- CIA: confidentiality is the read side, integrity the change side, availability the access side.
- AAA: the user is identified, then authenticated, then authorised, then accounted.
- Non-repudiation means deniable, no: signatures and logs make denial fail.
- Zero trust: never trust, always verify. A design principle, not a product.
- Deception sizes: pot is one system, net is many, token is one piece of fake data.
- Change control in four words: request, assess, approve, schedule. Then document.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

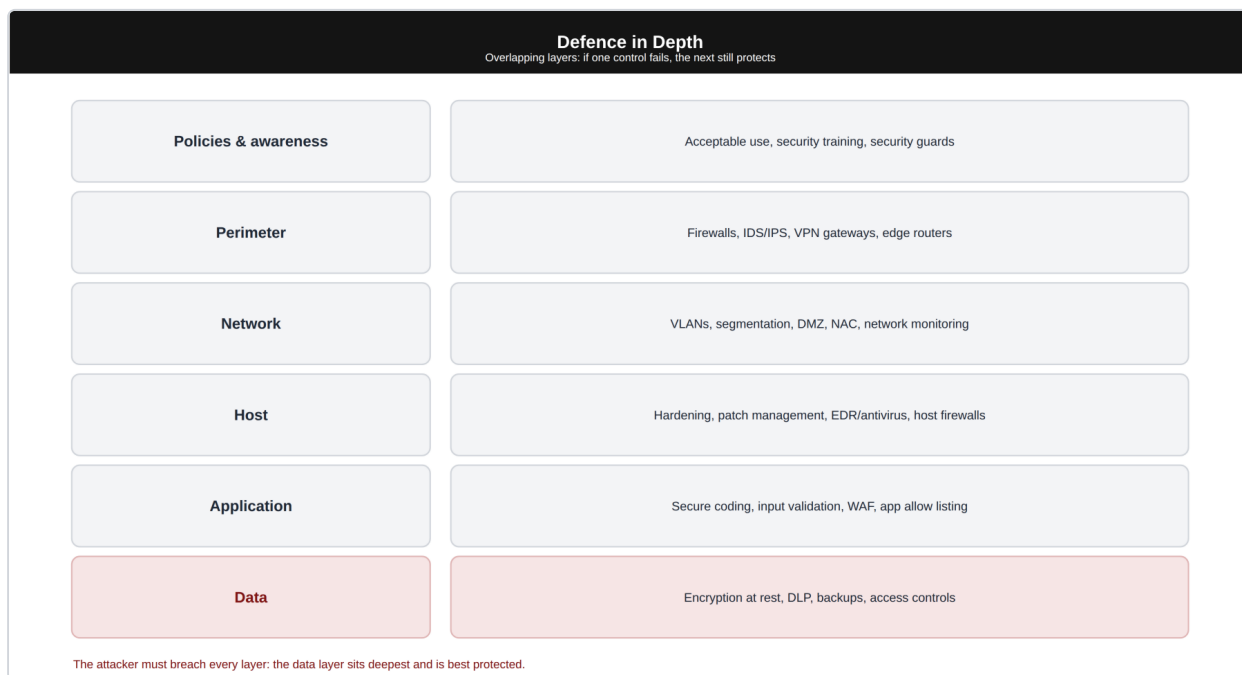
Reference deep dive: security control types

Security controls are safeguards that manage and mitigate risk. They group by function (technical, physical, managerial, operational) and by action (preventive, detective, corrective, compensating, deterrent, directive). No single control is enough; controls must work together.

Control	Definition	Example
Technical	Hardware and software that protect systems and data	Firewall, encryption, ACLs, IDS
Physical	Protect the physical environment and assets	Locks, fences, security cameras, mantraps, biometric doors
Managerial	Policies and procedures that govern security practice	Risk assessments, security training, incident response plans
Operational	Day-to-day procedures that keep security measures working	Guard patrols, incident response, backup routines
Preventive	Stop security incidents before they occur	Access controls, network segmentation, firewalls
Detective	Identify and respond to incidents as they happen	IDS, SIEM, log monitoring, security audits
Corrective	Repair systems and recover after an incident	Patching, restoring from backups, revising procedures
Compensating	Alternative safeguards when the primary control is not feasible	Network-level encryption for legacy systems, extra monitoring instead of MFA
Deterrent	Discourage violations by raising perceived risk	Warning banners, visible cameras, security personnel
Directive	Guide user and administrator behaviour toward compliance	Acceptable use policies, security awareness training

Reference deep dive: defence in depth

Figure 4.1: Defence in depth layers. The data layer sits deepest and is best protected.

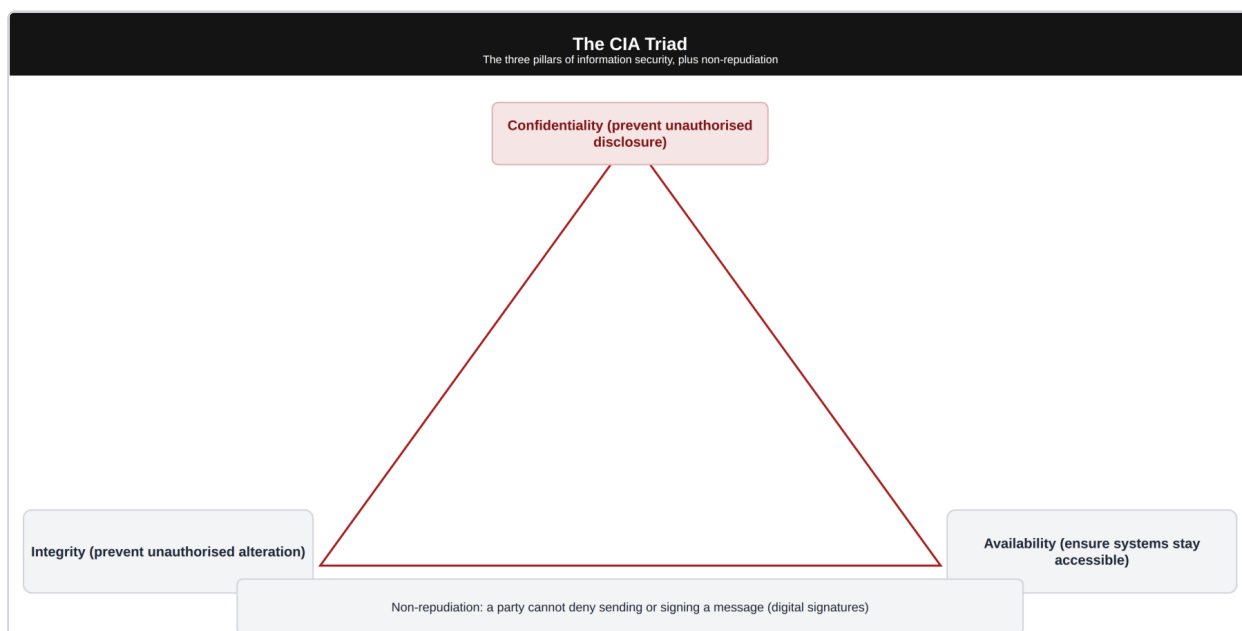


A layered approach, also called defence in depth, deploys multiple overlapping controls so that if one fails others still protect the system.

- If an attacker bypasses the firewall, the IDS and IPS still detect and mitigate the threat
- Aligns controls with the risk management strategy so they complement each other
- Technical, physical and administrative controls combine into one resilient posture
- Reduces both the likelihood and the impact of a security incident

Reference deep dive: CIA triad and non-repudiation

Figure 4.2: The CIA triad and non-repudiation.



The CIA triad is the foundational model of information security. Each pillar faces specific threats and needs matching controls.

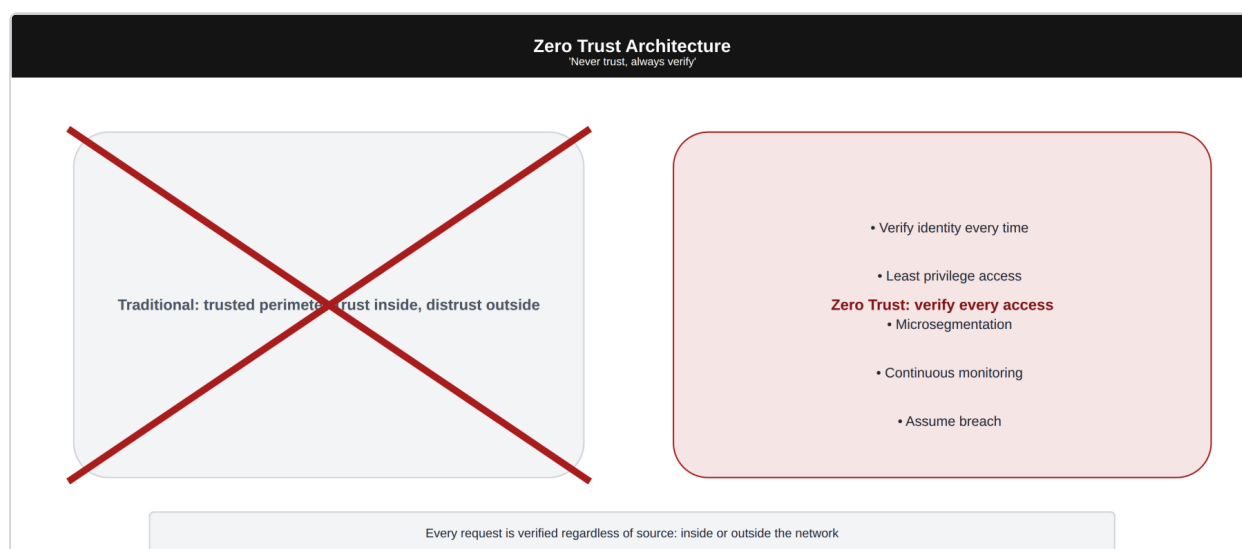
Pillar	Meaning	Key threats	Example controls
Confidentiality	Only authorised users can see the data	Unauthorised access, breaches, eavesdropping	Encryption, access controls, least privilege, VPNs
Integrity	Data is accurate and unaltered	Data tampering, man-in-the-middle, software bugs	Hashing, digital signatures, version control
Availability	Resources are accessible when needed	DoS, hardware failure, natural disaster	Redundancy, failover, backups, disaster recovery plans

Non-repudiation guarantees that a party cannot deny sending a message or signing a document. It is achieved through digital signatures, audit logs and timestamps, and is vital in contracts, financial transactions and compliance (for example HIPAA).

- Digital signature: hash the message, encrypt the hash with the sender's private key
- Recipient decrypts the hash with the public key and compares it to a fresh hash
- Audit logs record user, action, timestamp and outcome to build accountability
- Timestamps confirm the sequence and timing of actions

Reference deep dive: Zero Trust

Figure 4.3: Zero Trust replaces the trusted perimeter with 'never trust, always verify'.



Zero Trust Architecture abandons the trusted perimeter model and assumes threats exist both inside and outside the network. Its core principle is 'never trust, always verify'.

- No user or device is trusted by default, regardless of location
- Microsegmentation divides the network into isolated zones to limit lateral movement
- Continuous verification monitors and revalidates identity and trust in real time
- Least privilege access minimises the damage a compromised account can cause

- Benefits: stronger security, better visibility, easier compliance, flexible scaling

Reference deep dive: deception technologies

Deception technologies lure attackers into decoy systems so defenders can study their tactics and alert early, wasting attacker resources.

- Honeypot: a decoy system mimicking real services to attract and observe attackers
- Honeynet: a network of honeypots simulating a full environment to study lateral movement
- Honeytoken: fake data, such as a decoy account or file, that triggers an alert when accessed
- Value: early warning, threat intelligence gathering, and diverting attacker effort

Practical cautions

- Do not confuse integrity (unchanged) with correctness (true).
- Do not confuse preventive (blocks) with deterrent (discourages).
- Do not confuse managerial (writes policy) with operational (carries it out).
- Do not forget corrective has three parts: patch, restore, and revise the procedure.
- Do not treat a vulnerability scan as a gap analysis: they measure different things.
- Do not expect zero trust to be a product: it is a design principle.
- Do not approve a change with no rollback plan, and do not test in production.
- Do not confuse the data owner (accountable) with the custodian (implementer).

Self-check questions

1. Why does an organisation need more than one control around the same asset?
2. Give an example control for each category: technical, physical, managerial, operational.
3. Name the six functional control types and say when each acts.
4. What three things happen in a corrective response to ransomware?
5. When is a compensating control the right answer, and what must accompany it?
6. Define the three pillars of the CIA triad and give one control for each.
7. What does non-repudiation provide, and which mechanisms provide it?
8. Name the three authentication factors and the four protocols in the chapter.
9. What is an audit trail, and name the four things it gives you?
10. Describe the three duties of log management and what a SIEM does.
11. What is microsegmentation for, and what does continuous verification add?
12. Explain the difference between a honeypot, a honeynet and a honeytoken.
13. What are the four steps of a controlled change, and what can a change break?
14. What are the five NIST CSF functions?
15. Explain the difference between a vulnerability scan and a gap analysis.
16. Who is accountable for a data set, and who implements the controls that protect it?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 4

- Know the two-axis control model cold: category and functional type, with one concrete example for each.
- Non-repudiation is a favourite exam term: link it to signatures and logs, not logging alone.
- Learn the classic paired distinctions: preventive versus deterrent, integrity versus correctness, owner versus custodian, scan versus gap analysis, managerial versus operational.
- Zero trust is described as a design principle: reject any option that sells it as a product.
- Remember the change-management answer: assess and test before approval, and always have a rollback plan.
- The exam is vendor-neutral: no product-specific questions.
- Learn the exam facts: 90 questions, 90 minutes, pass mark 750.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 1.
- NIST Cybersecurity Framework (CSF 2.0) documentation.
- NIST SP 800-53, security and privacy controls catalogue.
- NIST SP 800-207, Zero Trust Architecture.
- NIST SP 800-61, incident handling guide (for change and incident procedures).



TRAINING @ FORREST.ONE

CHAPTER 05

Threat Actors, Attack Surfaces & Vectors

Comparing threat actor types and their motivations; explaining threat vectors and attack surfaces; and understanding the vulnerability-threat-risk relationship that underpins every defensive decision.

Student Notes, Threat Actors, Attack Surfaces & Vectors

Your revision guide for Session 5. This is the whole of Domain 2 (Threats, Vulnerabilities and Mitigations, 22% of the exam) in six chapters: the actors, the attack surface, the vulnerabilities, the malware, the network attacks, and the mitigations. Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready.

Key terms

Term	Definition
Vulnerability	A weakness in a system, process or design
Threat	A person, tool or method that could exploit a vulnerability
Risk	The likelihood and impact of a threat exploiting a vulnerability
Threat actor	A person or group that poses a threat
APT	Advanced Persistent Threat: a long-term, stealthy, strategic campaign, state-backed or highly resourced
False flag	Techniques that mislead attribution towards another actor
Shadow IT	Unauthorised apps, devices or cloud services used outside approved controls
Attack surface	Every point where an attacker can enter or extract data
Threat vector	A path or method used to gain access or deliver a payload
Spear phishing	Targeted, personalised phishing aimed at a named individual
Whaling	Spear phishing aimed at executives and key decision makers
Pretexting	A fabricated scenario used to extract information
Baiting	A tempting lure, such as a dropped USB drive
Tailgating	Following an authorised person through a secure door
Watering hole	Compromising a site the target trusts, then delivering malware from it
Zero day	A vulnerability unknown to the vendor with no available patch
Misconfiguration	Insecure settings such as open ports, weak rules or exposed storage
Botnet	Many compromised machines, called zombies, controlled by one operator

Term	Definition
Command and control	The servers that issue orders to bots and collect their results
Double extortion	Stealing data as well as encrypting it, then threatening to publish
Credential stuffing	Replaying username and password pairs stolen in an earlier breach
Password spraying	A few common passwords tried across many accounts, under the lockout threshold
Injection	Input that changes what a query or command does
Denial of service	Making a service unavailable to legitimate users
Amplification	A small spoofed request that produces a large reply aimed at the victim
On-path attack	Relaying traffic between two parties who believe they are talking directly
Segmentation	Dividing a network into isolated zones to contain an attack
Least privilege	The minimum access needed to do the job, and nothing more
Hardening	Removing unnecessary services, software, ports and features

Core concepts

Chapter 1 · Know the adversary

Risk = threat × vulnerability. Actors are compared by resources, sophistication, motivation and intent. Motivations: financial, political or ideological, strategic, personal and ethical. Types: nation-state actors and APTs (espionage, disruption, persistence, false flags), organised crime (profit, ransomware, BEC, crime as a service), hacktivists (ideology, defacement, denial of service), unskilled attackers (ready-made tools), malicious and negligent insiders, shadow IT, and competitors (intellectual property, disinformation).

Chapter 2 · The attack surface

Every point where an unauthorised user could enter or extract data: hardware, software, networks, processes and people. Cloud, mobile, Internet of Things and remote work all expand it. Common vectors: phishing email, malware, software vulnerability, social engineering, wireless and cloud. Human vectors: the phishing family (phishing, spear phishing, whaling, smishing, vishing), then pretexting, baiting, tailgating, shoulder surfing and dumpster diving. Network and file vectors: unsecured wireless, rogue access points, on-path, malicious documents, infected executables and removable media. Direct access, remote access (VPN, RDP, SSH), open service ports, default credentials and the watering hole complete the picture.

Chapter 3 · Vulnerabilities

Supply chain (compromised updates, vendor credentials) and software (unpatched systems, misconfiguration, zero-day). Application and web: memory injection, buffer overflow, race conditions, SQL injection, cross-site scripting, cross-site request forgery and session hijacking. Operating system and hardware: privilege escalation, kernel exploits, end-of-life and legacy systems, BIOS and UEFI attacks, side channels, Spectre

and Meltdown. Mobile, cloud and virtualisation: jailbreaking, sideloading, lost devices, misconfigured storage, insecure interfaces, shared responsibility confusion, virtual machine escape and hypervisor flaws.

Chapter 4 · Malware and credential attacks

Lifecycle: delivery, exploitation, persistence. Types: virus (needs a user), worm (self-propagating), trojan (disguised). Evasion: polymorphism, encryption, rootkits, code obfuscation and fileless malware.

Ransomware, double extortion, spyware, keyloggers, rootkits and bootkits. Botnets: zombies, command and control, domain generation algorithms, fast flux and peer to peer. Credential attacks: brute force, dictionary, spraying, stuffing, offline hash attacks and rainbow tables.

Chapter 5 · Attacks on the network

Injection: SQL, command, LDAP, directory traversal and interface abuse, answered by validation, escaping and parameterised queries. Denial of service: volumetric, protocol, application layer, distributed and amplification. Layer 2: VLAN hopping, address table flooding, ARP poisoning and Spanning Tree attacks, answered by port security, DHCP snooping, dynamic ARP inspection and BPDU guard. DNS: poisoning, spoofing and hijacking, answered by DNSSEC, encrypted DNS and monitoring. Rogue devices and on-path attacks, answered by encryption and certificate validation. Physical and cryptographic attacks: device theft, malicious USB devices, badge cloning, downgrade, birthday and collision, and side channels.

Chapter 6 · Mitigation

Segmentation: VLANs, subnets and microsegmentation, so an attacker cannot move freely between zones. Access control: least privilege, need to know, separation of duties and regular entitlement reviews. Hardening and patching: remove what is unnecessary, change default credentials, close unused ports, apply firmware updates, build from CIS or NIST baselines, then inventory, assess, test, deploy and verify. Isolation: sandboxing, containerisation and air gaps. The attack chain: recon, vector, exploit, act.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: threat actors

Analyse every threat actor by four attributes: resources, sophistication, motivation and intent. Use these to predict impact and prioritise defences.

- Nation-state or APT: government backed, huge resources, high sophistication, strategic espionage goals.
- APT lifecycle: recon, initial intrusion, foothold, privilege escalation, internal recon, exfiltration, persistence.
- Organised crime or cybercriminals: profit driven, run like businesses with hierarchy and specialist roles.
- Typical criminal methods: ransomware, banking trojans, card theft, business email compromise (BEC).
- Hacktivists: politically or ideologically motivated, use defacement, data leaks and DDoS.

- Unskilled attackers or script kiddies: use ready-made tools against known vulnerabilities and weak passwords.
- Insiders: employees, contractors or partners acting maliciously or through negligence; hardest to detect.
- Shadow IT: unapproved personal devices, apps or cloud services that bypass security policy.

Reference deep dive: attack surfaces and threat vectors

The attack surface is every point an attacker can use to enter or extract data; a threat vector is the method used to exploit it. New technology grows both.

- Cloud, mobile and IoT devices each add entry points, often with weaker built-in security.
- Minimise the surface by patching, network segmentation, restricting access and regular audits.
- Understand which vectors are most likely and impactful, then apply layered defences.
- Common vectors: phishing, malware, exploited unpatched software and social engineering.
- Network and file vectors: rogue access points, on-path interception, malicious documents and USB media.

Reference deep dive: message-based and social engineering

Social engineering manipulates trust and helpfulness to bypass technical controls. Attacks exploit urgency, authority and the desire to comply.

- Phishing: mass fraudulent emails that trick users into revealing data or installing malware.
- Spear phishing: targeted at a specific person, personalised with gathered intelligence.
- Whaling: spear phishing aimed at executives and key decision makers.
- Smishing and vishing: phishing by text message or over the phone, often impersonating banks.
- Other techniques: pretexting (fake scenario), baiting (lure such as free USB), tailgating (following into secure areas).
- Defend with security awareness training, phishing simulations and clear reporting channels.

Reference deep dive: malware categories

Malware follows a lifecycle of delivery, exploitation and persistence. Understand each category and how it evades detection.

Malware	Key trait	Typical example or action
Virus	Attaches to files, needs user action to spread	Infects a Word document when opened
Worm	Self propagates without user action	ILOVEYOU spread by email
Trojan	Disguised as legitimate software	Free game that opens remote access
Ransomware	Encrypts data and demands payment	Double extortion steals then threatens release
Spyware or keylogger	Secretly gathers data and keystrokes	Records passwords and card numbers
Rootkit or bootkit	Hides malware at low system level	Bootkit reinfects on every reboot

Malware	Key trait	Typical example or action
Botnet	Network of zombie devices with command-and-control	Spam, DDoS and credential stuffing

- Evasion techniques: polymorphism, encryption, code obfuscation, fileless memory-resident payloads.
- Botnet C&C resilience: domain generation algorithms, fast flux networks and peer-to-peer control.
- Counter with defence in depth: firewalls, patching, endpoint protection, encryption and user training.

Reference deep dive: password and credential attacks

Credential attacks exploit weak or reused passwords. Different methods target either many passwords on one account or one password across many accounts.

- Brute force: try every possible combination, costly but thorough on short passwords.
- Dictionary: try a precompiled list of common words and leaked passwords.
- Password spraying: try a few common passwords across many accounts to avoid lockouts.
- Credential stuffing: reuse breached username and password pairs on other sites.
- Offline hashes: crack stolen password hashes with brute force, dictionary or rainbow tables.
- Rainbow tables: precomputed hash lookups, less effective against salted modern hashes.
- Defend with strong password policies and multifactor authentication.

Reference deep dive: application and injection attacks

Injection and application attacks feed malicious input into software to alter its behaviour, gain access or manipulate data.

- SQL injection: inject queries into input fields to read, modify or delete database data.
- XSS: inject scripts into pages to steal data, hijack sessions or deface sites.
- CSRF: trick an authenticated user into performing unwanted actions using their session.
- Command, LDAP and directory traversal injections reach the OS, directory service or filesystem.
- Session hijacking: steal session cookies to impersonate a user; secure cookies and HTTPS help.
- Replay: capture and resend valid packets, such as a login session, to gain access.
- Privilege escalation: vertical gains higher rights, horizontal accesses another user's data.
- API abuse: weak authentication or excessive data exposure in APIs.
- OWASP Top Ten guides prioritisation of the most critical web application risks.
- Secure coding: input validation, prepared statements, output escaping, anti-CSRF tokens.

Reference deep dive: network, physical and cryptographic attacks

Network attacks target infrastructure and protocols, while physical and cryptographic attacks exploit direct access or algorithm weaknesses.

- DNS attacks: cache poisoning redirects users, DNS amplification amplifies DDoS traffic.
- ARP poisoning: associate the attacker's MAC with a legitimate IP to intercept traffic.

- VLAN hopping: switch spoofing or double tagging to cross segmentation boundaries.
- On-path: intercept and alter communication between two parties without detection.
- DoS and DDoS: flood a service to make it unavailable, using botnets for scale.
- Physical: device theft, malicious USB devices and badge cloning require direct access.
- Cryptographic: downgrade forces weak protocols, birthday finds hash collisions, side-channel leaks timing or power data.
- Integrate physical and logical security so a breach of one does not expose the other.

Reference deep dive: segmentation, access control, hardening and isolation

Contain and prevent attacks by segmenting networks, restricting access and reducing the attack surface through hardening and isolation.

- Segmentation: VLANs, subnets and microsegmentation isolate zones and limit lateral movement.
- Access control: least privilege, need to know and separation of duties reduce insider and compromise risk.
- Hardening: remove unnecessary services, apply secure settings and change default passwords.
- Patch management: inventory assets, assess and prioritise, test, deploy and verify updates.
- Isolation: sandboxing, containerisation and air gapped systems contain any breach.

Reference deep dive: quick exam recall

Term	One line meaning
APT	Prolonged stealthy campaign, usually nation state, that extracts data over time
BEC	Fake executive email that tricks staff into transferring funds
CaaS	Crime as a service, renting botnets, ransomware and DDoS tools
OWASP Top Ten	Framework of the most critical web application risks
Zero day	Vulnerability unknown to the vendor, so unpatched at time of exploit
Defence in depth	Layered controls so no single failure exposes the system
MFA	Requires two or more factors, blocking most credential attacks

Practical cautions

- Do not call all hackers criminals; ethical testing and responsible disclosure are legitimate work.
- Do not forget the negligent insider; the employee who falls for phishing is more common than the malicious one.
- Do not use 'APT' for every advanced attack; persistence and strategy are the point.
- Do not treat a virus and a worm as the same thing; only a worm spreads without the user.
- Do not assume backups defeat ransomware; double extortion steals the data first.
- Do not ignore the human vectors; most intrusions start with a person, not a port.
- Do not assume patching fixes everything; end-of-life and zero-day flaws need other controls.

- Do not treat vulnerability and risk as the same thing; risk needs a threat behind the weakness.
- Do not leave shadow IT out of the actor list; unauthorised services place data outside your controls.
- Do not confuse a spoofed DNS answer with a poisoned cache; spoofing leaves the resolver untouched.

Self-check questions

1. Define vulnerability, threat and risk in one sentence each.
2. Name the four attributes used to compare threat actors, and say what each one predicts.
3. List six threat actor types and one motivation for each.
4. What makes an APT different from a single advanced attack, and what are its stages?
5. Name five ways the attack surface grows, and explain why people are part of it.
6. Distinguish phishing, spear phishing, whaling, smishing and vishing.
7. Name four social engineering techniques and the defence that covers all of them.
8. Give one application vulnerability, one operating system vulnerability and one cloud vulnerability.
9. What are the three stages of the malware lifecycle, and which one does a rootkit serve?
10. Explain the difference between password spraying and credential stuffing.
11. Name the Layer 2 attacks and the four switch features that answer them.
12. Contrast DNS poisoning, DNS spoofing and DNS hijacking.
13. What are the four steps of the attack chain?
14. Name the three isolation strategies and say what each one protects.
15. Contrast an unpatched-software vector with a supply chain vector, using one real example for each.

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 5

- Scenario questions reward classification; label the actor, the vector, the weakness or the control, and give two labels when both apply.
- Learn the attack-to-control pairs from chapters four and five; objective 2.5 asks for the purpose of the mitigation.
- APT means persistence and strategy, not just sophistication.
- Insider threat includes accidents, not just malice.
- Supply chain is an increasingly tested vector; know the NotPetya update example.
- Know the difference between a vulnerability and a risk; the exam tests the distinction directly.
- Name the phishing family member precisely; the target defines the type.
- Remember the Layer 2 defences by name: port security, DHCP snooping, dynamic ARP inspection and BPDU guard.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, objectives 2.1 to 2.5.
- NCSC threat reports, real-world actor profiles and motivations.
- MITRE ATT&CK, techniques mapped to actor groups.
- Case write-ups of Stuxnet, WannaCry and NotPetya for concrete examples of an APT campaign and a supply chain compromise.



TRAINING @ FORREST.ONE

CHAPTER 06

Cryptography, PKI & Identity

Symmetric and asymmetric encryption, hashing and digital signatures; the public key infrastructure of certificates, authorities and revocation; and the practical solutions for data at rest, in transit and in use.

Student Notes, Cryptography, PKI & Identity

Your revision guide for Session 6. Read it alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. The session hangs on three maps: the three-job map (encrypt, hash, sign), the data-state map (at rest, in transit, in use), and the identity map (authentication proves who you are, authorisation decides what you may do).

Key terms

Term	Definition
CIA triad	Confidentiality, integrity and availability: the three jobs every control serves
Vulnerability / threat / exploit / risk	A weakness; anything that could exploit it; the method used; likelihood combined with impact
Symmetric encryption	One shared secret key encrypts and decrypts: fast, for bulk data
AES	Advanced Encryption Standard: symmetric, with key sizes of 128, 192 or 256 bits
Asymmetric encryption	Public and private key pair: public encrypts, private decrypts
RSA / ECC	Asymmetric algorithms: RSA rests on factoring difficulty; ECC uses smaller keys
Keyspace	The range of possible key values; longer keys mean larger keyspaces
Hashing	One-way, fixed-length digest with the avalanche effect: integrity, not secrecy
SHA-256 / SHA-1 / MD5	The modern standard; broken by collision attacks; broken on demand
Digital signature	Hash encrypted with the private key: integrity, authentication, non-repudiation
PKI	The infrastructure that proves the identity of a public key holder
Certificate authority (CA)	Verifies identity and issues certificates, signing each with its private key
Registration authority (RA)	Performs identity checks on behalf of the CA before issuance
X.509	The digital certificate standard
CN / SAN	Common Name (legacy FQDN) and Subject Alternative Name (modern, wildcards)
CSR	Certificate signing request: carries the public key and identity, never the private key
CRL / OCSP	Revocation list published periodically, and a real-time query about one certificate

Term	Definition
TPM / HSM	Motherboard cryptoprocessor, and a dedicated hardware security module
Key escrow	Backup of keys with a trusted third party, with M-of-N control splitting recovery
Perfect forward secrecy	Ephemeral session keys, so a later compromise cannot decrypt past traffic
Salting / key stretching	A random per-password value, and extra hashing rounds against brute force
Tokenisation / data masking	Substituting a value with a token in a vault, and fictitious data for testing
Steganography	Concealing the existence of a message, often in an image's least significant bits
Blockchain	A distributed ledger of blocks chained by hashes: tamper-evident, not tamper-proof
Documentation / version control	Policies, procedures and diagrams kept current; repository, commit, branch
Authentication / authorisation	Proving who you are, and deciding what you may do
Role-based access control	Permissions assigned to roles, and people assigned to roles
Provisioning / deprovisioning	Creating and removing identity and access across the lifecycle
The three factors	Something you know, something you have, something you are
TOTP / passwordless	A time-based one-time password, and authentication without a password at all
SSO / SAML / federation	One login for many applications; assertion exchange; trust between organisations
RADIUS / TACACS+	Network access authentication over UDP, and device administration over TCP
LDAP / LDAPS	Directory protocol on port 389, secured on 636 or upgraded with StartTLS
ACL	A list of permission entries attached to an object, read in order, first match wins
DAC / MAC / ABAC	Owner-set permissions; central policy; attribute-based with place and time

Core concepts

1 • The three jobs and the vocabulary

Confidentiality, integrity and availability are the three jobs, and every control in this session serves one of them. Encryption and access controls serve confidentiality, hashes and signatures serve integrity, and redundancy serves availability. Use the vocabulary precisely: a vulnerability is a weakness, a threat is anything that could exploit it, an exploit is the method or tool, and risk combines likelihood with impact, which is how you prioritise.

2 • Cryptographic algorithms

Symmetric: one key, fast, bulk data, distribution problem. AES is the standard, with 128, 192 or 256-bit keys, and each added bit doubles the attacker's work. Asymmetric: key pairs, which solve distribution, and are slower, so they protect keys and small payloads. RSA rests on factoring difficulty; elliptic curve cryptography reaches similar strength with smaller keys, which suits mobile and constrained devices. TLS shows both together: an asymmetric handshake exchanges a symmetric session key, then symmetric encryption carries the session.

3 • Integrity and trust

Hashing is one-way, deterministic and fixed-length, it shows the avalanche effect, and it should be collision resistant: SHA-256 or better, with SHA-1 and MD5 treated as broken. A digital signature hashes the message and encrypts that hash with the sender's private key, giving integrity, authentication and non-repudiation, but not confidentiality. Certificates bind a public key to a verified identity, issued by a CA after checks by an RA, and read in the X.509 format. Trust flows from a self-signed root through intermediates to the leaf certificate. The CSR carries the public key and never the private key; CN is legacy and SAN is modern; revocation is published through a CRL or queried live over OCSP, and it sits in the lifecycle of issuance, renewal, revocation and expiration. Key management covers the lifecycle, TPM and HSM cryptoprocessors, and escrow with M-of-N control.

4 • Applied solutions and the paper trail

Data at rest: full disk, volume or file encryption, and database encryption at table, column or cell level. Data in transit: TLS and VPN tunnels, with perfect forward secrecy so ephemeral session keys protect traffic recorded earlier. Data in use: processed in memory, the hardest state. Passwords: salting plus key stretching. Then the applications: tokenisation and data masking, code obfuscation, steganography (hiding existence, not meaning), and blockchain, where each block carries the previous block's hash so tampering is detectable. Documentation and version control close the loop, because knowing what changed, and when, is half of security.

5 • Identity and access

Authentication proves who you are; authorisation decides what you may do; a user can be authenticated and still be denied. Least privilege grants the minimum needed. Role-based access control assigns permissions to roles, and the identity lifecycle runs from provisioning through modification to deprovisioning, which is the step organisations most often forget. The three factors are something you know, something you have and something you are, and multi-factor means two or more different families. One-time passwords are time-based with a short window, phishing can relay a code, and passwordless designs use a biometric, a device key or a link. Single sign-on reduces password fatigue and centralises policy and revocation; SAML exchanges signed assertions between an identity provider and a service provider. Federation extends that trust between organisations, which widens the blast radius of a single compromise.

6 • Controlling access

RADIUS centralises authentication, authorisation and accounting over UDP, and you meet it in VPN access and wireless 802.1X. TACACS+ uses TCP, separates all three functions, and gives command-level control, which suits managing network devices. Directories such as Active Directory are built on LDAP, a hierarchy of

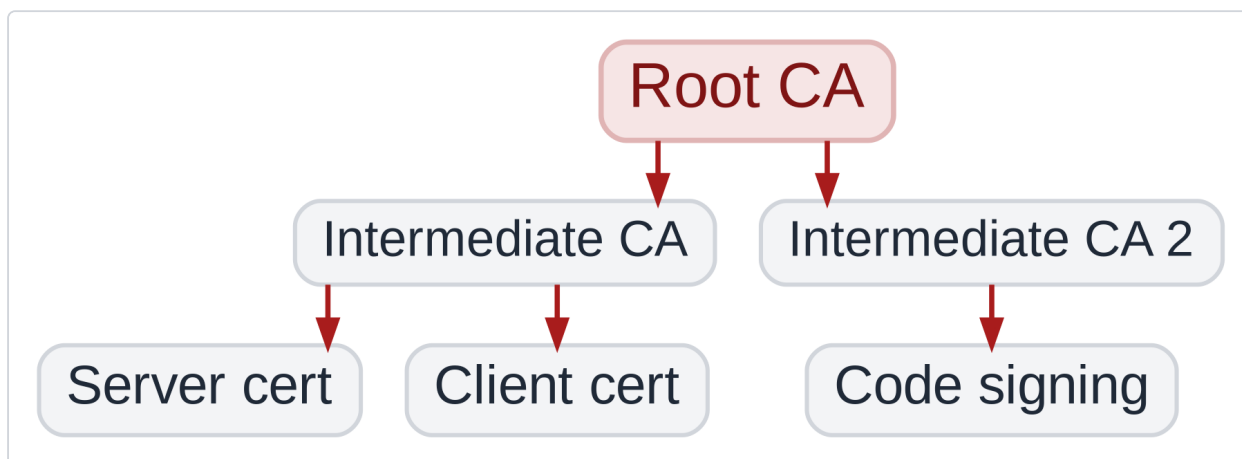
organisational units, groups and user objects carrying attributes, and they are optimised for reading and searching. Authentication follows bind, search, compare and result, on port 389 in the clear, on 636 with LDAPS, or upgraded with StartTLS. Access control lists are read in order, first match wins, and no match means the default, normally deny. Discretionary access lets the owner decide, mandatory access follows central policy, and attribute-based access evaluates user, resource and environmental attributes together, including geofencing and time-based restrictions.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: PKI fundamentals

Figure 6.1: The PKI trust chain, anchored at a root CA.



Public Key Infrastructure (PKI) manages digital certificates and public key encryption to enable secure, authenticated communication.

Component	Role
Certificate Authority (CA)	Trusted entity that verifies identity, issues and manages certificates
Registration Authority (RA)	Intermediary that verifies the requester's identity before the CA issues a certificate
Certificate Revocation List (CRL)	List of certificates revoked early, for example after key compromise

Reference deep dive: certificate lifecycle and trust

- Lifecycle: issuance, renewal, revocation, then expiration
- Renewal re-verifies identity and issues a fresh certificate before expiry
- Revocation removes a compromised or unneeded certificate via the CRL
- Trust hierarchy: a self-signed root CA certifies subordinate CAs down to end-entity certificates

- Trusting the root CA means trusting every certificate in its chain

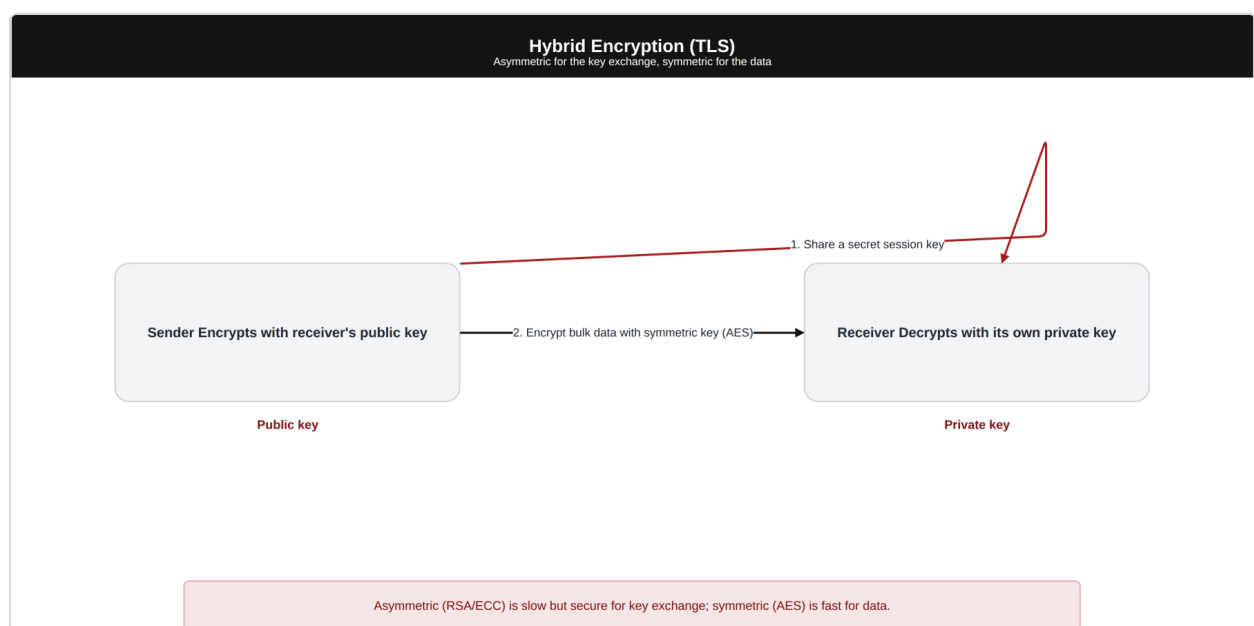
Reference deep dive: symmetric and asymmetric encryption

Symmetric encryption uses one shared key for both encryption and decryption; asymmetric encryption uses a public-private key pair.

Property	Symmetric	Asymmetric
Key model	Single shared secret key	Public key encrypts, private key decrypts
Common algorithm	AES (128, 192 or 256 bit)	RSA, ECC
Speed	Fast, good for large data	Slow, compute intensive
Use cases	Data at rest, file encryption (BitLocker, FileVault)	Key exchange, digital signatures, TLS
Challenge	Secure key distribution and management	Performance on large volumes

Reference deep dive: TLS combines both

Figure 6.2: Hybrid encryption in TLS. Asymmetric exchange, then symmetric bulk encryption.



TLS mixes asymmetric and symmetric encryption to get both security and speed.

- Handshake: client and server use asymmetric encryption to exchange keys securely
- The client encrypts a symmetric session key with the server's public key
- Both sides then switch to fast symmetric encryption for the session data

Reference deep dive: hashing and digital signatures

Hashing converts data of any size into a fixed-length value that verifies integrity; a single changed bit changes the whole hash.

- Good hash properties: deterministic, fast, pre-image resistant, collision resistant
- SHA-256 (SHA-2 family) is secure and widely used
- MD5 and SHA-1 are broken and unsuitable for security-sensitive use
- Digital signature: hash the message, encrypt the hash with the private key
- Verify by decrypting the hash with the public key and comparing to a fresh hash
- Gives authenticity, integrity and non-repudiation; used for software and document signing

Reference deep dive: obfuscation and steganography

Obfuscation makes data or code hard to understand; steganography hides the existence of data itself, unlike encryption which just scrambles it.

- Tokenization replaces sensitive data with a token stored in a secure vault (used for card payments)
- Data masking creates realistic-looking fake data for testing environments
- Code obfuscation renames variables and complicates logic to block reverse engineering
- Steganography hides data in images (least significant bits), audio or video
- Legitimate use protects intellectual property and enables covert but authorised communication
- Misuse: malware concealment, covert channels and data exfiltration

Reference deep dive: blockchain basics

Blockchain is a decentralised distributed ledger in which each node holds a copy of the chain, using cryptographic hashing to guarantee integrity.

- Each block holds transactions, a timestamp and the hash of the previous block
- Altering one block changes every later block, making tampering impractical
- Security uses: supply chain provenance, identity management, immutable record keeping
- Limitations: scalability, energy use, complexity, evolving regulation

Practical cautions

- Do not use asymmetric encryption for bulk data: symmetric is the bulk tool.
- Do not rely on encryption for integrity: hashing does that job.
- Do not treat a certificate as a safety rating: it proves key-to-identity binding only.
- Do not use MD5 or SHA-1 for anything modern: use SHA-256 or better.
- Do not store passwords without salt and stretching.
- Do not confuse CRL with OCSP: one is a published list, the other a real-time query.
- Do not confuse encryption with obfuscation or steganography: they protect different things.
- Do not count a password plus a personal identification number as multi-factor.

- Do not leave accounts active after someone leaves: deprovision on the day they go.
- Do not send directory credentials over port 389 unencrypted: use LDAPS or StartTLS.
- Do not assume one login is free of risk: it is one point of failure, so protect the session.
- Do not confuse RADIUS with TACACS+: network access versus device administration.

Self-check questions

1. Name the three jobs of the CIA triad, and one control that serves each.
2. Why is symmetric encryption preferred for bulk data, and what is its weakness?
3. What problem does asymmetric encryption solve, and why is it slower?
4. What is the difference between AES, RSA and ECC?
5. How does TLS combine asymmetric and symmetric encryption?
6. Why does the avalanche effect matter for integrity?
7. What three properties does a digital signature provide, and which one does it not?
8. What is the difference between CN and SAN, and which is modern?
9. Explain CRL versus OCSP.
10. What is perfect forward secrecy protecting you from?
11. Why is ECC attractive for mobile and IoT devices?
12. Name one control for each data state: at rest, in transit, in use.
13. What is the difference between authentication and authorisation?
14. Why is deprovisioning the step organisations get wrong?
15. Give an example of two credentials that are still single factor.
16. How do the identity provider and the service provider divide the work in SAML?
17. What is the main risk that federation introduces?
18. Compare RADIUS and TACACS+ on transport, functions and best use.
19. What ports does LDAP use, and how is it secured?
20. In an access control list, what happens when no entry matches?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 6

- Job-fit is the exam skill: which algorithm, for which purpose.
- Sign with private, verify with public: memorise the direction, and remember it is not confidentiality.
- Data-state questions: at rest → disk, file or database; in transit → TLS and perfect forward secrecy; in use → memory controls.
- Know the pairs the exam loves: CN versus SAN, CRL versus OCSP, TPM versus HSM, RADIUS versus TACACS+, LDAP versus LDAPS.

- Recognise algorithms by role: AES symmetric, RSA and ECC asymmetric, SHA-256 for integrity.
- Remember that salting defeats pre-computed tables and stretching raises the cost of each guess.
- Separate identity from access: authentication proves who you are, authorisation decides what you may do.
- Count factors by family, not by credential: two things you know are still single factor.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives: the cryptography, identity and access objectives.
- NIST cryptographic standards and guidance (SP 800-series).
- The course reference chapters on public key infrastructure, encryption, hashing, blockchain, identity and access management, RADIUS, TACACS+ and LDAP.
- Your browser's certificate viewer: inspect subject alternative names and the chain of trust in the wild.



TRAINING @ FORREST.ONE

CHAPTER 07

Security Architecture & Data Protection

Where systems run and who carries the risk: on premises, cloud deployment and service models, virtualisation, containers, serverless and industrial systems, then secure design, data classification and encryption, and the resilience that keeps a service alive.

Student Notes, Security Architecture & Data Protection

Your revision guide for Session 7 (Lesson 4, architecture and data protection objectives across Domains 3 and 4). Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready.

Key terms

Term	Definition
On premises	The organisation owns and physically controls the hardware, and carries the full responsibility
Public cloud	Shared among tenants and sold by providers; the provider secures the infrastructure
Private cloud	Dedicated to one organisation, on premises or with a hosting partner
Hybrid cloud	A combination of public and private, with the customer securing the transfer between them
Community cloud	Shared by organisations with common needs, under agreed shared policies
IaaS	Infrastructure as a Service: you secure everything above the hypervisor
PaaS	Platform as a Service: a managed runtime; you secure the application and its data
SaaS	Software as a Service: the whole stack managed; you manage access and protect the data
Type 1 hypervisor	Runs directly on the hardware; smaller attack surface
Type 2 hypervisor	Runs on a host operating system; a flaw there reaches every guest
Virtual machine escape	Breaking out of a guest virtual machine to reach the hypervisor
Sprawl	Forgotten virtual machines that are never patched
Container	A shared host kernel with the application packaged in an image
Serverless	Event driven, stateless and ephemeral functions run by the provider
ICS and SCADA	Industrial control systems, and Supervisory Control and Data Acquisition
IT and OT convergence	Joining office and plant networks, which extends the attack surface
Infrastructure as code	Configuration held in machine readable, version controlled files
Defence in depth	Layers of control, so one failure is not fatal

Term	Definition
Segmentation	Splitting the network so an intruder cannot move freely
Demilitarised zone	A buffer segment for services that face the public
Personally identifiable information	Data that can identify a person; exposure enables identity theft
Data at rest, in transit, in use	Stored, moving across a network, or being processed in memory
Classification	The label that decides how data is stored, transmitted and disposed of
Full disk encryption	Encrypts the whole drive; the answer for a stolen laptop
Hardware security module	Tamper resistant hardware that holds cryptographic keys
Wiping and degaussing	Overwriting storage, or destroying magnetic media with a strong magnet
Data loss prevention	Inspects outbound traffic and blocks sensitive content from leaving
RAID	A redundant array of independent disks, mirrored for fault tolerance
Hot, warm and cold site	Immediate failover, hardware ready, or an empty shell
Recovery point objective	How much data the business can afford to lose
Recovery time objective	How long the service can be unavailable
Platform diversity	Different technologies and more than one vendor, so one flaw is not fatal
Business continuity planning	The umbrella plan that keeps critical processes running

Core concepts

Chapter 1, Architecture models

On premises means physical control and full responsibility: patching, maintenance, disaster recovery planning and skilled staff, plus power, cooling and upgrades in the total cost of ownership. Cloud deployment models shift the security duties between provider and customer: public, private, hybrid and community. Service models set how far the provider reaches: infrastructure as a service leaves you everything above the hypervisor, platform as a service leaves you the application and its data, and software as a service leaves you access control and the data itself. The pattern is that more provider management means less of your control and less of your responsibility.

Chapter 2, Compute and edge platforms

Virtualisation depends on the hypervisor. A type 1 hypervisor runs on the hardware with a smaller attack surface; a type 2 hypervisor runs on a host operating system. Watch for virtual machine escape and for sprawl, which leaves virtual machines unpatched; snapshots also hold sensitive data. Containers share the host kernel and package the application into an image, so a vulnerable library is reproduced in every copy: scan images and secure orchestration. Serverless functions are stateless and ephemeral, but the trigger is an

entry point, so authenticate and validate every event. Internet of things risk comes from limited processing power, infrequent updates, default credentials and sheer scale, answered by segmentation, monitoring and lifecycle management. Industrial control systems and SCADA run physical processes with legacy protocols, so safety and availability outrank confidentiality, and IT and OT convergence extends the attack surface into the plant.

Chapter 3, Secure design

Infrastructure as code builds the same server from the same file every time, holds history in version control, and allows automated scanning before production. Its risks are misconfiguration at scale and secrets written into configuration files, answered with a dedicated secrets manager, peer review, pipeline validation and separate environments. Secure network design uses defence in depth, segmentation with virtual local area networks and firewalls, access control lists, a demilitarised zone for public facing services, and least connectivity. Protect the channel with virtual private networks, Transport Layer Security and Internet Protocol Security, administrator access through a jump server, and certificates issued, renewed and revoked by a trusted authority. Control selection weighs risk assessment, compliance, cost and operational impact, using technical, administrative and physical controls together, then tests and monitors them.

Chapter 4, Data protection

Data types carry legal weight: personally identifiable information, protected health information and financial data. Data has three states: at rest, in transit and in use. Classification levels run public, internal, confidential and restricted, and the label drives storage, transmission and disposal. At rest, use full disk encryption, file level encryption or database encryption, and manage keys properly; hardware security modules hold keys in tamper resistant hardware. For disposal, wiping works on hard disk drives and solid state drives, degaussing destroys magnetic media only, and destruction by shredding, crushing or incineration is strongest. In transit, use the secure version of every protocol, encrypt email, apply data loss prevention to outbound traffic, and validate certificates rather than accepting warnings.

Chapter 5, Resilience and recovery

Availability is measured by uptime and mean time between failures, and built from redundancy: RAID, teamed network cards, clusters, load balancing and automatic failover, with single points of failure removed. Alternate sites trade cost against readiness: hot, warm and cold, placed far enough apart that one disaster cannot take both. Backups are full, incremental or differential, and the recovery objectives come first: the recovery point objective is how much data you can lose, and the recovery time objective is how long you can be down. Power and environment controls (uninterruptible power supply, generator, cooling, fire suppression, humidity) and platform diversity protect the room and the stack. Testing runs from tabletop exercise through simulation and full failover to parallel processing. Business continuity planning is the umbrella: business impact analysis, acceptable downtime, continuity of operations, IT disaster recovery, and a maintained and rehearsed plan.

Chapter 6, Consolidation

Every decision in this session either protects data or protects the systems that hold it. Architecture sets where the trust sits; classification makes data protectable; encryption and key management defend it in every state; and resilience plus continuity keep the service alive. The exam tests the responsibility line, the control that fits a data state, and the recovery objectives. Name them, and you can answer the scenario.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: on premises architecture

On premises infrastructure consists of IT systems an organisation owns, operates and houses in its own facilities. Direct physical control lets it regulate who reaches servers and network equipment, add alarms and surveillance, and respond to incidents locally. The organisation also carries patching, disaster recovery planning and the total cost of ownership, covering hardware, power, cooling and staff.

- Physical control supports surveillance and alarms
- Maintenance and patching stay in house
- Capital, power and staffing form the total cost of ownership
- Regulated sectors keep sensitive data in house

Reference deep dive: cloud deployment models

A public cloud delivers services over the internet and shares them among many tenants, as Amazon Web Services, Microsoft Azure and Google Cloud Platform do. A private cloud is dedicated to one organisation and may sit on premises or with a provider. A hybrid cloud moves workloads between the two, and a community cloud is shared by organisations with common needs.

Deployment model	Provider secures	Customer secures
Public	Data centres, network and hypervisors	Data, applications and operating systems
Private	Physical security, where the provider hosts it	Infrastructure, applications and data
Hybrid	The public cloud infrastructure	Data moving between both clouds
Community	The underlying infrastructure	Shared policy agreed by participants

Reference deep dive: cloud service models and shared responsibility

The cloud service models differ in how much of the stack the provider runs. Infrastructure as a Service supplies virtual machines and storage while the provider keeps the hardware and hypervisor, so the customer patches the operating system and secures everything above it. Platform as a Service adds a managed runtime. Software as a Service delivers a finished application, and the customer still protects the data placed there.

Service model	Provider manages	Customer manages
IaaS	Hardware and hypervisor	Operating system, middleware and data

Service model	Provider manages	Customer manages
PaaS	Infrastructure and runtime environment	Application code and data
SaaS	The entire stack	The data held in the service

Reference deep dive: virtualisation and hypervisor security

Virtualisation runs several virtual machines on one physical host under a hypervisor, the software layer that creates and manages them. A type 1 hypervisor such as VMware ESXi or Microsoft Hyper-V sits directly on the hardware, so it carries a smaller attack surface. A type 2 hypervisor such as VMware Workstation or Oracle VirtualBox runs on a host operating system and inherits its weaknesses.

- A virtual machine escape breaks out to the hypervisor
- Inter virtual machine attacks spread between guests
- Sprawl leaves forgotten guests unpatched
- Snapshots consume storage and may hold sensitive data

Reference deep dive: containers, serverless and workload isolation

A container packages application code, runtime, libraries and settings into one image and shares the operating system kernel of its host, so it starts faster and weighs less than a virtual machine, which carries a full operating system of its own. Docker builds and runs images, and Kubernetes orchestrates them. Serverless functions run in response to events, stay stateless and ephemeral.

- Use trusted images and scan with Clair or Trivy
- Secure the orchestration layer and its secrets
- Enforce policy with AppArmor or SELinux
- Segment container networks to limit east west traffic
- Validate input, since event triggers are entry points

Reference deep dive: internet of things and industrial control systems

Internet of Things devices such as sensors, cameras and embedded systems often lack processing power for strong security, receive updates rarely, ship with default credentials and deploy in numbers that widen the attack surface. Industrial control systems, including programmable logic controllers, distributed control systems and SCADA, drive physical processes where safety and availability outrank confidentiality, and many run legacy protocols that carry no encryption.

- Place devices on separate segments using VLANs
- Watch device behaviour for anomalies
- Change default credentials at deployment
- Patch on a schedule agreed with the manufacturer
- Wipe stored data before decommissioning

Availability outranks confidentiality in operational technology

A stopped industrial process can damage equipment or endanger people, so control system design favours uptime and safety. Segment the plant network, keep legacy protocol traffic inside it, and never test a control change in production first.

Reference deep dive: infrastructure as code

Infrastructure as Code defines servers, networks and services in machine readable configuration files instead of configuring hardware by hand. Standardised files remove configuration drift, version control records every change and allows rollback, and automated checks test compliance before deployment. The risks are a single misconfiguration copied across every environment and secrets such as keys or certificates left inside the files.

- Keep configuration files in version control
- Scan files for compliance with security policy
- Store secrets in HashiCorp Vault or AWS Secrets Manager
- Validate templates with terraform validate or cfn-lint
- Separate development, test and production environments

Reference deep dive: secure network design and defence in depth

Secure network design assumes that any single control can fail. Defence in depth layers physical, network, application and data measures so that one failure does not expose the system. Segmentation divides the network into VLANs and zones policed by firewalls, which limits lateral movement, and a demilitarised zone holds public facing servers between an external and an internal firewall.

- VLANs keep sensitive traffic inside defined boundaries
- A demilitarised zone shields the internal network
- Jump servers and bastion hosts concentrate administrative access
- TLS, IPsec and VPNs protect data crossing the network

Reference deep dive: security control selection

Selecting controls begins with a risk assessment that ranks threats by likelihood and impact. Compliance duties such as GDPR, HIPAA or PCI DSS then dictate particular controls, for example encryption of cardholder data. Cost of ownership and the effect on daily work both shape the choice. Every control should serve confidentiality, integrity or availability.

- Technical controls include firewalls and intrusion detection
- Administrative controls cover policy and awareness training
- Physical controls include cameras, badges and scanners
- Encryption protects confidentiality, hashing protects integrity
- Redundant systems and backups protect availability

Reference deep dive: data types, states and classification

Regulated data carries legal duties: personally identifiable information under GDPR and CCPA, protected health information under HIPAA, and financial data such as card numbers under PCI DSS. Data sits in one of three states, at rest on storage media, in transit across a network, or in use in memory while a process handles it. Classification then sets the level of handling required.

- Public data can be shared openly
- Internal data stays within the organisation
- Confidential data covers personal and proprietary information
- Restricted data needs the strongest protection
- Labels mark the level with stickers or metadata tags

Reference deep dive: protecting data at rest

Data at rest is inactive data held on disks, in databases, in archives or in cloud storage. Encryption is the primary control. Full disk encryption covers the whole volume, file level encryption covers chosen files and directories, and database encryption can target single columns or entire tablespaces. Key custody and secure disposal complete the picture.

- BitLocker and FileVault provide full disk encryption
- The Windows Encrypting File System secures chosen files
- Column level encryption protects selected database fields
- Rotate and retire keys on a defined schedule
- Hardware security modules hold keys in tamper resistant hardware

Reference deep dive: protecting data in transit

Data in transit moves between systems and can be intercepted on the way. Transport Layer Security encrypts web traffic after a handshake in which both ends agree algorithms and keys, and certificate validation confirms that a certificate is genuine, current and not revoked. IPsec works at the network layer, in transport mode for the payload alone or tunnel mode for the whole packet wrapped inside a new one.

- HTTPS is HTTP carried over TLS
- SFTP and SCP use SSH, while FTPS uses TLS
- PGP and S/MIME encrypt the message itself
- Data loss prevention inspects and can block outbound traffic
- Certificate validation checks signature, expiry and revocation

Match the control to the data state

Encryption at rest does nothing for data already crossing the network, and TLS on the wire does nothing for a stolen disk. Name the state first, at rest, in transit or in use, because each needs a different control.

Reference deep dive: high availability and site redundancy

High availability keeps a service running when a component fails. Uptime percentages state the target, so 99.9% allows roughly 8.76 hours of downtime a year, and mean time between failures measures how often a system breaks. Redundancy attacks single points of failure through RAID, NIC teaming, clustering, load balancing and automatic failover. Geographic spread guards against regional outage but adds latency.

Site	State of readiness	Cost and recovery
Hot	Full hardware, software and current data	Highest cost, almost immediate takeover
Warm	Hardware ready, data needs restoring	Moderate cost, hours to days
Cold	Power and environmental control only	Lowest cost, longest recovery

Reference deep dive: backup strategies and recovery objectives

Backup copies data to another location for restoration after loss, corruption or attack. A full backup copies everything, an incremental backup copies changes since the last backup of any kind, and a differential backup copies everything since the last full backup without resetting. Recovery time objective sets the longest tolerable outage, and recovery point objective sets the data loss tolerated. The 3 2 1 rule keeps three copies of data, on two different media, with one copy held off site.

Backup type	What it captures	Restore effort
Full	All data, every time	One set, simplest to restore
Incremental	Changes since the last backup of any kind	Last full plus every increment
Differential	Changes since the last full backup	Last full plus the latest differential

RTO measures time, RPO measures data

Recovery time objective sets how long a service may stay down. Recovery point objective sets how much data may be lost, expressed in time. Confusing the two is the most common error in a question about recovery targets.

Reference deep dive: power, environmental controls and platform diversity

Availability depends on the physical plant as much as on software. An uninterruptible power supply carries the load on batteries through a brief outage while a generator starts, and the generator then sustains a long one. Cooling, fire suppression and humidity control keep equipment within safe limits. Platform diversity spreads risk across varied technologies and vendors.

- An uninterruptible power supply bridges the gap until a generator runs
- Generators sustain power through long outages

- Cooling prevents heat related hardware failure
- FM-200 or inert gas suppresses fire without water damage
- Humidity control prevents static electricity and condensation

Reference deep dive: business continuity planning and resilience testing

Business continuity planning prepares an organisation to keep essential functions running through a disruption. A business impact analysis identifies the critical processes, maps the dependencies behind them and sets the acceptable downtime, which becomes the recovery time objective. Continuity of operations planning sustains those functions, while IT disaster recovery restores systems and data. Plans are tested, documented and reviewed annually.

- A business impact analysis identifies the critical processes
- Acceptable downtime becomes the recovery time objective
- Tabletop exercises talk through a scenario and expose gaps
- Simulation testing stresses systems and models attacks
- Full failover testing moves operations to the backup site
- Parallel processing validates recovery without disruption

Practical cautions

- Do not assume the cloud removes your responsibility. Find the line for the service model you use.
- Do not treat containers as automatically secure. A vulnerable image reproduces its weakness everywhere.
- Do not leave serverless triggers unauthenticated. An event is an entry point.
- Do not connect industrial networks without deliberate segmentation and industrial aware monitoring.
- Do not write secrets into infrastructure as code files. Use a dedicated secrets manager.
- Do not rely on encryption without key management, rotation and restricted key use.
- Do not degauss a solid state drive and call it sanitised. Wipe it or destroy it.
- Do not choose backups before you have agreed the recovery point objective.
- Do not treat a written continuity plan as a plan. Rehearse it.

Self-check questions

1. Name the four cloud deployment models and say who carries the security responsibility in each.
2. In infrastructure as a service, what does the customer still secure?
3. What is the difference between a type 1 and a type 2 hypervisor, and which is safer?
4. Why is a container image a security risk, and what two things reduce it?
5. Name the four risks of internet of things devices.
6. Why do safety and availability outrank confidentiality in industrial control systems?
7. What two risks does infrastructure as code introduce, and how do you answer them?
8. Name the three elements of secure network design that contain an intruder.

9. What are the three states of data, and which control suits each?
10. When is degaussing the wrong disposal method, and what should you use instead?
11. What is the difference between the recovery point objective and the recovery time objective?
12. What distinguishes a hot site from a warm site and a cold site?
13. Why is an untested recovery plan only a guess, and what tests are available?
14. What does a business impact analysis produce?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 7

- Find the responsibility line first. Most architecture questions are answered by knowing what the customer still owns.
- Learn the pattern, not the acronyms: more provider management means less control and less responsibility.
- The exam pairs to know: type 1 and type 2 hypervisors, hot and warm and cold sites, recovery point and recovery time objectives.
- Data state decides the control: full disk and database encryption at rest, secure protocols and data loss prevention in transit.
- Classification is the control that makes every other data protection possible, so be ready to assign a level.
- Containment vocabulary is examinable: defence in depth, segmentation, demilitarised zone, least connectivity.
- Continuity is a business plan with IT inside it, driven by a business impact analysis.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, architecture and data protection objectives.
- NIST SP 800-53, security and privacy controls catalogue, for the control families used here.
- NIST SP 800-34, contingency planning guide, for recovery objectives and continuity planning.
- NIST SP 800-88, media sanitisation guidelines, for wiping, degaussing and destruction.
- Cloud provider shared responsibility documentation, to compare your own responsibility line.



TRAINING @ FORREST.ONE

CHAPTER 08

Network Security Controls & Segmentation

Architecture and segmentation, the appliance stack, firewalls, IDS/IPS, proxies, WAF and NAC, secure remote access with VPN and ZTNA, and the secure protocol toolkit that carries traffic safely.

Student Notes, Network Security Controls & Segmentation

Your revision guide for Session 8. The session follows six chapters: the physical and human layer, segmenting the network, guests and personal devices, hardening and admission control, keys and content control, and trust zones. Read these notes alongside the slides, then use the self-check questions and the session quiz to confirm you can place the right control in the right position, which is the scenario skill the exam rewards.

Key terms

Term	Definition
Physical controls	Rooms, locks, surveillance and visitor management that protect the hardware
Key lock	Cheap but pickable and duplicateable; the weakest access control
Combination lock	No key to lose, but the code is a shared secret
Electronic access control	Cards and fobs, which can be revoked instantly when lost
Biometrics	Hardest to share, costliest to run, and not revocable if copied
Access log	Record of who entered a secure space, and when
Honeypot	A decoy system built to attract attackers away from real targets
Low interaction honeypot	Simulates few services: simple, safe, shallow detail
High interaction honeypot	Runs a full operating system: rich detail, more risk
Honeynet	A network of decoys, which makes lateral movement visible
Entrapment	Inducing an offence; a decoy must observe and record, never solicit
Internal audit	Assurance run by your own team; deep system knowledge
External audit	Independent third party assessment, often required by a regulator
PCI DSS	Payment Card Industry Data Security Standard: protect cardholder data
GDPR	EU personal data rules: consent, access, correction and deletion
Data locality	Requirement that citizens' records stay within a country
VLAN	Virtual local area network: one switch split into logical networks

Term	Definition
Firewall zone	A boundary that defines what may cross between segments
Micro-segmentation	Policy applied per workload, not per rack or physical segment
Least connectivity	Allow only the connections that are actually necessary
IoT	Internet of things: cheap, rarely patched, often default credentials
Operational technology	Systems controlling physical processes, where availability outranks confidentiality
SCADA / ICS	Industrial control systems, legacy by design and often unpatchable
Purdue model	Layered industrial reference model, levels 0 to 4, plus an air gap
Air gap	Physical isolation from other networks, for near-zero intrusion risk
Guest VLAN	A separate segment giving guests internet access only
Captive portal	Web page presenting acceptable use terms before access is granted
BYOD	Bring your own device: personal hardware accessing corporate resources
MDM	Mobile device management: enrolment and policy enforcement on a device
Hardening	Removing everything a device does not need
Secure baseline	One documented configuration standard per device type
Configuration drift	An undocumented change that moves a device away from its baseline
Minimal functionality	A device does only the job it was bought for
NAC	Network access control: posture checking before a device joins
Posture assessment	Checks antivirus, patches, settings and user credentials
Quarantine segment	A restricted segment for devices that fail posture checks
Remediation network	A limited network that lets a failing device patch itself
802.1X	Port based authentication at the switch, before traffic flows
Supplicant / authenticator	The device that asks, and the switch port that relays
RADIUS	Remote authentication dial in user service: central authentication server
Key lifecycle	Generate, distribute, store, rotate, revoke, destroy
Hardware security module	Physical device that performs crypto without exposing the key
Key vault	Software key store with access control, auditing and logging
Secure enclave	Isolated execution area inside the processor

Term	Definition
Key rotation	Scheduled key replacement, which limits the blast radius of a leak
ACL	Access control list: permit or deny by address, port or protocol, first match wins
URL filtering	Blocking whole categories of site, usually at a proxy or service
DNS filtering	Blocking the name lookup before a connection can be made
Content filtering	Scanning traffic for malicious content and blocking it
Deep packet inspection	Examining packet contents in real time
DLP	Data loss prevention: stopping sensitive data leaving the organisation
Web proxy	Intermediary that enforces policy, caches content and hides internal addresses
Trust zone	A boundary defining what trust may cross it: untrusted, semi-trusted, trusted
Screened subnet (DMZ)	Buffer zone hosting public facing services, separate from the interior
Defence in depth	Several layers of control, because no single control is foolproof
Zero trust	No implicit trust from location; verify identity and context per request
Tiered model	Core (transport), distribution (policy), access (endpoints)
Spine-leaf	Data-centre fabric where every leaf connects to every spine
Stateless firewall	Filters each packet alone, with no connection context
Stateful firewall	Tracks connections in a state table and allows established flows
NGFW	Next-generation firewall: application aware, with deep packet inspection
IDS / IPS	Detect and alert / detect and block inline
WAF	Web application firewall: protects web apps at layer 7
Site-to-site VPN	Tunnel connecting whole networks, often IPsec tunnel mode
SSL VPN	Browser-based or TLS remote access, with no client install
Split tunnel	Only some traffic traverses the tunnel
ZTNA	Per-request verification: no implicit network trust
SASE	ZTNA plus SD-WAN delivered as a service
PFS	Perfect forward secrecy: ephemeral keys keep past traffic secret
HSTS	Tells browsers to refuse plaintext connections for the domain

Core concepts

8E, Physical, deception and audit

Physical controls protect the rooms that hold the network: equipment rooms, wiring closets and data centres, with key, combination, electronic or biometric access. Around them sit cameras (with coverage, retention and blind spots), visitor management, access logs and guards. Physical access defeats every logical control, so it comes first. Deception technologies add honeypots (low or high interaction) and honeynets, which give intelligence and early warning, provided the decoy is isolated and the monitoring is lawful: consent, privacy and entrapment all apply. Audits test whether controls exist and whether they work; internal audit uses your own team, external third party assessment brings independence. Prepare with documentation, evidence, briefings and a mock audit, then remediate and verify. PCI DSS, GDPR and data locality set the compliance context, and logs, configurations and access records are the evidence.

8F, Segmentation and special environments

Segmentation divides one network into many. VLANs split a physical switch into logical networks, firewall zones decide what may cross, and micro-segmentation applies policy per workload, so a compromised web server cannot reach the database on the same segment. Benefits are containment, a smaller attack surface and compliance, and the plan starts from data sensitivity and trust level, never convenience. Special environments get their own treatment: IoT devices are cheap, rarely patched and shipped with default credentials; industrial IoT and operational technology drive physical processes where availability outranks confidentiality. The Purdue model places field devices at levels 0 and 1, process control at 2, site operations at 3 and enterprise systems at 4, with tightly controlled traffic between layers, and an air gap where intrusion risk must be near zero. Because these devices cannot be patched during a production run, the control shifts from hardening the device to containing the segment.

8G, Guests and personal devices

A guest network is its own VLAN, with no route inward, enforced by firewall rules and access control lists, a bandwidth cap, and a captive portal that presents acceptable use terms, records agreement and captures a name or address for the log. BYOD is the same problem with personal hardware you do not own: segment the devices, limit what they reach, enrol them in mobile device management to enforce policy, and use certificate based authentication so the network knows the device and can revoke it. Define what a compliant device looks like, make enrolment a condition of connecting, separate work data from personal data, and be ready to wipe corporate data from a lost device.

8B, Hardening and admission control

Hardening removes everything the device does not need: change default credentials immediately, disable unused services, close unused ports, disable unused protocols, and patch firmware and software promptly with automation. Build a secure configuration baseline from published guides (CIS benchmarks, NIST publications and vendor hardening guides), one standard per device type, then audit against it to catch configuration drift. The principle is minimal functionality: a router routes and does not host a website. Admission control then decides who joins. NAC performs posture assessment (antivirus presence and currency, operating system patches, configuration settings and user credentials) with outcomes of allow, quarantine into a restricted segment, or deny, plus a remediation network so a device can fix itself. The

mechanism is 802.1X port based authentication: the device is the supplicant, the switch is the authenticator, and a RADIUS server makes the decision. Deploy in phases, in monitor mode first, because false positives lock out healthy devices.

8H, Key management and content control

A key has a lifecycle: generation from a secure random source seeded with real entropy, distribution without exposure, storage, rotation on a schedule, revocation, and destruction including backups. Keys live in a hardware security module (physical, never exposes the key), a key vault (software, with access control and auditing), a secure enclave (inside the processor), or under a key management system that centralises the lifecycle. Rotation limits the blast radius of a leak. Filtering turns policy into enforcement: an access control list permits or denies by source, destination, port or protocol, is evaluated in sequence, and stops at the first match, so a permit everything rule at the top makes the rest decoration. URL filtering blocks whole categories, DNS filtering blocks the lookup, content filtering blocks malicious content, deep packet inspection examines contents in real time, data loss prevention stops sensitive data leaving, and a web proxy enforces policy, caches and hides internal addresses.

8A, Trust zones and the retained exam objectives

Trust zones describe architecture: the untrusted internet, the trusted interior, semi-trusted partner, branch and guest networks, and the screened subnet (DMZ) that buffers public facing services. Zone based policy governs every path between zones, deliberately asymmetric so the DMZ cannot initiate back into the interior, layered with defence in depth, and validated per request under zero trust. Architecture models: tiered (core, distribution, access), spine-leaf for low-latency data-centre fabrics, and flat SMB designs, with redundancy to remove single points of failure. Appliances: stateless and stateful firewalls, NGFW and UTM, IDS versus IPS, proxy, WAF and load balancer. Remote access: site-to-site, remote access and SSL VPNs, split tunnel, and ZTNA with SASE, with MFA non-negotiable on RDP. Protocols: TLS 1.2 and 1.3 current, PFS, certificate validation, and the toolkit of TLS/HTTPS, SSH/SFTP, IPsec, S/MIME, DNSSEC and HSTS.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

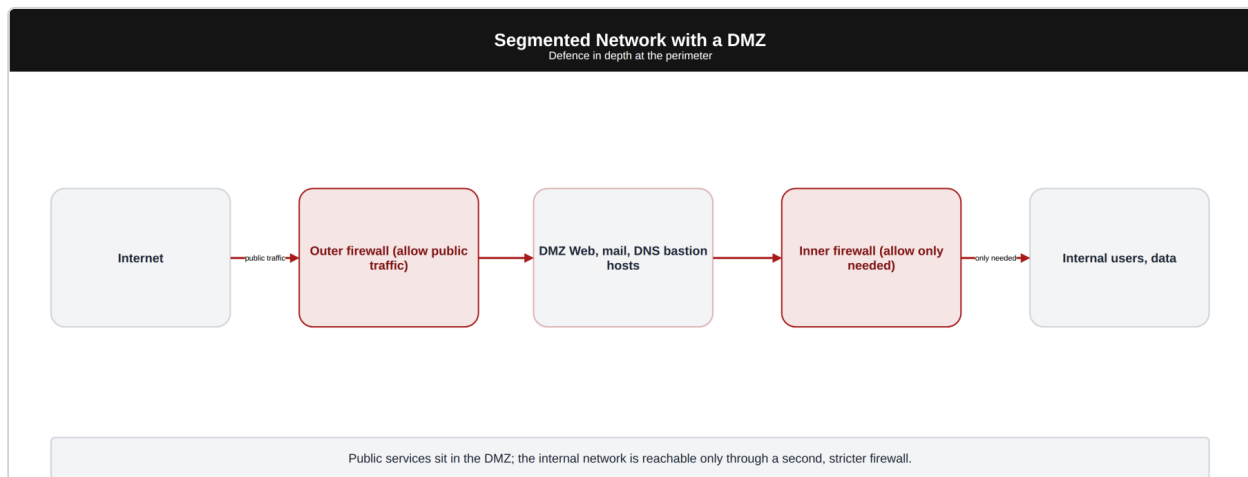
Reference deep dive: defence in depth

Defence in depth stacks independent security layers so a failure in one is caught by the next. Layer the controls rather than relying on any single mechanism.

- Physical layer controls facility access, surveillance and hardware protection
- Network layer applies firewalls, IDS and IPS to filter and monitor traffic
- Application layer uses updates, patching and security testing to block exploits
- Data layer encrypts sensitive data against unauthorised access
- Combine layers so no single compromise defeats the whole system

Reference deep dive: segmentation, DMZ and least connectivity

Figure 8.1: Segmented network with a DMZ between two firewalls.



Segmentation shrinks the blast radius of a breach by dividing the network into isolated zones with controlled traffic between them.

- VLANs segregate traffic so sensitive data stays inside secure boundaries
- Firewalls between segments filter and monitor all crossing traffic
- ACLs define exactly which users and devices may reach each segment
- Segmentation blocks lateral movement after an initial compromise
- A DMZ hosts public services (web, mail) shielded from the internal network
- Use an external and an internal firewall either side of the DMZ
- Least connectivity permits only the connections a service truly needs
- Audit and monitor traffic regularly to detect unauthorised connections

Reference deep dive: jump servers and bastion hosts

Jump servers and bastion hosts provide controlled entry points for secure administrative access so admins never touch internal systems directly.

- Jump server is a hardened, monitored gateway to manage internal devices
- Bastion host faces the internet and is built to withstand direct attack
- Both enforce strong authentication before granting access
- They remove direct exposure of sensitive internal systems
- Restrict and log all activity passing through these access points

Reference deep dive: security control selection

Choose controls by weighing risk, compliance, cost and operational impact, then integrate technical, administrative and physical measures.

- Risk assessment prioritises controls by likelihood and impact of threats
- Compliance rules such as GDPR, HIPAA and PCI DSS dictate specific controls

- Balance upfront and ongoing cost against the value of what is protected
- Controls must not unduly slow daily business operations
- Technical controls include firewalls, antivirus and intrusion detection
- Administrative controls cover policy, procedure and staff training
- Physical controls include cameras, access badges and biometric scanners
- Test controls and monitor them continuously to confirm ongoing effectiveness

Reference deep dive: protecting data in transit

Data moving across networks is at risk of interception, so encrypt it with protocols that preserve confidentiality, integrity and authenticity.

- TLS secures web traffic via a handshake that authenticates peers and agrees keys
- IPsec encrypts at the network layer, ideal for site to site VPNs
- Transport mode encrypts only the payload; tunnel mode wraps the whole packet
- Use HTTPS, SMTPS, SFTP and FTPS as secure versions of plain protocols
- Encrypt email with PGP or S/MIME so only the recipient can read it
- SFTP, FTPS and SCP give encrypted file transfer options
- DLP inspects outbound traffic and blocks or alerts on sensitive data leaks
- Validate certificates to confirm identity and prevent man in the middle attacks

Control	Layer	Use case
TLS	Transport	HTTPS web sessions and email
IPsec	Network	Site to site and remote VPNs
PGP / S/MIME	Application	Email encryption and signing
DLP	Content	Stop sensitive data leaving the network

Practical cautions

- Do not deploy a decoy without consent, and never let it solicit an attack: that is entrapment.
- Do not let a honeypot reach production: isolation is mandatory, or you have built an attacker a stepping stone.
- Do not treat IoT or industrial devices as ordinary endpoints: they are untrusted by default and often unpatchable.
- Do not plan segmentation from convenience: plan it from data sensitivity and trust level.
- Do not put guests on an internal segment, and do not rely on a Wi-Fi password as the control.
- Do not approve BYOD without enrolment, a certificate and a selective wipe capability.
- Do not skip default credentials: they are published, and every attacker already has them.
- Do not write a baseline from memory, and do not leave it unaudited: drift is the enemy.
- Do not enforce NAC without a pilot and monitor mode: false positives lock out healthy devices.

- Do not forget that ACL order matters: first match wins, so a permit everything rule at the top defeats the list.
- Do not confuse IDS (detects and alerts) with IPS (blocks inline).
- Do not expect signature detection to find new attacks; anomaly detection covers the unknown.
- Do not call TLS 1.0 acceptable: SSL and TLS 1.0 / 1.1 are deprecated.
- Do not assume a split tunnel protects all user traffic: it only covers the tunnel.
- Do not put public services inside the internal segment: that is the screened subnet's job.
- Do not forget MFA on remote access: it is the non-negotiable control.
- Do not treat a firewall's state tracking as encryption: filtering and encryption are separate.

Self-check questions

1. Which four access control types might secure a wiring closet, and what does each cost you?
2. Why is isolation mandatory for a honeypot, and what legal limits apply to deception?
3. What does an audit test, and how do internal and external audits differ?
4. Name the compliance regimes from this session, and say what evidence proves compliance.
5. How does micro-segmentation differ from VLAN segmentation?
6. Where do internet of things devices belong in a segmented network, and why?
7. Describe the Purdue model's levels, and say where an air gap belongs.
8. Why does availability outrank confidentiality in operational technology?
9. List the controls that make a guest network safe.
10. What must a BYOD programme include before a personal device may connect?
11. What does hardening remove, and which four changes come first?
12. What is a secure configuration baseline, and what is configuration drift?
13. What does NAC posture assessment check, and what are the possible outcomes?
14. Name the three roles in 802.1X, and the protocol a RADIUS server speaks.
15. Walk the key lifecycle, and say what rotation achieves.
16. Where should keys be stored, and what does each store protect against?
17. Why does the order of an access control list matter?
18. Distinguish content filtering, deep packet inspection and data loss prevention.
19. Describe the trust zones and the purpose of a screened subnet.
20. What is deliberate asymmetry between zones, and how does zero trust change it?
21. Where does policy enforcement happen in the tiered model?
22. Name the four firewall types and their differences.
23. Why can signature detection miss a novel attack?
24. Which VPN type suits a contractor with browser-only access?
25. What does perfect forward secrecy protect?
26. What does certificate validation defeat, and which checks make it up?

27. Match: web traffic, remote admin, VPN, email, DNS integrity.

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 8

- Scenario questions ask which control fits: classify by what the control does, when it acts and where it sits.
- Segmentation and containment questions are answered by what limits lateral movement.
- Industrial and IoT scenarios usually want isolation plus monitoring, not patching.
- Guest and BYOD scenarios want a separate segment, a portal or enrolment, and no internal trust.
- Hardening questions want removal of unused services, credentials and a verified baseline.
- NAC questions want posture checking, with quarantine and remediation as the recovery path.
- Key management questions want rotation, storage and destruction, in that order of emphasis.
- ACL questions hinge on order and first match.
- IDS versus IPS and stateful versus stateless are the highest-frequency appliance distinctions.
- Know the VPN flavours, including IPsec tunnel mode, and the secure protocol toolkit (TLS, SSH, IPsec, S/MIME, DNSSEC).
- Read every quiz explanation: the distractors teach as much as the answers.

Further reading

- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture).
- Definitive CompTIA Network+ Certification Path, physical security, deception, segmentation, hardening, NAC, key management, filtering and network zones.
- NIST SP 800-41, guidelines on firewalls and firewall policy.
- NIST SP 800-53, security and privacy controls, including boundary protection and physical protection.
- Centre for Internet Security Benchmarks, published secure configuration baselines.
- IEEE 802.1X, port based network access control.
- PCI DSS and the UK GDPR, the regulatory regimes discussed in this session.
- RFC 8446, TLS 1.3; RFC 6071, the IPsec and IKE documentation roadmap.



TRAINING @ FORREST.ONE

CHAPTER 09

Network Troubleshooting & Resilience

Diagnosing what went wrong and designing so it matters less: the structured troubleshooting methodology, cable and interface faults, wireless interference, switching and VLAN problems, routing and gateway faults, addressing and DHCP pool exhaustion, congestion, latency and packet loss, and the command line and protocol analysis toolset used to prove it.

Student Notes, Network Troubleshooting & Resilience

Your revision guide for Session 9. Read alongside the slides, then use the self-check questions and the session quiz to confirm you can pick the control for each asset class: endpoint, application, cloud.

Key terms

Term	Definition
EDR	Endpoint detection and response, behaviour-based monitoring
Allowlisting	Only pre-approved software runs, blocks unknown malware
Blocklisting	Known bad software is denied, misses unknowns
Code signing	Verifies software origin and integrity before execution
Secure baseline	A documented secure configuration from a known state
CIS benchmark	Consensus security configuration guidance from CIS
MDM	Mobile device management, enrol, configure, enforce, wipe
BYOD	Bring your own device, corporate data on personal devices
Application vetting	Assessing and approving apps before corporate install
Secure boot	Verified boot chain blocks tampered firmware
Firmware update	Patching below the operating system
Shift left	Security from the first design, not the last test
Threat modelling	Finding the attack surface before code exists
SAST / DAST	Source analysis / running-application testing
DevSecOps	Security in the CI/CD pipeline, not a release gate
Input validation	Whitelisting, sanitisation and boundary checks
SQL injection	User input treated as part of the query
XSS	Attacker script runs in another user's browser
CSRF	Forged request rides a victim's session
Sandboxing	Isolating code to contain any compromise

Term	Definition
Buffer overflow	Excess input overwrites memory
Directory traversal	Dot dot slash escapes the web root
IaaS / PaaS / SaaS	Infrastructure / platform / software as a service
Community cloud	Shared by organisations with common needs
Shared responsibility	Vendor secures the cloud; you secure what is in it
CASB	Cloud access security broker
Hypervisor	Type 1 bare metal or Type 2 hosted, separates the VMs
VM escape	Breaking out of the guest into the hypervisor host

Core concepts

9A, Endpoint security

The endpoint stack: AV/EDR (signature plus behaviour), hardening (baseline from CIS benchmarks or vendor guides, patching, disable unused services, ports and default accounts), application control (allowlisting over blocklisting, backed by code signing), MDM (enrol, configure, enforce, wipe) with application vetting and containers for BYOD, and OS controls, least privilege, secure boot, full disk encryption and firmware updates.

9B, Application lifecycle

Shift left: threat modelling before code, code review at every change, SAST for source and DAST for running apps. Secure coding keeps the code at least privilege, hides errors, and validates all input by whitelisting, sanitisation and boundary checks. DevSecOps puts security in the CI/CD pipeline and scans infrastructure as code, so secure code ships as fast as insecure code.

9C, Application attacks

SQL injection: input treated as code, fix with parameterised queries and input validation. XSS: script in another user's browser, fix with output encoding; a Web Application Firewall filters web traffic. CSRF: forged action on a session, fix with tokens and same-site cookies. Also buffer overflow, directory traversal and race conditions, mitigated by input validation, least privilege and sandboxing.

9D, Cloud & virtualisation

Service models: IaaS (you secure everything above the hypervisor), PaaS (you secure the app and its data), SaaS (the vendor secures nearly everything). Deployment models, public, private, hybrid and community, shift the line. Shared responsibility: vendor secures the cloud, you secure what is in it. Misconfiguration is the top cloud risk, managed with CASB and posture management. Virtualisation: the hypervisor is the crown jewel, Type 1 beats Type 2, VM escape is the nightmare, containers share the kernel and need namespaces and seccomp.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: troubleshooting method and the OSI model

Structured troubleshooting starts by identifying the problem: ask the users what changed, when the fault began and who is affected, then check documentation, monitoring data and change logs. The engineer then forms a theory of probable cause and uses the seven layer OSI model, Physical, Data Link, Network, Transport, Session, Presentation and Application, to isolate the fault.

- Physical layer: faulty cables, dead ports and power faults.
- Data link layer: MAC address and switch port faults.
- Network layer: addressing and routing faults.
- Transport layer: TCP and UDP configuration faults.
- Upper layers: software and application faults.
- Escalate when testing fails or the needed skills are absent.

Reference deep dive: testing, resolution and documentation

Testing turns a theory into evidence through controlled change, altering one variable and watching whether the symptom clears. A successful change confirms the theory, which is then planned for wider use; a failed change disproves it and the engineer forms a new hypothesis. Deployment needs an impact review, a rollback plan and a maintenance window.

1. Confirm the theory with one controlled change.
2. Assess the effect on performance, security and access.
3. Write a rollback plan and book a maintenance window.
4. Apply the fix, verify the system and ask users to confirm.
5. Record the problem, root cause, resolution and preventive measures.

One variable at a time

Change a single element, read the result, then repeat. Record every modification, its time and its effect, so a disproved theory reverts cleanly. Plan the rollback before the fix and confirm the repair with system tests and user feedback.

Reference deep dive: cable type and signal degradation

Wrong cable selection and signal loss explain many intermittent faults. A straight through cable joins unlike devices; a crossover cable joins like devices and reverses the pin arrangement at one end. Category sets speed and reach, and twisted pair must stay within 100 metres, beyond which attenuation, electromagnetic interference and crosstalk degrade the signal.

Cable	Speed	Maximum reach
Cat5e	1 Gbps	100 metres
Cat6	10 Gbps	55 metres
Cat6a	10 Gbps	100 metres
Single mode fibre	Highest bandwidth	Long haul, higher cost
Multimode fibre	High bandwidth	Building and campus spans

Reference deep dive: termination and connector faults

Termination faults sit between the cable and the port. A poor crimp, or a connector made for another cable type, gives weak contact and intermittent links. Wires must follow the T568A or T568B pin out, and a transposed transmit or receive pair, or a split pair built from two twisted pairs, raises crosstalk. Dirty fibre end faces attenuate light.

- Inspect connectors for bent pins, cracks and a loose fit.
- Verify the pin out against T568A or T568B.
- Check that transmit and receive pairs are not swapped.
- Keep each twisted pair together up to termination.
- Clean fibre connectors and inspect end faces.

Reference deep dive: interface states and error counters

An interface reports health through state and counters. Up/Up means the physical link is live and the data link layer works; Up/Down points to a data link fault such as a wrong VLAN; Down/Down points to a missing cable, a dead port or a configuration error. Counters then name the fault: CRC errors, runs, giants, collisions, resets and flapping.

State	Meaning
Up/Up	Physical link live and data link working
Up/Down	Physical link live, data link fault
Down/Down	No physical link or faulty port
Administratively down	Disabled by an administrator

Reference deep dive: port configuration and hardware faults

Speed and duplex mismatches head the list of switch port faults. 100 Mbps full duplex against 100 Mbps half duplex produces collisions and poor throughput, so both ends must match or auto negotiate. Port security disables a port that sees an unauthorised MAC address, leaving it err disabled.

- Read switch logs to find the MAC address that triggered the violation.
- Add the authorised address, or adjust the port security settings.

- Re enable the port with shutdown then no shutdown.
- Match the Power over Ethernet standard: IEEE 802.3af or IEEE 802.3at.
- Check DOM readings for optical power, temperature and voltage.

Reference deep dive: wireless signal and interference

Wireless faults are measured in dBm, decibels relative to a milliwatt. A signal of -67 dBm or better supports voice over IP, video and gaming, while basic browsing and email survive at -70 dBm. Interference comes from neighbouring networks, Bluetooth devices and microwave ovens in the 2.4 GHz band, and from concrete, brick and metal structures.

- Survey the site with a wireless analyser before choosing a channel.
- Choose channels 1, 6 or 11 in the 2.4 GHz band.
- Use the wider channel choice of the 5 GHz band.
- Point omnidirectional antennas vertically; use directional antennas for long links.
- Move access points away from dense walls and metal.

Reference deep dive: spanning tree faults

Spanning Tree Protocol keeps an Ethernet network loop free, and its faults are disruptive. A suboptimal switch becomes root bridge when it holds the lowest priority value, or the lowest MAC address where no priority is set, pushing traffic along inefficient paths. Link failures trigger reconvergence, and a wrong port state breaks connectivity or creates a broadcast storm.

- Set a low priority value on the switch that should be root bridge.
- Apply root guard where the root bridge must never appear.
- Run Rapid STP to shorten reconvergence.
- Enable PortFast on edge ports serving end devices.
- Read the topology with show spanning-tree and its detail form.

Reference deep dive: vlan and trunk faults

A wrong VLAN assignment isolates a device from the resources it should reach, so confirm the port VLAN with show vlan or show interfaces switchport, then check the address, mask and gateway. On trunk links, a missing allowed VLAN, a native VLAN mismatch or a failed Dynamic Trunking Protocol negotiation stops VLAN traffic crossing the link.

- Add a missing VLAN with the allowed vlan add trunk command.
- Set the same native VLAN, the untagged VLAN, at both ends.
- Set the trunk mode manually when DTP negotiation is not wanted.
- Check routed interfaces with show ip interface brief.
- Confirm VLAN routes with show ip route.

Reference deep dive: acl faults and the implicit deny

An access control list filters traffic rule by rule from the top down, and the first match decides the outcome. Every list ends with an invisible deny all, so a packet that matches no rule is dropped. A legitimate flow can be blocked by an overly broad rule above it, or by a list bound to the wrong interface or direction.

- Document each list and the purpose of every rule.
- Find the first rule matching the blocked flow.
- Check its source, destination, protocol and port.
- Confirm the interface and direction the list is bound to.
- Enable logging on suspect rules and review the hits.

Implicit deny all

The deny all at the end of every access control list is invisible in the running configuration but always present. Traffic matching no explicit permit is dropped, so a service that worked yesterday can fail today after a new rule is inserted above the permit that used to match it.

Reference deep dive: routing table and default gateway faults

A router forwards a packet only when it holds a route to the destination network. A missing route makes that destination unreachable, and show ip route reveals the gap. Each entry carries a destination network, next hop, metric and administrative distance, and the lower distance wins: a static route with a distance of 1 beats an OSPF route at 110.

- Check the routing table for the expected network.
- Confirm dynamic protocols learn routes from neighbours.
- Compare metrics where two routes reach one destination.
- Break loops with split horizon and route poisoning.
- Confirm the default route, 0.0.0.0/0, points to the right next hop.
- On end devices, check the gateway sits in the same subnet.

Reference deep dive: ip addressing and dhcp faults

Many connectivity faults are addressing faults: an address from the wrong subnet, a mask that disagrees with its neighbours, a duplicate address claimed by two hosts, or a static address inside the DHCP pool. The engineer verifies the local configuration with ipconfig, ifconfig or ip, then compares it with the documented range.

- Compare the address and mask with the documented range.
- Treat 255.255.255.0 beside 255.255.0.0 as a fault.
- Ping the suspect address; two replies mean a duplicate.
- Keep static addresses outside the pool.
- Enlarge an exhausted pool, or shorten the lease time.
- Verify relay agents and use DHCP snooping against rogue servers.

Static addresses inside the pool

A static address that falls inside the DHCP pool range is offered to another client sooner or later, producing a duplicate address and intermittent loss. Keep every fixed address outside the pool, or reserve it on the server, and record the allocation in the addressing documentation.

Reference deep dive: congestion, latency and packet loss

Congestion appears when demand exceeds capacity, shown by high utilisation, queuing in buffers and dropped packets. Latency has four parts: propagation, transmission, processing and queuing delay. Jitter, the variation in delay, ruins voice and video. Packet loss forces retransmissions, and its causes include congestion, faulty hardware and buffer overflow.

Symptom	Likely cause
High jitter on voice calls	Queuing delay or congestion in the path
Loss climbing at one hop	Congestion, buffer overflow or faulty hardware
Poor wireless throughput	Co channel or adjacent channel interference
Collisions on a switched port	Duplex mismatch between the two ends
Interface resets or flapping	Power, cabling or hardware fault
Storm of broadcast traffic	Loop from an incorrect spanning tree port state
Slower bulk transfers	Retransmissions after dropped packets

Reference deep dive: cable, wireless and protocol analysis tools

Physical and wireless faults need the right instrument. A cable tester proves continuity and wire mapping and finds opens, shorts and crossed wires, while a cable certifier measures attenuation, crosstalk and return loss against Cat 5e, Cat 6 or Cat 6a limits. A time domain reflectometer locates breaks and measures cable length.

- Trace concealed cables with a tone generator and probe.
- Find fibre breaks and bends with a visual fault locator.
- Trace fibre faults and splices with an optical time domain reflectometer.
- Survey channel use and interference with a wireless analyser.
- Capture and filter traffic in Wireshark; follow a TCP stream.
- Compare headers, such as IP time to live, with the norm.

Reference deep dive: command line tools for connectivity and services

The command line remains the fastest way to prove where a fault lies. Ping tests reachability with ICMP echo requests and reports round trip time and loss. Traceroute, or tracert on Windows, lists every hop to the destination, and pathping adds per hop loss statistics.

Tool	Purpose	Watch for
ping 8.8.8.8	ICMP reachability	Round trip time, packet loss
tracert, traceroute	Path discovery	Slow hop or missing reply
pathping	Per hop loss	Loss rising at one hop
arp -a	Address resolution cache	Wrong or missing MAC mapping
ipconfig, ifconfig, ip	Local configuration	Wrong address, mask or gateway
nslookup, dig	Name resolution	Failed lookup or wrong server
netstat -a, ss -tln	Connections and ports	Unexpected listening service
route -n	Routing table	Missing or incorrect route
tcpdump -i eth0	Packet capture	Storms and repeated retries
iperf -s, iperf -c	Bandwidth test	Throughput below link speed

Practical cautions

- Do not rely on antivirus alone, signatures miss unknown threats.
- Do not choose blocklisting over allowlisting for unknown threats.
- Do not skip input validation, every field is a potential injection point.
- Do not confuse XSS (hijacks the browser) with CSRF (hijacks the action).
- Do not assume the cloud vendor secures your data and configuration.
- Do not assume private cloud has no shared responsibility, duties are still divided.
- Do not treat all hypervisors as equal, a Type 1 bare-metal hypervisor is safer than Type 2.
- Do not treat containers as perfectly isolated, they share the kernel.

Self-check questions

1. Name the five layers of the endpoint protection stack.
2. Why does allowlisting beat blocklisting, and what does code signing add?
3. What is the difference between XSS and CSRF?
4. Which fix stops SQL injection, and what is the role of input validation?
5. Where does the shared responsibility line fall for IaaS versus SaaS?
6. Name the four cloud deployment models and how they shift responsibility.
7. What is VM escape, and why is a Type 1 hypervisor safer than Type 2?
8. Name the three data states and the control that protects each.

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 9

- Match the attack to the fix: injection to parameterised queries; XSS to output encoding; CSRF to tokens.
- The shared responsibility line is a favourite scenario, so know IaaS, PaaS, SaaS and the deployment models.
- Allowlisting versus blocklisting is a direct distinction; code signing verifies origin.
- Misconfiguration, not exotic attacks, is the number one cloud risk.
- Know the three data states, at rest, in transit and in use, and the control for each.
- Type 1 versus Type 2 hypervisor security is a recurring exam point.

Further reading

- OWASP Top 10, the application security risks catalogue.
- NIST SP 800-218, Secure Software Development Framework (SSDF).
- NIST SP 800-190, application container security guide.
- CIS Benchmarks, consensus security configuration guidance.
- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture).



TRAINING @ FORREST.ONE

CHAPTER 10

Vulnerability Management & Asset Protection

Harden from a known good state, secure the devices and the airwaves, defend the application, then run the vulnerability loop: identify, analyse, prioritise, remediate, validate and report.

Student Notes, Vulnerability Management & Asset Protection

Your revision guide for Session 10, arranged chapter by chapter in the order we taught it. Read it alongside the slides, then use the self-check questions and the session quiz to confirm you can run the vulnerability loop and account for every asset.

Key terms

Term	Definition
Secure baseline	The documented minimum security settings a system needs before deployment
Configuration drift	Divergence from the baseline, through unauthorised change or missed update
Ansible / Puppet / Chef / SaltStack	Configuration management tools that apply settings and report drift
Attack surface	Every point where an attacker can send or take data
Hardening	Shrinking the attack surface: services, ports, accounts, permissions
Secure boot	Refuses to load unauthorised firmware during start up
MDM	Mobile device management: policy, configuration, compliance checks, remote wipe
BYOD	Bring your own device: flexibility and lower cost, less control
Containerisation	Isolates work data so personal applications cannot reach it
WEP / WPA / WPA2 / WPA3	The four generations of wireless encryption, each replacing the failure before it
Pre-shared key	One passphrase shared by all users of a wireless network
RADIUS	Remote Authentication Dial-In User Service: per-user enterprise authentication
Rogue access point	Unauthorised wireless hardware on your premises
Site survey	Coverage planning that also sets security zones and stops at your walls
Input validation	Accept only known good data, sanitise the rest, enforce boundaries
Allow listing	Only pre-approved applications may run: list the good, not every bad
Sandboxing	Runs code isolated with limited access to system resources
Code signing	A signature proving software origin and integrity

Term	Definition
WAF	Web application firewall: filters and monitors traffic to the application
RASP	Runtime application self-protection: watches behaviour and blocks live attacks
Credentialed scan	A scan using valid credentials, which sees internal state and missing patches
CVE	Common Vulnerabilities and Exposures: the identifier for a known flaw
CVSS metric groups	Base (the flaw), temporal (exploit and fix state), environmental (your asset)
False positive	A reported vulnerability that does not exist; validate before acting
Compensating control	Extra monitoring or detection where a direct fix is impossible
Risk acceptance	A documented, reviewed decision to live with a known risk
Asset owner	Accountable for the asset and how it may be used
Custodian	Day to day: updates, access control and the asset record
Data sanitisation	Overwriting, degaussing, physical destruction or cryptoshredding
Chain of custody	Unique identifier, every transfer, and the disposal record
SIEM	Aggregates and correlates logs from many sources to reveal patterns
UEBA	User and entity behaviour analytics: baseline normal, flag deviation
Alert fatigue	So many alerts that the one that mattered is missed

Core concepts

1 • Baselines and hardening

A secure baseline is the documented minimum configuration a system must have before deployment, and configuration drift is the quiet divergence that follows. Implementation is four steps: identify the requirements, develop the configuration, test it in a controlled environment, deploy and monitor for drift. Sources include the Centre for Internet Security Benchmarks and vendor hardening guides. Configuration management tools hold the standard at scale: Ansible with readable text files, Puppet with a declarative language, Chef with a domain specific language on Ruby, SaltStack with a master and minion architecture. Hardening reduces the attack surface by auditing services, closing unused ports, removing or securing default accounts and enforcing least privilege, at three layers: operating system (patching, disabled services, mandatory access control), application (secure configuration, updates, validation) and firmware (current versions, secure boot). Balance matters: over-hardening breaks processes and gets rolled back, so assess impact, test, document and review.

2 • Mobile devices and wireless

Mobile devices are lost and stolen, they run many security models, they install unvetted third party applications, and they roam onto public Wi-Fi. Mobile device management answers with central control:

policy, configuration, compliance checks and remote wipe. BYOD buys flexibility and costs control; corporate owned devices buy control and cost freedom; containerisation isolates work data either way; application vetting decides what may be installed. Wireless encryption has four generations: WEP (RC4 with a weak integrity check, broken), WPA (Temporal Key Integrity Protocol, a key per packet, still RC4), WPA2 (Advanced Encryption Standard, pre-shared key or enterprise), and WPA3 (Simultaneous Authentication of Equals, which resists offline guessing and adds forward secrecy). A pre-shared key is one passphrase for everybody; enterprise authentication checks each credential at a RADIUS server. Detect rogue access points by scanning the spectrum, and use the site survey to set coverage and security zones.

3 • Applications and monitoring

Application security begins in the code: least privilege, correct error handling, code review, input validation and boundary checking, with allow listing preferred over blocklisting. The defences around the application are a web application firewall for internet facing services, sandboxing for untrusted content, allow listing for servers, code signing for distribution and runtime self-protection in production. Layer them to cover prevent, contain, verify and detect. Monitoring is continuous observation: watch authentication attempts, privilege usage, network traffic and system change, because you cannot spot abnormal until you know normal. Real-time alerting catches the active threat, trend analysis reveals the campaign, and scope sets both your storage requirement and your detection ceiling. Too many alerts hide the one that mattered.

4 • The asset lifecycle

Asset management starts at the purchase order, with security requirements in procurement, vendor assessment and supply chain verification, which defends against a malicious change during manufacture or delivery. In service, the owner is accountable and the custodian does the daily work, and both depend on an accurate inventory, because the first question after a compromise is what else touched the asset. Tracking is continuous: location for the devices that move, configuration, patch state, licence counts and unauthorised installations. Disposal is a security process: overwriting for reused media, degaussing for magnetic media only (it does nothing for flash), physical destruction for end of life hardware, and verification every time. Chain of custody records each transfer and the disposal, and the GDPR and HIPAA raise the stakes on personal and health data.

5 • Vulnerability management

The loop is identify, analyse, prioritise, remediate, validate, report, and it never closes. Network scanners see the infrastructure, host scanners see one device in depth, application scanners test the web application, and none of them finds a design flaw. A credentialed scan sees missing patches and misconfiguration from inside; a non-credentialed scan sees only what an outsider sees. CVSS scores from three metric groups: base (the flaw itself, fixed), temporal (exploit and fix availability, report confidence) and environmental (how much the asset matters to you). Priority then depends on criticality, exposure, exploitability and validation of suspected false positives, because exposure and active exploitation outrank the raw score. Remediation offers four options: patch, configuration change, compensating control, or documented risk acceptance with an owner and a date. Rescan to confirm the fix, keep exceptions visible, and report counts by severity, average time to patch and trends, with responsible disclosure to the vendor and written rules of engagement for any test.

6 • Monitoring tools and technologies

Every control produces logs, and logs alone change nothing. A SIEM aggregates and correlates logs from many sources, so an event that looks harmless in one log is obvious across three. A log management platform provides collection, storage and retention for investigations and regulators. Network traffic analysis captures packets, catching exfiltration and floods. File integrity monitoring compares critical files against a baseline, exposing tampering and persistence. User and entity behaviour analytics learn normal behaviour and flag deviation, then risk score findings so investigations start where behaviour is strangest. Dashboards carry few metrics drawn clearly, and alert tuning keeps false positives from crowding out real ones.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: change management process

Uncontrolled changes introduce vulnerabilities. A structured change management process keeps the security posture intact.

- Request submission: document every change, however minor, with reasons and expected benefits
- Impact assessment: evaluate security, functionality and performance effects and their risks
- Approval workflow: obtain sign-off from IT managers, security officers and business leaders
- Scheduled implementation: deploy in off-peak or maintenance windows with a rollback plan
- Bypassing the process causes configuration drift and weakens defences

Reference deep dive: security baseline considerations

Security baselines define the minimum security standards for systems and must be reviewed whenever changes occur.

- Update allow lists when new applications, services or users are introduced
- Adjust firewall rules for new servers or architecture to avoid open ports
- Refresh baselines when encryption protocols are updated or deprecated
- Map system dependencies so a change does not cascade into failures
- Test changes in a non-production environment before deployment
- Keep a rollback plan covering backups, restore steps and verification

Reference deep dive: documentation and version control

Documentation underpins security and change management, supporting communication, compliance and continuity.

- Keep network, data flow and architecture diagrams accurate to the live environment
- Review and update policies and procedures as regulations, operations and technology change

- Version control records file and code changes over time
- Key concepts: repository, commit, and branch for independent work
- Good documentation accelerates incident response, eases audits and aids knowledge transfer

Reference deep dive: data types, states and classification

Protect data according to its type, its state and its classification, since each drives the controls and compliance rules you must apply.

- PII identifies individuals and is covered by GDPR and CCPA
- PHI covers health records and is protected under HIPAA
- Financial data is safeguarded under PCI DSS
- Data at rest is stored data, protected mainly by encryption
- Data in transit is moving data, protected by TLS and VPNs
- Data in use is in memory during processing, the hardest to secure
- Classify data as public, internal, confidential or restricted
- Higher classification demands stricter storage, transmission and disposal
- Label data physically or with metadata tags to guide handling
- Train users and update classification policy regularly

Reference deep dive: protecting data at rest

Secure stored data with encryption, strong key management, physical security and safe disposal.

- Full disk encryption (BitLocker, FileVault) protects laptops and mobiles
- File-level encryption targets specific files for granular control
- Database encryption covers columns, tablespaces or entire databases
- Generate, distribute, store and rotate keys securely
- Hardware security modules (HSMs) store keys in tamper resistant hardware
- HSMs offload cryptographic work and support compliance auditing
- Restrict physical access to servers and backup media
- Wipe drives to overwrite data, effective for HDDs and SSDs
- Degauss magnets disrupt magnetic drives but not SSDs
- Physically destroy media when data is highly sensitive

Reference deep dive: high availability

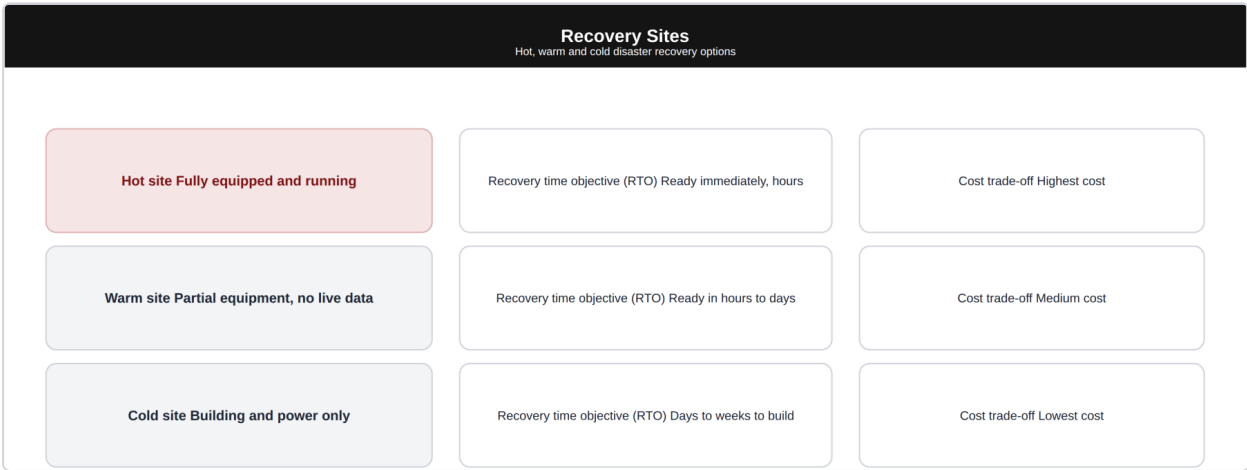
High availability keeps services running despite component failure through redundancy, load balancing, failover and removing single points of failure.

- Uptime percentages measure availability, for example 99.9% means 8.76 hours down a year
- MTBF predicts average time between failures as a reliability gauge
- RAID mirrors or stripes disks for storage fault tolerance
- NIC teaming bonds interfaces for network redundancy and bandwidth

- Clustering lets other servers take over a failed server's workload
- Load balancers spread traffic so no single server becomes a bottleneck
- Failover automatically switches to a standby system on failure
- A single point of failure (SPOF) can bring the whole system down
- Add redundant power supplies, switches and geographic redundancy
- Use diverse network paths from multiple providers

Reference deep dive: site considerations

Figure 10.1: Hot, warm and cold recovery sites and their cost and RTO trade-off.



Site type	Preparedness	Cost / downtime trade-off
Hot	Fully equipped, ready for immediate failover with live replication	Highest cost, near zero downtime
Warm	Partial hardware in place, needs data restore and setup	Moderate cost, short recovery time
Cold	Empty shell with only power and environment	Lowest cost, longest recovery time

- Hot sites suit operations that cannot tolerate any downtime
- Warm sites need a defined disaster recovery plan to activate smoothly
- Cold sites suit workloads where immediate continuity is not critical
- Locate backup sites far enough to avoid the same regional disaster
- Balance distance against the latency it adds to replication

Reference deep dive: backup strategies, RTO and RPO

Figure 10.2: Full, incremental and differential backup strategies compared.

Backup Strategies Full, incremental and differential backups compared					
	Mon	Tue	Wed	Thu	Fri
Full	Full	Full	Full	Full	Full
Incremental	Full	Inc	Inc	Inc	Inc
Differential	Full	Diff	Diff	Diff	Diff

Incremental: smallest backups, restore needs full + every change since. Differential: restore needs full + last differential.

Choose backup types and frequency to meet your recovery objectives, balancing speed, storage and data loss tolerance.

- Full backup copies everything but takes time and storage
- Incremental backs up only changes since the last backup
- Restoring incremental chains needs the full plus every subsequent increment
- Differential captures all changes since the last full backup
- Differential restores need only the full plus the latest differential
- RTO is the maximum acceptable downtime after an incident
- RPO is the maximum acceptable data loss, measured in time
- Short RTO and RPO demand more frequent backups and faster recovery tools
- Assess data criticality, resources and test recovery against targets

Reference deep dive: power, environment and platform diversity

Physical and platform controls underpin availability. Keep power flowing, the environment stable and technology varied.

- UPS supplies battery backup against brief power interruptions
- Generators cover long outages without a gap in supply
- Managed power distribution monitors and optimises usage
- Cooling prevents overheating and hardware failure
- Gas based fire suppression protects electronics better than water
- Humidity control avoids static discharge and condensation
- Platform diversity spreads risk across technologies and vendors
- Using varied OS, software and hardware stops one flaw hitting everything
- Multiple vendors avoid a single interruption taking the whole system down

Reference deep dive: testing resilience and recovery

Validate your resilience plans through structured testing so you discover gaps before a real incident does.

- Tabletop exercises walk teams through scenarios to test response plans
- Tabletops expose communication gaps and procedure weaknesses
- Simulations stress systems under load and model real failures
- Full failover switches to backup systems to prove they work
- Parallel processing tests recovery without disrupting normal operations
- Test regularly and document outcomes, lessons and recommendations

Reference deep dive: business continuity planning

Business continuity planning keeps essential functions running during and after disruption, guided by the business impact analysis.

- BIA identifies critical processes and their dependencies
- BIA sets acceptable downtime, feeding the recovery time objective
- COOP keeps essential functions running across a range of emergencies
- IT disaster recovery restores systems and data as part of COOP
- Broader continuity covers people, facilities and supply chains
- Review the plan annually and after any significant change
- Train staff and run drills so response is swift in a real emergency

Reference deep dive: asset acquisition, assignment and disposal

Asset management tracks hardware, software and data through the full lifecycle. Knowing what you have underpins risk management, compliance and incident response.

- Define security requirements during procurement.
- Assess vendor reputation, compliance and security practices.
- Verify the supply chain to prevent tampering.
- Designate an owner and custodian for every asset.
- Keep accurate inventory records of location and status.
- Track configuration, location and patch status continuously.
- Manage software licences and flag unauthorised installs.
- Sanitise data on disposal with overwriting, degaussing or destruction.
- Document the disposal process and chain of custody.

Reference deep dive: vulnerability identification

Vulnerability scanning finds known weaknesses across networks, hosts and applications. Schedule scans and define scope so you catch issues without disrupting operations.

- Network scanners check routers, switches and open ports.
- Host scanners review operating systems and installed applications.

- Application scanners test web apps for injection and XSS.
- Credentialed scans reveal issues only an authenticated user can see.
- Non-credentialed scans view systems from outside and miss deep faults.
- Schedule scans by risk tolerance and system criticality.
- CVE identifiers give a standard way to track each vulnerability.
- Subscribe to feeds to stay current with new threats.

Reference deep dive: vulnerability analysis and prioritisation

Analysis turns raw findings into an ordered response list. Combine CVSS scores with business context and validate results to avoid chasing false positives.

- CVSS base metrics cover attack vector, complexity and impact.
- Temporal metrics reflect exploit availability and remediation.
- Environmental metrics weigh asset importance to your organisation.
- Prioritise assets by criticality, exposure and exploitability in the wild.
- Validate findings manually or with extra tools to cut false positives.
- Categorise findings by score and criticality.
- Automate monitoring to keep track of changing exploitability.
- Build a remediation plan with timelines and owners.

Reference deep dive: remediation, validation and exceptions

Fixing a vulnerability is not the end: verify the fix, manage what cannot be fixed yet, and report progress to stakeholders with clear metrics.

- Patch software to remove known vulnerabilities.
- Change configurations to shrink the attack surface.
- Use compensating controls where a direct fix is not possible.
- Document and review risk acceptance decisions.
- Rescan to confirm remediation worked.
- Log exceptions with reasons, compensating controls and timelines.
- Report metrics like time to patch and systems patched.
- Track trends and keep stakeholders informed.

Practical cautions

- Do not treat a baseline as a one-off project; holding the configuration there is continuous work.
- Do not harden without assessing operational impact; a broken control gets switched off quietly.
- Do not rely on secure boot alone for firmware; keep firmware versions current as well.
- Do not share one pre-shared key across a large wireless estate; use enterprise authentication.
- Do not expect WPA2 to resist offline guessing; that is what the WPA3 handshake adds.

- Do not blocklist input; allow listing names what is permitted and refuses the rest.
- Do not treat a sandbox as a fix; it contains what runs, it does not make code safe.
- Do not treat CVSS score as risk; criticality, exposure and exploitability decide priority.
- Do not remediate a suspected false positive without validating it first.
- Do not rely on non-credentialed scans alone; credentialed scans see missing patches.
- Do not assume a wider scan scope is free; it sets your storage bill and detection ceiling.
- Do not degauss flash media; use overwriting, cryptographic erasure or destruction instead.
- Do not discard hardware without verified destruction and chain of custody records.
- Do not leave alerts untuned; noise hides the alert that mattered.

Self-check questions

1. What is a secure baseline, and what is configuration drift?
2. Name the four steps of implementing a baseline, and two sources for the settings.
3. What does each configuration management tool use to define its configuration?
4. Give four hardening actions a host audit would produce.
5. What are the three hardening layers, and what does secure boot refuse?
6. Why does over-hardening fail, and what four things should you do about it?
7. What risks make mobile devices different, and what does MDM provide?
8. Compare BYOD with corporate owned devices, and say where containerisation fits.
9. Name the four wireless encryption generations and what WPA3 adds.
10. What is the difference between a pre-shared key and enterprise authentication?
11. What is a rogue access point, and how do you detect one?
12. List five secure coding practices and the payoff for input validation.
13. Name the application defences and where each earns its place.
14. What four things should monitoring watch, and why?
15. How do alerting strategy, scope and storage interact?
16. What are the roles of the asset owner and the custodian?
17. What does continuous tracking cover, and why do licences belong there?
18. Name four data sanitisation methods and say which does not suit flash media.
19. What is chain of custody, and which regulations raise the stakes?
20. Differentiate network, host and application scanners, and name the blind spot.
21. What does a credentialed scan see that a non-credentialed scan cannot?
22. Describe the three CVSS metric groups.
23. Which contextual factors set priority above the score?
24. Name the four remediation options.
25. What does rescanning confirm, and what metrics belong in the report?
26. What does a SIEM do that a single log cannot?

27. What is user and entity behaviour analytics for, and why tune alerts?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz. The quiz shows the session area for every question, so a low score tells you exactly which slides to revisit.

Exam tips for Session 10

- The loop order, identify, analyse, prioritise, remediate, validate, report, is directly examinable.
- Baseline and drift, and the four implementation steps, appear in process questions.
- Hardening is attack-surface reduction: fewer services, ports, accounts and permissions.
- The three hardening layers and secure boot are a frequent separation question.
- Credentialed versus non-credentialed scanning is a classic comparison.
- CVSS base, temporal and environmental metric groups are commonly tested.
- Severity is not risk: criticality, exposure and exploitability set priority.
- Remediation options run patch, configure, compensate, accept, with a documented owner and date.
- WEP, WPA, WPA2 and WPA3 in order, with the WPA3 handshake, is a favourite sequence.
- Mobile device management, containerisation and application vetting answer mobile scenarios.
- Data sanitisation method matching is common: overwrite, degauss, destroy, cryptoshred.
- Verification and chain of custody are the compliance half of disposal.
- SIEM correlation, log retention and alert fatigue answer monitoring tooling questions.

Further reading

- Centre for Internet Security Benchmarks: baseline configuration guidance.
- FIRST: the CVSS specification, including temporal and environmental metrics.
- MITRE: the CVE list; NIST: the National Vulnerability Database.
- NIST SP 800-40: enterprise patch management planning.
- NIST SP 800-124: guidelines for managing the security of mobile devices.
- NIST SP 800-88: media sanitisation guidelines.



TRAINING @ FORREST.ONE

CHAPTER 11

Security Operations, Monitoring & Forensics

Alerting and monitoring concepts, the incident response lifecycle, digital forensics and evidence handling, and the indicators of malicious activity across the estate.

Student Notes, Security Operations, Monitoring & Forensics

Your revision guide for Session 11 (Lessons 12 to 13 · Domain 4, Security Operations, 28% of the exam, the largest domain). Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready. The session runs in six chapters: monitoring and network security devices, endpoint and data controls, identity and automation, incident response, threat hunting and forensic evidence, then logs and consolidation. Domain 4 is scenario-heavy and rewards order-of-operations thinking: monitor, control, respond, hunt, investigate.

Key terms

Term	Definition
Packet filtering firewall	Network layer filtering on source, destination, protocol and port, with no state
Stateful inspection	Keeps a state table and judges each packet by its conversation
NGFW	Next-generation firewall: application awareness, deep packet inspection, intrusion prevention
WAF	Web application firewall: layer 7, reads HTTP and HTTPS requests and blocks web attacks
DMZ	Demilitarized zone: a segmented zone between the internet and the internal network
IDS	Intrusion detection system: passive, detects and alerts only
IPS	Intrusion prevention system: inline, drops packets, blocks addresses, resets connections
Signature-based detection	Matches traffic against a database of known attack patterns
Anomaly-based detection	Baselines normal activity and alerts on deviation
DNS filtering	Blocks malicious or policy-breaking domains at the name resolution query
DLP	Data loss prevention: monitors, detects and controls movement of sensitive data
NAC	Network access control: posture check before a device joins the network
EDR	Endpoint detection and response: behaviour-based endpoint monitoring and response
XDR	Extended detection and response: correlates endpoint, network and cloud data
IAM	Identity and access management: controls who has access to what
User lifecycle	Onboarding, role changes, and offboarding (deprovisioning)

Term	Definition
SSO	Single sign-on: one credential, many systems, and a single point of failure
Federation	Trust between an identity provider and a service provider, proven by a token
MFA	Multifactor authentication: two or more different factor categories
TOTP	Time-based one-time password, as generated by an authenticator application
PAM	Privileged access management: just-in-time access, session recording, vaulting
Orchestration	Automated tasks coordinated into one workflow, in sequence
IR lifecycle	Preparation, detection and analysis, containment, eradication, recovery, lessons learned
Incident classification	Type: unauthorised access, malware, denial of service, data breach
Severity	Low, medium, high, critical, which drives response urgency
Tabletop exercise	Discussion-based walkthrough of a scenario, low cost, exposes plan gaps
Functional exercise	Hands-on testing of specific capabilities with real tools
Full-scale exercise	Multi-team, all roles performed, end to end
After-action review	What worked, what was difficult, what changes; findings feed the plan
Threat hunting	Proactive searching for threats that the alerts missed
Indicator sweeping	Searching the estate for known indicators of compromise
Root cause analysis	Finding the underlying cause of an incident so it cannot recur
Write blocker	Prevents any change to the original storage device during examination
Forensic imaging	Bit-for-bit copy, including deleted and hidden data
Hash verification	Comparing hashes of the original and the image to prove nothing changed
Chain of custody	The documented history of evidence handling
Order of volatility	Capture the most volatile data first: registers, memory, then disk
Memory forensics	Analysing RAM: running processes, open connections, malware remnants
Metadata analysis	Creation dates, authorship, modification history
SIEM	Aggregates and correlates monitoring sources into one view
Retention policy	How long logs are kept, archived and then deleted
C2 beacon	Small, regular connections to a command-and-control host
Impossible travel	Logins from locations too far apart in time to be real

Core concepts

Chapter 1 · Monitoring and network security devices

Firewalls progress by what they can see: packet filtering matches addresses, ports and protocol with no state; stateful inspection adds the conversation; the next-generation firewall adds application awareness, deep packet inspection and intrusion prevention. Rules need specific creation, change control and regular review, and firewalls enforce segmentation including the DMZ. The web application firewall works at layer 7, reading HTTP and HTTPS requests to block injection and cross-site scripting. An IDS detects and alerts; an IPS drops, blocks and resets. Detection is either signature-based (known threats, blind to novelty) or anomaly-based (baselines, unknown threats, more false positives), and tuning is what keeps both useful. Host logs matter too: the xrdp log on a Kali box records every RDP attempt, and a run of failures followed by a success from one address means brute force that worked.

Chapter 2 · Endpoint and data controls

Domain Name System filtering intercepts the name resolution query and checks it against a blocklist or allowlist, denying the request before a connection exists. Data loss prevention watches data in motion (network) and at rest or in use (endpoint), matching content, context and user action, with actions that alert, block or encrypt. Network access control checks posture (antivirus, updates, credentials) before a device joins, then denies or quarantines anything non-compliant. Endpoint detection and response watches behaviour and telemetry, which is how it catches zero-day and advanced persistent threats that signature antivirus misses. Extended detection and response correlates endpoint, network and cloud data, and the alert investigation workflow runs triage, analysis, contextualisation, response planning, then remediation and recovery, with automated responses such as isolating an endpoint or revoking credentials.

Chapter 3 · Identity, access and automation

Identity and access management provisions accounts, modifies them on role change and deactivates them on exit; late offboarding is a common audit finding. Single sign-on is convenient and a single point of failure, so pair it with multifactor authentication. Directory services hold the identities (Active Directory, LDAP, cloud directories); federation links identity systems with trust and tokens; identity governance runs the access reviews. Multifactor authentication combines different factor categories (know, have, are), and two passwords are still one factor. Privileged access management adds just-in-time access, session recording and password vaulting, so every privileged use is attributable. Automation covers patching, provisioning and incident response playbooks, while orchestration chains those tasks into one workflow. Guardrails are mandatory: test changes, restrict who edits scripts, log every action, and keep human oversight for judgement, exceptions and ethics.

Chapter 4 · Incident response

The four phases, in order: preparation (policy, tools, written plan, trained people, rehearsals); detection and analysis (identify, scope, grade); containment, eradication and recovery (isolate, remove the cause, restore from validated backups); then lessons learned. Containment and eradication are different jobs, and containment preserves evidence but can alert the adversary. Classification (unauthorised access, malware, denial of service, data breach) and severity (low to critical) drive urgency, while named roles remove hesitation: handlers, management, legal, communications. Preparation is tested by tabletop, functional and

full-scale exercises, each testing more of the plan than the last. Responder training and general staff awareness are ongoing, and the after-action review feeds findings back into the plan.

Chapter 5 · Threat hunting and forensic evidence

Threat hunting assumes an attacker is already inside. Hypothesis-driven investigation tests an idea with targeted searches, and indicator sweeping searches the estate for known indicators of compromise (addresses, file hashes, domains); findings sharpen the detection rules. Root cause analysis runs in order: identify the problem, gather data, analyse for patterns, identify the root causes (configuration, behaviour or vulnerability), develop and implement solutions, then monitor their effect. Forensics collects and preserves evidence: collection from computers, mobile devices and network systems; write blockers so nothing changes; forensic imaging bit by bit, including deleted and hidden data; hash verification between original and image; and volatile data before disk. The chain of custody records every handler, and an unbroken chain is what makes evidence admissible; authorisation (warrant or consent) and privacy law (GDPR, ECPA) shape collection, and evidence must be organised, documented and reported.

Chapter 6 · Logs, investigation and consolidation

Security logs record logins and privilege changes; system logs cover boot, hardware and errors; application logs capture errors, interactions and transactions; network device logs cover traffic, status and configuration change; firewall logs record allowed and denied traffic. Collection feeds centralisation into a SIEM, where correlation turns separate events into one story, and retention policy decides how long logs are kept, archived and deleted, set by regulation and investigative need. Beyond logs sit network capture, memory forensics (running processes, open connections, malware remnants) and metadata analysis (creation dates, authorship, modification history). Indicators close the session: malware (virus, worm, Trojan, ransomware, spyware, rootkit, botnet); network (port scanning, data exfiltration, command-and-control beaconing); application (injection probes, phishing email); and behavioural (privilege escalation, impossible travel, data volume spikes).

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: security monitoring fundamentals

Monitoring continuously observes systems and networks to detect events that signal intrusion. What you watch and how you alert shapes your detection capability.

- Monitor authentication attempts for brute force patterns.
- Watch privilege usage by elevated accounts.
- Analyse network traffic for exfiltration and anomalies.
- Track system and file changes for persistence attempts.
- Use real-time alerting for active threats.

- Use trend analysis to spot emerging coordinated attacks.
- Broader scope improves detection but raises storage needs.
- Balance monitoring scope with storage and analysis capacity.

Reference deep dive: monitoring tools

A range of tools aggregate, analyse and respond to security data. Choose tools that correlate events and cut noise so teams can focus on genuine threats.

- SIEM aggregates and correlates logs from many sources in real time.
- Log management centralises collection, storage and analysis.
- Network traffic analysis inspects packets for anomalies.
- File integrity monitoring detects unauthorised file changes.
- UEBA uses machine learning to spot behavioural deviations.
- Good dashboard design highlights critical metrics.
- Alert tuning reduces false positives and alert fatigue.

Reference deep dive: firewalls and network security devices

Firewalls sit between trusted and untrusted networks, filtering traffic by rule. Choose the right type and manage rules carefully to enforce segmentation.

- Packet filtering checks IP, protocol and port only.
- Stateful firewalls track active connections.
- NGFWs add application awareness and intrusion prevention.
- Manage rules with change control and regular review.
- Firewalls enforce segmentation like DMZ and guest zones.
- WAFs protect web apps from SQL injection and XSS.
- WAFs operate at the application layer on HTTP traffic.

Reference deep dive: IDS, IPS, DNS filtering, DLP and NAC

Detection and control devices work together in layers. IDS and IPS flag or block intrusions, while DNS, DLP and NAC enforce policy at different points.

- IDS detects and alerts, IPS also blocks threats.
- Signature detection catches known attacks only.
- Anomaly detection spots new threats but raises false positives.
- Network-based systems watch whole networks at gateways.
- Host-based systems catch insider threats on individual devices.
- Tune sensitivity and update signatures to balance alerts.
- DNS filtering blocks access to malicious and policy-violating domains.
- DLP monitors and blocks sensitive data movement.
- NAC checks device compliance before granting network access.

Reference deep dive: EDR and XDR

EDR and XDR move beyond signature antivirus to behavioural detection and coordinated response. They give analysts telemetry to trace and contain threats.

- EDR uses behavioural analysis rather than signatures alone.
- EDR exposes process trees, file changes and connections.
- XDR extends detection across endpoints, networks and cloud.
- XDR correlates layers to spot complex attack patterns.
- Alert workflows run triage, analysis and response planning.
- Automated actions isolate endpoints and block malicious IPs.
- Automation revokes compromised credentials quickly.

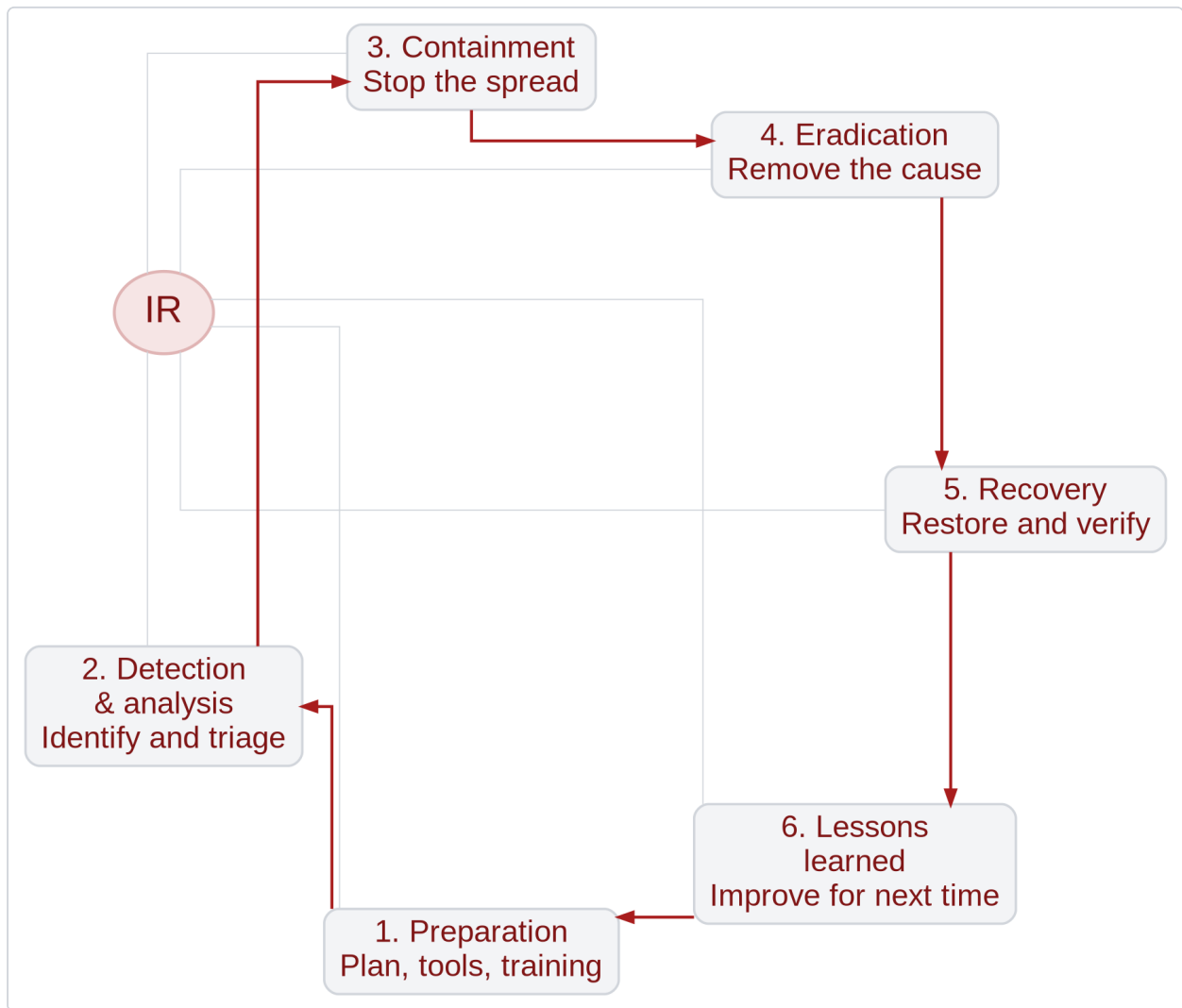
Reference deep dive: automation and orchestration

Automation runs security tasks with minimal human input, and orchestration sequences them into workflows. Keep guardrails so automated actions cannot harm.

- Automate patching, account provisioning and response playbooks.
- Orchestration coordinates tasks in the correct sequence.
- Scripting customises workflows and ensures consistency.
- Test automated processes before deployment.
- Restrict who can modify or run scripts.
- Log and monitor automated actions for anomalies.
- Keep human oversight for complex or ethical decisions.

Reference deep dive: incident response phases

Figure 11.1: The incident response lifecycle.



A structured incident response plan limits damage and speeds recovery. Work through distinct phases from preparation through to learning.

- Preparation builds plans, tools and trained responders.
- Detection and analysis find and scope the incident.
- Containment isolates affected systems to limit damage.
- Eradication removes the cause of the incident.
- Recovery restores systems from backups and patches.
- Lessons learned update the plan and future responses.
- Classify incidents by type like malware, DoS or breach.
- Rate severity from low to critical to set response urgency.

Reference deep dive: IR training, testing, threat hunting and root cause analysis

Regular exercise and proactive hunting keep response teams sharp and reveal gaps before real crises. Dig into causes to stop incidents recurring.

- Tabletop exercises walk through scenarios in discussion.
- Functional exercises test hands-on response skills.
- Full-scale exercises involve many teams end to end.
- After-action reviews feed lessons into future training.
- Threat hunting actively searches for evaded threats.
- Hypothesis-driven hunting tests patterns against data.
- Indicator sweeping hunts known IOCs across systems.
- Root cause analysis fixes the underlying cause, not symptoms.
- Hunting insights feed incident response and security improvements.

Reference deep dive: digital forensics and log data

Forensics collects and preserves electronic evidence so it stays intact and admissible. Logs and extra data sources reconstruct what happened in an incident.

- Collect evidence without altering the original data.
- Write blockers prevent changes during examination.
- Forensic imaging makes bit-by-bit copies for analysis.
- Hash verification confirms evidence is unaltered.
- Chain of custody records every handover of evidence.
- Obtain authorisation and respect privacy laws.
- Security, system, application and network logs each add detail.
- Centralise and retain logs per compliance needs.
- Network captures, memory forensics and metadata extend analysis.

Practical cautions

- Do not assume a plain firewall sees the application. Only a next-generation firewall does.
- Do not confuse detection with prevention. An IDS alerts; an IPS acts.
- Do not leave detection untuned. Anomaly-based detection floods, and alert fatigue hides real incidents.
- Do not start response at containment. Preparation comes first.
- Do not treat every incident alike. Classify it and grade its severity.
- Do not skip the after-action review. Lessons learned prevent recurrence.
- Do not analyse the original drive. Image and hash first, then work on the copy.
- Do not collect evidence without authorisation. A warrant or consent comes first.
- Do not ignore the order of volatility. Memory will not wait for the disk.
- Do not celebrate 'service restored'. Verify and monitor.

- Do not set retention by convenience. You cannot investigate what you never kept.
- Do not let automation make the judgement call. Keep a human on exceptions and ethics.

Self-check questions

1. What does each firewall type add: packet filtering, stateful inspection, next-generation firewall?
2. What process must precede a firewall rule change, and what should a rule review remove?
3. At which OSI layer does a web application firewall work, and what does it read?
4. State the difference between an IDS and an IPS in one sentence.
5. Compare signature-based and anomaly-based detection, including the weakness of each.
6. What pattern in an xrdp session log suggests brute force that succeeded?
7. Where does each control act: DNS filtering, DLP, NAC?
8. Why does endpoint detection and response catch what signature antivirus misses?
9. Name the five steps of the alert investigation workflow.
10. What are the three stages of the user lifecycle, and which one is most often done late?
11. Give the advantage and the risk of single sign-on.
12. Name the three multifactor authentication factors with one example and one weakness each.
13. What three capabilities does privileged access management add, and what do they prove?
14. Name the four incident response phases in order.
15. What is the evidence trade-off in containment?
16. How do classification and severity drive the response, and which roles are involved?
17. Compare tabletop, functional and full-scale exercises.
18. What does an after-action review ask, and where do its findings go?
19. What is the difference between hypothesis-driven hunting and indicator sweeping?
20. Put the root cause analysis steps in order, and explain why the last step matters.
21. Why does forensic collection need authorisation, and how do write blockers help?
22. What does hash verification prove?
23. What does a chain of custody record, and what happens when it breaks?
24. Name five log sources and one tell-tale event for each.
25. Why does retention policy matter to an investigation?
26. What do memory forensics and metadata analysis each reveal?
27. Which monitoring layer would catch a command-and-control beacon, and which would catch impossible travel?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 11

- Sequencing is the exam skill: the IR phases and the order of volatility.
- Learn what each firewall generation can see. Application awareness is the NGFW line.
- Know the control-to-layer match: firewall and NGFW, NAC, DLP, EDR, XDR.
- Alert fatigue, baselines and tuning are common monitoring items.
- Signature against anomaly detection appears as a comparison question.
- Identity items are scenario-heavy: lifecycle, SSO and federation, MFA factors, PAM.
- Automation questions reward knowing what should stay with a human.
- Chain of custody and order of volatility are guaranteed items.
- Authorisation (warrant or consent) and write blockers appear in forensic scenarios.
- Retention is examined as a compliance and investigation issue.
- Indicators are scenario-based: read the pattern, name the indicator.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 4.
- NIST SP 800-61, incident handling guide.
- NIST SP 800-86, forensic techniques and guidelines.
- NIST SP 800-207, Zero Trust Architecture, for the identity material.



TRAINING @ FORREST.ONE

CHAPTER 12

Governance, Risk, Compliance & Awareness

The layer that turns security into organisational behaviour: policies and standards, risk management, compliance, and the protection of data and privacy.

Student Notes, Governance, Risk, Compliance & Awareness

Your revision guide for Session 12, the course finale (Lessons 14 to 16 · Domain 5, Security Program Management and Oversight, 20% of the exam). Six chapters take you from why governance exists, through external obligations and risk management, to vendors, compliance, audit and the awareness programme, and then close with the exam consolidation. Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready.

Key terms

Term	Definition
Governance	Direction, rules and accountability for security, aligned to business objectives
Authority	The documented power to decide, approve or authorise
Accountability	Answering for the outcome, reinforced by audits
Policy	High-level statement of management intent
Standard	Mandatory, specific and measurable requirement
Guideline	Recommended practice, not mandatory
Procedure	Step-by-step instructions for a task
Regulatory requirement	A mandatory obligation from a regulator or the law (HIPAA, PCI DSS, GDPR)
Risk identification	Asset inventory, threat modelling and vulnerability assessment
Likelihood / impact	Probability of the event / scale of the consequence
Qualitative risk	Ratings and judgement: high, medium, low
Quantitative risk	Monetary values: SLE and ALE
Exposure factor	The share of the asset value lost if the risk occurs
Annual rate of occurrence	Expected frequency of the event each year
Risk register	Living record of risks, ratings, owners and treatment status
Risk appetite	How much risk the organisation will pursue or retain
Risk tolerance	How far it may drift from that appetite before action

Term	Definition
The four responses	Avoid, transfer, mitigate, accept
Business impact analysis	Identifies critical processes and drives recovery priorities
Rules of engagement	The boundaries of what a vendor may access and do
Compliance	Adhering to the laws and standards that apply to you
Attestation	A formal declaration that controls meet stated criteria: SOC 1, SOC 2, SOC 3
Internal / external audit	Own staff for self assessment / independent third party for assurance
Awareness programme	Audience analysis, objectives, content, delivery, measurement
Data classification	Public, internal, confidential, restricted
Data owner / steward / custodian	Accountable / governance / implementation
GDPR / UK GDPR	EU and UK data protection frameworks
Data sovereignty	Data is subject to the law where it resides

Core concepts

Chapter 1: Governance Foundations

Governance comes first because it aligns security with business objectives, stops security being implemented in isolation, targets spending at what the business depends on, and sets the risk appetite. Structure matters: a cross-functional security committee, reporting lines that reach the chief executive or the board, and executive oversight that supplies direction, resources and review. Authority is the documented power to decide; accountability is answering for the outcome. Executive roles are the chief information security officer, security directors and the board. Operational roles are analyst, administrator and architect, with data ownership split between the accountable owner and the implementing custodian. The four document types form a hierarchy: policy (intent), standard (mandatory and measurable), guideline (recommended), procedure (the steps). Every document is developed, approved, distributed and reviewed.

Chapter 2: External Obligations and Risk Identification

Requirements arrive from regulators, contracts and the law, and external obligations become internal policy. Regulatory: HIPAA, PCI DSS, NERC CIP, GDPR and CCPA, each targeting a sector or region. Contractual: service level agreements, data processing agreements and partnership agreements, with the NIST Cybersecurity Framework as a common baseline. Legal: liability, due diligence, jurisdiction and privacy law. Risk identification uses the asset inventory, threat modelling and vulnerability assessment, because you cannot manage a risk you have never named. Assessment sits on two axes: likelihood and impact, expressed either qualitatively (ratings) or quantitatively (money and probabilities), and usually as a hybrid.

Chapter 3: Risk Analysis, Registers and Treatment

The calculation: single loss expectancy is asset value times exposure factor; annualised loss expectancy is single loss expectancy times the annual rate of occurrence. With an asset value of 100,000, an exposure factor of 40 percent and a rate of 0.1, that gives an SLE of 40,000 and an ALE of 4,000 a year. Every risk goes into a register that describes it, rates it, names an owner and tracks treatment status. Appetite is how much risk the organisation will pursue or retain; tolerance is how far it may drift from that appetite. The four responses are avoid, transfer, mitigate and accept, and acceptance is always a documented management decision.

Chapter 4: Risk Reporting, Business Impact and Vendors

Reporting is tailored by audience: technical detail for teams, business consequences for executives, compliance and plain language for the board and regulators, with dashboards, detailed reports and executive summaries as the formats. A business impact analysis identifies critical processes, maps dependencies, assesses consequences and drives recovery priorities and resource allocation. Vendor risk starts before the contract: questionnaire, documentation review, on site assessment, due diligence, with depth matched to risk. Contracts carry data handling, incident notification, audit rights, security-based service levels and an exit clause. Monitoring continues afterwards, with compliance verification, performance tracking and clear rules of engagement under least privilege.

Chapter 5: Compliance, Privacy and Audit

Compliance means adhering to the laws and standards that apply to you, and it is proved with evidence. Frameworks have territory: PCI DSS for cardholder data, HIPAA for medical information, SOX for financial reporting, GDPR for personal data of EU citizens. Monitoring is continuous, using a security information and event management system and configuration management, with manual review for interpretation, and logs and audit trails as the evidence. Non-compliance costs money, permission, trust and legal liability, with penalties up to four percent of global turnover or twenty million euro. Privacy law adds subject rights, informed consent and breach notification. Audits are internal (self assessment) or external (independent assurance), and both follow planning, evidence, findings and remediation tracking.

Chapter 6: Assurance, Testing and Awareness

Attestation is a formal declaration that controls meet stated criteria: SOC 1 for financial reporting controls, SOC 2 for security, availability, processing integrity, confidentiality and privacy, SOC 3 as a high-level summary. Penetration testing actively proves the controls, in black box, white box or grey box form, with scope agreed first and findings remediated and retested. An awareness programme starts with audience analysis, sets specific, measurable and time bound objectives, uses current and recognisable content, delivers by role, and measures with assessments, simulations and reported incidents. Phishing training teaches recognition and one reporting route, then simulates with progressive difficulty, immediate feedback and reasonable pacing.

Data protection and exam consolidation

Classification is public, internal, confidential and restricted, with the higher class receiving stronger protection, and three states, at rest, in transit and in use. Roles: owner accountable, steward governing, custodian implementing. The lifecycle runs collect, store, use, share, archive, destroy, with retention policy and secure

destruction at the end. GDPR and UK GDPR supply principles, rights, informed consent and the breach notification duty; sovereignty means data answers to the law of the jurisdiction where it resides, with GDPR and CCPA applying by data-subject location.

Reference deep dive

Consolidated exam-depth material drawn from the course reference text. Use this alongside the core concepts above to reach beyond revision level and into the depth the SY0-701 exam expects.

Reference deep dive: governance documents and security roles

Security governance aligns security activities with business objectives and risk appetite. A documented hierarchy of controls keeps this consistent, and clear role ownership prevents gaps and duplication.

Document	Purpose	Level
Policy	High level statement of management intent, sets strategic direction	Strategic
Standard	Mandatory requirement derived from policy, measurable benchmarks	Specific
Guideline	Recommended practice, flexible how to guidance, not mandatory	Advisory
Procedure	Step by step instructions for performing a task	Granular

- Document lifecycle: develop, approve, distribute, review periodically
- CISO sets strategy and bridges technical and executive teams
- Security directors oversee domains and incident response planning
- Board provides executive oversight and holds the programme accountable
- Data owner classifies data and decides access and protection level
- Data custodian implements the technical controls to protect that data

Reference deep dive: risk identification and assessment

Risk management identifies, evaluates and addresses threats. Assessment estimates likelihood and impact, then prioritises risks for treatment.

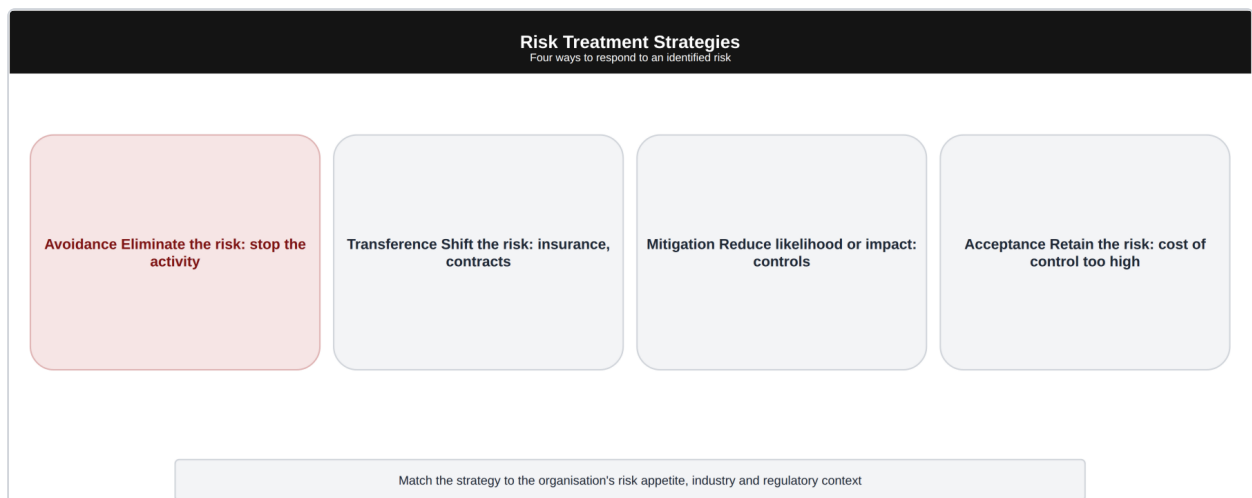
- Identify risks via asset inventories, threat modelling and vulnerability assessment
- Likelihood is the probability a risk occurs; impact is the damage if it does
- Qualitative uses descriptive scales (high, medium, low); quick for initial review
- Quantitative uses numbers; supports SLE, ARO and ALE calculations
- Risk register is a living document: risk ID, rating, owner and treatment status

Metric	Formula	Meaning
AV	Asset value	Total worth of the asset to the organisation

Metric	Formula	Meaning
EF	Exposure factor	Percentage of asset value lost if risk occurs
SLE	$AV \times EF$	Single loss expectancy for one occurrence
ARO	Annual rate of occurrence	Estimated frequency of the risk per year
ALE	$SLE \times ARO$	Expected annual financial loss from the risk

Reference deep dive: risk appetite, tolerance and treatment

Figure 12.1: The four risk treatment strategies.



Risk appetite is the risk an organisation will pursue; tolerance is the acceptable variation from it. Four strategies treat identified risks.

- Appetite sets the overall limits; tolerance sets day to day operating boundaries
- Avoidance: eliminate the risk by not doing the activity at all
- Transference: shift risk via insurance or contracts to a third party
- Mitigation: reduce likelihood or impact using controls, usually preferred
- Acceptance: retain risk when mitigation cost exceeds potential impact
- Match the chosen strategy to industry, regulation and business context

Reference deep dive: risk reporting, BIA and vendor management

Tailor risk reporting to the audience and assess business impact to drive recovery priorities. Manage third party risk from selection through monitoring.

- Technical teams need detail; executives need business impact; board needs compliance focus
- Use dashboards, detailed reports and executive summaries as formats
- BIA identifies critical processes, dependencies and disruption consequences
- BIA drives recovery priorities and resource allocation
- Assess vendors via questionnaires, documentation review and on site visits

- Check financial stability, certifications, incident history and references

Agreement	Purpose
SLA	Defines performance and security metrics such as uptime and response times
MSA	Master terms governing the overall vendor relationship
DPA	Governs processing of personal data, GDPR compliance
NDA	Legally binds vendor to confidentiality obligations
RoE	Boundaries, access limits and escalation for vendor activities

Reference deep dive: compliance, audits, attestation and pen testing

Compliance means adhering to laws, regulations and standards. Audits and attestation prove it, while pen testing actively finds weaknesses.

- Frameworks: PCI DSS, HIPAA, SOX and GDPR; apply per industry, geography and data type
- Compliance is a baseline; security should go beyond it for emerging threats
- Monitor compliance with SIEM, configuration tools and manual reviews
- Non compliance brings fines, sanctions, loss of operating authority and legal liability
- Internal audits self assess and improve; external audits give objective assurance
- Attestation: SOC 1 financial, SOC 2 security/availability, SOC 3 general audience
- Pen testing: black, white and grey box, with scoped rules of engagement and remediation

Reference deep dive: security awareness and user programme

A sound awareness programme analyses the audience, sets clear objectives, and measures results to strengthen users as the first line of defence.

- Analyse audience, assess current knowledge and set SMART learning objectives
- Deliver via CBT, instructor led sessions and ongoing awareness campaigns
- Phishing training uses progressive difficulty, diverse scenarios and immediate feedback
- Track click rates and reporting rates to measure training effectiveness
- Give clear reporting channels and reward reporting, never punish it
- Recognise anomalous behaviour: unsolicited requests, impersonation, urgency and odd grammar
- Insider threat signs: unusual access, disgruntlement, data hoarding, bypassing controls
- Physical risks: tailgating, unattended devices and suspicious packages

Practical cautions

- Do not confuse policy (intent) with standard (requirements), or standard with guideline (advisory).
- Do not treat guidelines as mandatory.

- Do not confuse authority (the power to decide) with accountability (answering for the outcome).
- Do not treat appetite and tolerance as the same idea.
- Do not accept risk without management sign-off and documentation.
- Do not write the risk register once and file it away; it is a living document.
- Do not let the contract end the vendor relationship, because monitoring continues after signature.
- Do not treat attestation as proof; penetration testing is what tests.
- Do not run so many phishing simulations that fatigue destroys the reporting habit.
- Do not keep data beyond retention, and do not treat deletion as secure destruction.
- Do not ignore which jurisdiction your cloud data lives in.
- Do not swap the data owner (accountable) with the custodian (implementer).
- Do not treat compliance as the whole of security; go beyond the baseline.

Self-check questions

1. Explain three reasons why governance comes first in a security programme.
2. What is the difference between authority and accountability?
3. Name the four governance document types and give an example of each.
4. Name two regulatory requirements and two types of contractual obligation.
5. Name the three methods used to identify risks.
6. What are the two axes of risk assessment, and how do qualitative and quantitative methods differ?
7. Calculate the SLE and ALE for an asset worth 100,000 with an exposure factor of 40 percent and an annual rate of occurrence of 0.1.
8. What is the difference between risk appetite and risk tolerance?
9. Name the four risk responses and one example of each.
10. What three audiences receive risk reporting, and what does each need?
11. What does a business impact analysis drive?
12. Name four things a vendor contract should require.
13. What is the difference between an internal and an external audit, and what are the four audit stages?
14. What is attestation, and how do SOC 1, SOC 2 and SOC 3 differ?
15. Name the three ways to measure an awareness programme.
16. What is the difference between the data owner and the data custodian?
17. Name four GDPR principles, two data rights, and the breach notification window.
18. What does data sovereignty mean for cloud region choice?

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz. This session's quiz is the final one, so treat a low score as a map of what to revise rather than a verdict.

Exam tips for Session 12

- The exam pairs: policy and standard, standard and guideline, appetite and tolerance, qualitative and quantitative, owner and custodian, internal and external audit, avoid and accept.
- Risk response questions are scenario-based, so match the response to the situation rather than to the wording.
- Expect quantitative items that supply asset value, exposure factor and annual rate of occurrence and ask for SLE or ALE.
- Vendor items test the lifecycle: assess before contract, monitor during, exit cleanly.
- Compliance items test which framework applies, judged by industry, geography and data type.
- Audit items test who conducts the audit and what each type is for.
- Attestation items test the SOC report types and what penetration testing adds.
- Awareness items test programme design and measurement, not just phishing recognition.
- GDPR items: principles, consent, rights, the breach notification window and the penalties.
- Data roles: owner accountable, custodian implements, never reversed.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, Domain 5.
- ICO guidance on UK GDPR principles, rights and breach notification.
- NIST SP 800-30, risk assessment guidance, and NIST SP 800-39 for risk management.
- NIST Cybersecurity Framework, the common contractual baseline named in vendor agreements.